# A Trusted Authorisation Framework for Multi-Party Patient Consent in Healthcare Data Sharing

Principal Supervisor: Professor Farookh Hussain

Co-Supervisor: Dr. Firas Al-Doghman

Presenter: Yasir Dhaifallah O Alyoubi

STUDENT ID #: 24724078

# Contents

1. Introduction.....3
2. Systematic Literature Review.....6
3. Research Gaps & Questions.....17
4. Research Objectives and Methodology.....20
5. Research Architecture: MVC.....23
6. The Proposed Solution for RO1.....31
7. The Proposed Solution for RO2.....35
8. The Proposed Solution for RO3.....39
9. The Proposed Solution for RO4.....44
10. The Proposed Solution for RO5.....49
11. The Proposed Solution for RO6.....54
12. Publications Summary.....72
13. Research Plan.....73
References.....75

# 1. Introduction

## 1.1 Research Context

Secure and trustworthy data sharing is now needed across organisational boundaries. Modern digital ecosystems involve multiple independent stakeholders, including individuals, healthcare providers, regulatory authorities, researchers, and third-party data processors (Ghafoor et al. 2025; Lomotey, Kumi & Deters 2022; Nguyen et al. 2025). Digital services make collaboration easier, but they also raise a governance question: how can data access be authorised and trusted when the participating entities do not belong to a single administrative or institutional domain? Healthcare is a clear example of this problem. The increasing digitisation of healthcare information enables patients, healthcare professionals, guardians, researchers, and healthcare organisations to participate in data-sharing processes (Webber et al. 2019; Welzel et al. 2025). At the same time, healthcare data is highly sensitive, heterogeneous, and often subject to strict privacy, ethical, and governance requirements. Its exchange therefore raises complex questions concerning identity, authority, patient consent, privacy protection, accountability, and fine-grained access control.

Traditional access-control architectures are based on centralised identity providers, institution-specific authentication systems, and relatively static permission-management mechanisms. These approaches can provide effective access control within an organisational boundary, but they become difficult to apply when authorisation decisions involve multiple independent entities. In such settings, no single participant may possess sufficient authority to determine access independently, and trust cannot necessarily be assumed on the basis of membership in a common administrative domain. This problem is particularly relevant in healthcare, where data-sharing decisions may require the coordinated participation of patients, guardians, healthcare professionals, and institutional authorities (Ibrahim et al. 2024; Webber et al. 2019). In these settings, authorisation is a distributed governance problem, not just a check of a user's login and a static permission (Theodorakopoulos, Theodoropoulou & Halkiopoulos 2024).

Blockchain-based mechanisms can provide tamper-resistant recording and distributed auditability (Al Mamun, Azam & Gritti 2022; Hellstern et al. 2022; Li, Liu & Shrestha 2026; Nguyen et al. 2025), while decentralised identifiers can support the identification of participants without relying exclusively on a central identity provider. Verifiable credentials can provide cryptographically verifiable evidence concerning roles or authority, and policy-based access-control mechanisms can restrict access to authorised resources. However, an immutable record does not necessarily demonstrate that the participating entities were legitimate, that they possessed the required authority, or that a subsequent data-access request remains consistent with the conditions originally authorised. Consent must therefore be treated as an active, evaluable part of the authorisation process, not as a static record of permission, extending the dynamic consent perspective (Khalid et al. 2023; Narkhede, Wankhede & Kamble 2025).

## 1.2 Problem Statement

Existing consent-management and decentralised access-control approaches represent authorisation through database records, access-control entries, smart contracts, or blockchain transactions. These mechanisms can improve record integrity, traceability, and auditability, but consent itself often remains a relatively passive artefact indicating that a permission or approval has been created (Jesus & Pandit 2022; Khalid et al. 2023). The relationship between the consent record, the identity of the participants, their authority to act, the applicable policy constraints, and the resulting access decision is frequently treated as separate technical concerns. Likewise, successful authentication establishes that an entity has been identified, but authentication does not automatically establish that the entity possesses the authority to access a particular patient's information. Even where identity and collective approval have been satisfied, an access request may still be inappropriate if it exceeds the authorised purpose or data scope. The requested operation must also be evaluated against the policy constraints associated with the consent.

The central problem addressed by this research is therefore the absence of an integrated trust-oriented mechanism that connects identity, authority, multi-party approval, policy, temporal, and lifecycle conditions within a coherent authorisation decision and whose security can be formally and empirically demonstrated. Existing approaches provide important technological components, including decentralised identity and verifiable credentials (Phuyal et al. 2026b; Wu & Zhang 2025), blockchain-based records, multi-party approval mechanisms (Ekholm et al. 2025; Punia et al. 2025; Tan, Chi & Lam 2024), and policy-based access control (Eneh et al. 2026; Khayer et al. 2025; Panagoulias et al. 2026; Román-Martínez et al. 2023), as well as several partial combinations. However, these mechanisms are often investigated independently or integrated primarily at the implementation level. The overarching research question is how a trust-oriented computing framework can establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority, and policy constraints. The research objectives are operationalised through six corresponding sub-research questions (SRQ1 to SRQ6, referred to as RQ1 to RQ6).

## 1.3 Research Motivation

The motivation of this research is to develop a Trust Computing perspective in which trustworthy healthcare data access emerges from the coordinated verification and enforcement of multiple security conditions. Under this perspective, trust is not treated as a property that is provided by blockchain, decentralised identity, or any other individual technology. Instead, trustworthy authorisation is understood as an emergent property of a decision process in which independently verifiable conditions must be satisfied. Trusted Computing provides an additional perspective on the protection and verification of security-critical processes. Trusted Execution Environments (TEEs), for example, provide hardware-supported isolation that can protect sensitive computation from compromised or untrusted operating environments (Li et al. 2026b; Ménétrey et al. 2022). Remote attestation mechanisms can further provide evidence concerning the integrity of the execution environment in which a security-sensitive process is performed. Nevertheless, Trusted Computing does not by itself determine the correctness of an authorisation policy. Consequently, secure execution and trustworthy authorisation address complementary rather than identical problems. Future work can therefore investigate how trusted execution and remote attestation can strengthen the enforcement and verification of decentralised consent decisions.

Identity concerns whether a participant can be reliably identified. Authority concerns whether that participant possesses the relevant role or permission to participate in a particular decision. Multi-party authorisation concerns whether the required set of independently verified participants has satisfied a defined collective approval condition. Policy compliance concerns whether the requested access is consistent with the authorised purpose and data scope. Time and lifecycle concern whether the consent is still within its validity window and has not expired or been revoked. Together, these conditions decide whether an authorisation decision has enough basis to be trusted, not only whether access was requested. The proposed framework consequently conceptualises patient consent as more than a static permission or a historical blockchain record. Consent is instead treated as a structured and trust-aware authorisation object, C = (I, A, P, T, L, E), that connects the relevant participants, authority requirements, policy constraints, temporal and lifecycle conditions, and evidence associated with an authorisation decision. In C, I is identity and A is authorisation, which holds the guardian set G and the threshold N. P is policy, which covers purpose and data scope. T is time, L is the lifecycle state of the consent, and E is evidence.

The current research concentrates on the foundational dimensions required to construct this trust-oriented authorisation model. The first focus is the development of a trust-centric consent representation capable of capturing the conditions associated with an authorisation decision. Building on this representation, the research investigates how decentralised identifiers and verifiable credentials can establish trustworthy participants while maintaining a clear conceptual separation between identity authentication and authorisation authority. The framework then extends individual trust to collective trust through a multi-

party authorisation mechanism, ensuring that sensitive healthcare data access can require the coordinated approval of multiple independently verified participants. Finally, policy-aware access control is incorporated to ensure that a valid identity or sufficient set of approvals cannot be used to obtain information outside the purpose or data scope authorised by the patient. These four dimensions, RO1 to RO4, collectively define the foundational scope of Multi-Party Patient Consent. RO1 to RO4 are completed and validated at the current stage; their evaluation will be carried out when the full system is done. RO5 adds temporal validity and lifecycle trust, because trust cannot be regarded as permanently established at the moment a consent is created. A consent that was valid when initially approved may subsequently become invalid due to expiration, revocation, or a change in its authorised lifecycle state. RO6 concerns formal security assurance and empirical validation. RO5 and RO6 are not done. RO5 is in progress, and part of it has already been delivered. For RO6, the HALAH (History Access Link for Authorised Healthcare) prototype has so far been used only for the initial scenario-based validation of RO1 to RO4; the formal assurance and the evaluation of the complete framework belong to the next stage. For RO5, this prototype provides a lifecycle-aware consent mechanism capable of rejecting access after expiration or revocation. The remaining formal security assurance and comprehensive empirical evaluation will be conducted in the next stage.

HALAH runs on the Ethereum Sepolia testnet, and the guardian approval rule is currently implemented as N-of-N over the guardian set G. Synthetic healthcare records derived from the Synthea dataset are used to construct representative consent workflows. Security properties are demonstrated through adversarial and negative testing, as well as empirical evaluation using the HALAH prototype and representative healthcare data-sharing scenarios, rather than formal proof. The current stage covers the work delivered so far, while temporal and lifecycle trust, formal security assurance, and comprehensive empirical validation will be developed further in the next stage.

Section 2 presents the systematic literature review, Section 3 the research gaps and questions, Section 4 the research objectives and the research methodology, and Section 5 the MVC-based research architecture. Sections 6 to 11 present the solution and status for RQ1 to RQ6, Section 12 the publications, and Section 13 the research plan.

## 1.4 Research Contributions

The scientific contributions of this research are threefold. First, this research proposes a trust-centric consent model that integrates identity, authority, multi-party approval, and policy constraints into a unified healthcare authorisation framework. Second, this research proposes a multi-party authorisation mechanism that requires approval from multiple verified participants before granting healthcare data access, where collective consent is required. Third, this research proposes a trust-aware authorisation approach that evaluates identity, authority, collective approval, and policy compliance when determining healthcare data-access permissions.

The social contributions of this research are also threefold. First, this research aims to help patients and their guardians manage consent for sharing sensitive healthcare information, supporting greater control over healthcare data access. Second, this research aims to support patient privacy by restricting healthcare data access according to authorised purposes and data scopes. Third, this research aims to support transparency and accountability in healthcare data sharing by providing verifiable records of consent activities and access decisions.

# 2. Systematic Literature Review

## 2.1 Introduction

The review does not only list technologies that can be applied to healthcare data sharing. It examines how existing approaches address different conditions required for a trustworthy authorisation decision and where conceptual or architectural gaps remain. Healthcare research has emphasised the importance of patient autonomy, privacy, informed consent, and controlled data sharing (Kaplow et al. 2024; Kharlamov, Hohmann & Parry 2023; McClelland & Harper 2023; Narkhede, Wankhede & Kamble 2025; Webber et al. 2019). Multi-party trust research has investigated immutable data governance, distributed auditability, and decentralised consent management (Andrew et al. 2023; Arbabi et al. 2023; Ghosh et al. 2023; Nguyen et al. 2025; Turan, Hashimzai & Qiam 2025). Research on decentralised identity and verifiable credentials has developed mechanisms for self-controlled identity representation, credential verification, selective disclosure, and privacy-preserving authentication (Deng et al. 2024; Flamini et al. 2024; Mazzocca et al. 2025; Nassar Kyriakidou, Papathanasiou & Polyzos 2023; Parameswarath, Gope & Sikdar 2022; Yin et al. 2025). Access-control research has further investigated role-based, attribute-based, risk-aware, and usage-control approaches for protecting sensitive healthcare information (Jiang et al. 2023; Nazir et al. 2026; Tawfik et al. 2025; Yin et al. 2024). However, the literature also indicates that these mechanisms are commonly developed and evaluated as separate technological components. Having the security mechanisms is one thing. Combining them into one trustworthy authorisation decision is another.

The structure of this section is as follows. Section 2.2 presents the six key requirements that a trustworthy multi-party consent authorisation should satisfy and that serve as the basis of the comparison. In Section 2.3, the process adopted for shortlisting the papers chosen for this SLR is discussed, including the criteria for searching the literature, the inclusion and exclusion criteria and the quality evaluation. Section 2.4 presents a summary of all the papers that were shortlisted, 25 in all, in six streams, and states the research gaps from the requirement perspective. In Section 2.5, the trust-oriented multi-party consent authorisation framework proposed in this thesis is positioned against the requirements. Finally, Section 2.6 concludes the SLR.

## 2.2 Key Requirements for Trustworthy Multi-Party Consent Authorisation

Trustworthy access should be understood as an outcome of the coordinated satisfaction of multiple independently verifiable conditions. The six requirements below collectively establish a progression from consent modelling and participant trust to collective authorisation, policy enforcement, temporal and lifecycle control, and finally formal security assurance and empirical validation. Each matches one sub-research question (Section 3), and each sub-research question addresses a distinct dimension of the proposed trust-oriented healthcare authorisation framework.

### 2.2.1 Req 1: Representation of consent as an evaluable authorisation object

Rather than representing consent as a simple association between a patient, a requester, and a permission, consent should be represented as a structured and evaluable authorisation object. The object should incorporate identity information, authority requirements, policy constraints on purpose and data scope, temporal validity, lifecycle state, and authorisation evidence so that a consent decision can be evaluated when a subsequent data-access request is made.

### 2.2.2 Req 2: Decentralised verification of identity and authority

Decentralised Identifiers (DIDs) and Verifiable Credentials (VCs) provide an alternative to conventional identity architectures based exclusively on centralised identity providers. Participants should establish persistent and cryptographically verifiable identifiers without dependence on a single identity provider. Identity verification establishes who is participating, while authority verification determines whether that entity satisfies the requirements associated with a particular consent. This separation prevents successful authentication from being interpreted as automatic authorisation.

### 2.2.3 Req 3: Multi-party authorisation through a verifiable threshold

Multiple independently verified participants can jointly establish a trustworthy consent decision without allowing a single participant to unilaterally authorise sensitive healthcare data access. A

predefined threshold of independent approvals from designated parties should be modelled as an explicit and independently verifiable security condition within the consent object.

#### 2.2.4 Req 4: Policy- and context-aware enforcement at the time of access

A requester may possess a valid identity, valid credentials, and even the required multi-party approval while still requesting information outside the scope authorised by the patient. The access decision must also be evaluated against the purpose and data-scope constraints explicitly associated with the consent. This applies to every request, because many unauthorised disclosures are caused by legitimate requesters who exceed their scope (Jiang et al. 2023).

#### 2.2.5 Req 5: Temporal validity and lifecycle control of consent

A consent that has expired, has been revoked, or has entered an invalid state must not be treated as an active authorisation even when its original identity, authority, and approval conditions were valid. The requirement is to ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, immediate and verifiable revocation, and unauthorised state transitions are correctly enforced at every request.

#### 2.2.6 Req 6: Verifiable auditability and security assurance

A system may execute valid authorisation scenarios without demonstrating that invalid identities, insufficient approvals, or policy violations cannot produce an unintended access decision. Every decision should preserve verifiable evidence to explain the reason for that decision. Formal analysis or systematic adversarial testing should provide a complementary layer through which the expected security properties of the authorisation model can be explicitly defined and examined.

### 2.3 Process Adopted for Shortlisting the Papers for SLR

This section details the process adopted to identify the relevant papers to be reviewed in the SLR. A four-step process was adopted:

Step 1: Searching the literature. This step involves defining the search terms, identifying the data sources and the process of data collection.

Step 2: Inclusion and exclusion criteria. Criteria are defined to guide the selection of the most relevant studies.

Step 3: Quality evaluation. Each of the full-text studies is reviewed against six quality evaluation questions, one for each key requirement.

Step 4: Data analysis. After reviewing the selected studies, data are extracted, recorded and categorised into streams.

The review process was structured according to the Preferred Reporting Items for Systematic Reviews and Meta-Analyses (PRISMA) 2020 statement (Page et al. 2021). PRISMA was adopted to improve the transparency, reproducibility, and traceability of the literature identification and selection process. A written protocol (Protocol v1.1) fixed the review questions, databases, master query, eligibility criteria, codebook, and quality items before screening. All screening, coding, and quality assessment were carried out by the author. The review is guided by the six key requirements of Section 2.2, and the six quality evaluation questions of Step 3 are derived from them, one for each requirement.

#### 2.3.1 Step 1: Criteria for Searching the Literature

This step involved deciding the databases to search, the search string, the information required from each record and the publication period of the records.

The literature search was conducted using the following academic databases including 1) IEEE Xplore, 2) ACM Digital Library, 3) ScienceDirect, 4) SpringerLink, 5) ProQuest Science and Technology, 6) Scopus, and 7) Web of Science. These databases were selected because they provide complementary coverage of computer science, cybersecurity, healthcare informatics, distributed systems, and information management research. ScienceDirect and SpringerLink were used to identify research on healthcare information systems, privacy, interoperability, and data governance. Scopus and Web of Science were used to improve the coverage of multidisciplinary studies. One master query of three concept blocks joined by AND covered healthcare data, consent and authorisation, and trust and multi-party concepts. The search string was ("Healthcare" OR "Health Data" OR "Medical Records") AND ("Consent" OR "Authorisation" OR "Authorization") AND ("Trust" OR "Multi-party" OR "Multi-party Approval"). The search strings were constructed using Boolean operators and were adapted only to the syntax requirements of each database.

Table 2.1 shows the seven databases and the number of records retrieved from each.

**Table 2.1:** Databases searched and records retrieved

| S/N | Database | Records |
|---|---|---|
| 1 | SpringerLink | 46 |
| 2 | Scopus | 38 |
| 3 | IEEE Xplore | 27 |
| 4 | ProQuest Science and Technology | 24 |
| 5 | Web of Science | 19 |
| 6 | ScienceDirect | 14 |
| 7 | ACM Digital Library | 11 |
| | Total | 179 |

2.3.2 Step 2: Inclusion and Exclusion Criteria

Not all the records identified in the previous step are considered in the SLR. They were further shortlisted according to the following inclusion and exclusion criteria.

The search results from all databases were exported into a reference management system. Duplicate records were identified using bibliographic metadata, including title, author, DOI, and publication year. Where duplicate records were identified, the most complete bibliographic record was retained for subsequent screening. Each study is cited by the year of the journal issue or proceedings volume in which it appeared, not the year it was first published online.

The eligibility criteria were defined before the screening process to ensure consistency in the selection of studies. Inclusion required healthcare data (IC1), consent, authorisation, access control, trust, or governance relevant to data access (IC2), and a mechanism, model, system, or evaluation relevant to a review question (IC3). Studies also had to be peer-reviewed English papers with full text (IC4 to IC7). The search was restricted to studies published between 2020 and 2026. The exclusion criteria removed, among others, studies outside healthcare or the authorisation scope, studies of authentication alone or with only a superficial mention of consent, non-peer-reviewed work, duplicate publications, and secondary reviews, although no study was excluded for failing to support the proposed research gap. Where a study addressed multiple topics, its eligibility was determined according to the relevance of its contribution to the review questions rather than by the presence of a single keyword.

Inclusion criteria:
1. Healthcare data sharing (IC1).
2. Consent or authorisation relevant to data access (IC2).
3. A model, mechanism, system or evaluation that addresses a review question (IC3).
4. Peer-reviewed English paper with full text (IC4 to IC7).
5. Publication between 2020 and 2026.

Exclusion criteria:
1. Outside healthcare or the authorisation scope.
2. Authentication alone or a superficial mention of consent.
3. Non-peer-reviewed work and duplicate publications.

The stages of evaluating and selecting the relevant papers for the SLR are summarised in Table 2.2.

**Table 2.2:** Summary of the stages of evaluating and selecting the relevant papers for the SLR

| Evaluation stage | Method | Assessment criteria | Records |
|---|---|---|---|
| 1st | Identify the related studies from the seven databases | Match the search string | 179 identified |
| 2nd | Remove duplicate records | Same title, author, DOI and publication year | 21 removed, 158 remain |

| Evaluation stage | Method | Assessment criteria | Records |
|---|---|---|---|
| 3rd | Screen the titles | Within healthcare consent or authorisation; otherwise exclude | 76 excluded, 82 remain |
| 4th | Screen the abstracts | Relevant to a review question; otherwise exclude | 43 excluded, 39 remain |
| 5th | Assess the full texts | Eligibility criteria and the quality evaluation of Step 3 | 14 excluded, 25 included |

Figure 2.1 presents the PRISMA flow diagram for this review, which summarises the identification, screening, eligibility, and inclusion stages of the SLR. The seven database searches returned 179 records: 46 from SpringerLink, 38 from Scopus, 27 from IEEE Xplore, 24 from ProQuest, 19 from Web of Science, 14 from ScienceDirect, and 11 from the ACM Digital Library. After 21 duplicates were removed, 158 records were screened by title, and 76 were excluded. The abstracts of the remaining 82 records were screened, and 43 were excluded. The full texts of 39 studies were then assessed for eligibility, 14 were excluded, and 25 studies were included in the analysis.

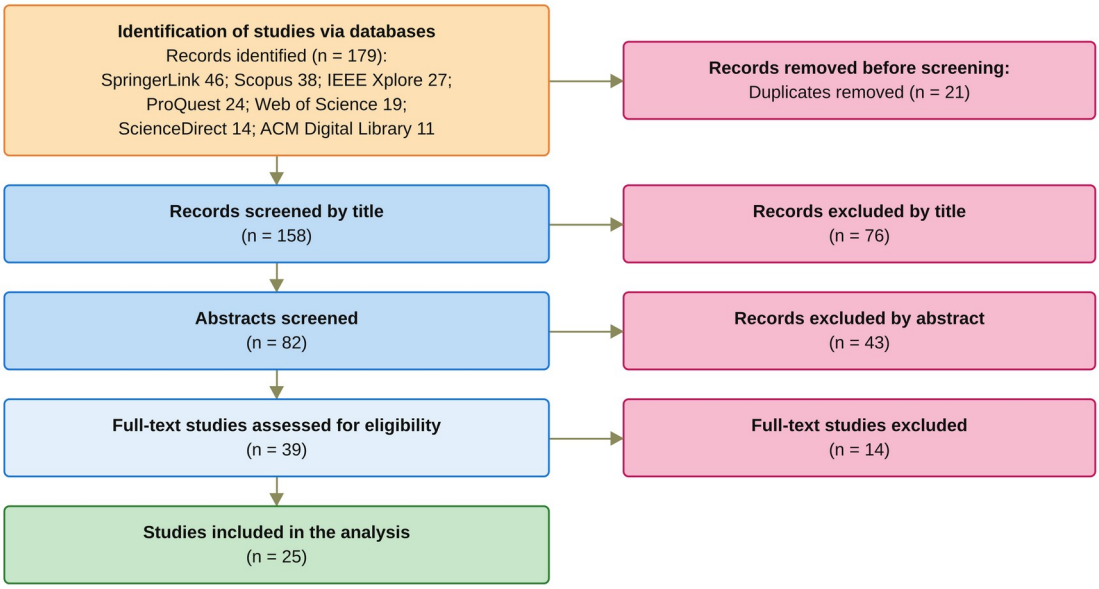



**Figure 2.1:** PRISMA 2020 flow diagram of the study identification, screening, eligibility and inclusion stages.

### 2.3.3 Step 3: Quality Evaluation

The 39 full-text studies were retrieved and critically evaluated based on the six quality evaluation questions, one for each key requirement of Section 2.2, as follows:

QA1: Does the study define a consent model covering identity, authority, policy, and evidence?

QA2: Does the study verify participant identities and their authorisation authority?

QA3: Does the study support consent decisions requiring approval from multiple authorised participants?

QA4: Does the study enforce purpose, data scope, and approval rules before allowing access?

QA5: Does the study manage consent validity, expiry, and revocation?

QA6: Does the study validate security and access decisions through formal analysis or implementation testing?

Each question was answered Yes or No, and any study which has at least three Yes answers to the six questions, and meets the eligibility criteria of Step 2, is included in this SLR. These questions decide whether a study enters the review; whether it satisfies the requirements of Section 2.2 is decided separately in Section 2.4. Of the 39 full-text studies, 25 satisfied the criteria, as shown in Table 2.3.

Each included study was then coded Yes or No against each of the six requirements, Req 1 to Req 6, with a page reference for every Yes. A study is core if its gap-impact verdict is contradicts, weakens or narrows, or if it provides a multi-party approval mechanism. Of the 25 included studies, S1 to S25, 23 are core studies and 2 are supporting studies (Albalwy, Brass & Davies 2021; Li et al. 2026a).

### 2.3.4 Step 4: Shortlisted Papers for SLR and Categorising Them into Broad Areas

Each of the shortlisted papers was analysed according to its scope, topic and contribution to the review questions. Based on the analysis, each study was placed in one of six streams, one per requirement: consent representation (Req 1), identity and authority (Req 2), multi-party authorisation (Req 3), policy and context (Req 4), temporal and lifecycle (Req 5) and security assurance (Req 6). Table 2.3 lists the 25 primary studies with their authors, year and title. The papers in each stream are summarised in the next section, and their issues and limitations with respect to the key requirements defined in Section 2.2 are discussed.

**Table 2.3:** Listing of the 25 primary studies identified after the selection process

| Study | Authors and year | Article title |
|---|---|---|
| S1 | Abbasi et al. (2026) | Nexa: Enabling Secure, Scalable, and Decentralized Management of Electronic Health Records Using Threshold Cryptography and Public Blockchains |
| S2 | Albalwy et al. (2021) | A Blockchain-based dynamic consent architecture to support clinical genomic data sharing (ConsentChain): Proof-of-concept study |
| S3 | Al Amin et al. (2023) | Informed Consent as Patient Driven Policy for Clinical Diagnosis and Treatment: A Smart Contract Based Approach |
| S4 | Ekholm et al. (2025) | Implementing electronic informed consent in rare disease genomics |
| S5 | Eneh et al. (2026) | Demo: EdgeConsent: On-Chain Attribute-Based Access Control for Data Consent Management |
| S6 | Hagström et al. (2024) | Minors' and guardian access to and use of a national patient portal: A retrospective comparative case study of Sweden and Finland |
| S7 | Jaiman and Urovi (2020) | A Consent Model for Blockchain-Based Health Data Sharing Platforms |
| S8 | Zhao and Su (2024) | A threshold traceable delegation authorization scheme for data sharing in healthcare |
| S9 | Li et al. (2026a) | Privacy-Preserving Fine-Grained EMR Access Control for IoMT: A Hybrid RBAC-Smart Contract Scheme With Attribute-Based Authorization |
| S10 | Madine et al. (2020) | Fully Decentralized Multi-Party Consent Management for Secure Sharing of Patient Health Records |
| S11 | Maruthi and Singh (2025) | Enhancing Security and Privacy of IoMT Data for Unconscious Patient With Blockchain |
| S12 | Mei et al. (2026) | Efficient Dual-Revocation CP-ABE for Secure and Fine-Grained Data Sharing in IoMT |
| S13 | Panagoulias et al. (2026) | Blockchain-Enabled Trust and Compliance for Clinical AI: Decentralized Governance Without Decentralized Data Storage |
| S14 | Phuyal et al. (2026b) | Enabling Cross-Institution Health Data Sharing in Norway: EUDI Wallets, On-Chain Consent, and openEHR ↔ FHIR Translation |
| S15 | Phuyal et al. (2026a) | A Blockchain-Based Architecture for Dynamic and Auditable Patient Consent in Secondary Use of Health Data |
| S16 | Punia et al. (2025) | An access control system for cloud-based healthcare systems driven by blockchain |
| S17 | Román-Martínez et al. (2023) | Blockchain-Based Service-Oriented Architecture for Consent Management, Access Control, and Auditing |
| S18 | Hema et al. (2026) | Patient Centric Cryptographic Protection of Cloud Electronic Health Records |

| Study | Authors and year | Article title |
|---|---|---|
| S19 | SooHoo et al. (2026) | Development of the authentication and authorization processes for the iAgree portal, a platform for patient-controlled data sharing across health systems |
| S20 | Tan et al. (2024) | Secure and privacy-preserving sharing of personal health records with multi-party pre-authorization verification |
| S21 | Tith et al. (2020) | Patient consent management by a purpose-based consent model for electronic health record based on blockchain technology |
| S22 | Tremper et al. (2026) | Mainzelliste: Ten years of pseudonymization, record linkage, and informed consent management |
| S23 | Tseng et al. (2025) | EMR-Chain: Decentralized Electronic Medical Record Exchange System |
| S24 | Wu et al. (2022) | Apply Trust Computing and Privacy Preserving Smart Contracts to Manage, Share, and Analyze Multi-site Clinical Trial Data |
| S25 | Wu and Zhang (2025) | HealthDID: An efficient and authorizable multi-party privacy-preserving EMR sharing system based on DID |

## 2.4 Summary of Papers Shortlisted in the SLR

The extracted data were organised into thematic categories corresponding to the research questions. Each included study was assigned to one stream, normally the one on which it is coded most strongly. S6 (Hagström et al. 2024) is placed in the multi-party stream for its guardian access gate, although it is not graded Yes on Req 3.

### 2.4.1 Consent representation and blockchain-based consent governance (Req 1)

Two of the three studies of this stream are deployed platforms that do not fully satisfy Req 1. SooHoo et al. (2026) describe the iAgree portal across three United States health systems with a permissioned Ethereum audit contract, but consent enforcement is outside its scope. Tremper et al. (2026) report ten years of the Mainzelliste service with FHIR consent directives, but specify no check semantics and no demonstrated enforcement of withdrawal. The two platforms are single-party systems. Al Amin et al. (2023) model informed consent as a patient-driven policy object with hash integrity, but specify no purpose condition and report no measured results. The supporting references represent consent as a permission indicating whether a particular party is allowed to perform a specified operation (Akter & Sanam 2025; Prashanth et al. 2024), as conditions fixed at encryption time (Zhang, Kan & Huang 2022), or as a key issued by the patient for each request (Teeda & Subba Rao 2026). The existence of a consent record does not necessarily explain whether the conditions required for a subsequent access request are still satisfied. Table 2.4 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

**Table 2.4:** Descriptions, issues and limitations of the studies on consent representation

| Study | Description of the study | Issues/ Limitations | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---|---|---|---|---|---|---|---|---|
| S3 Al Amin et al. (2023) | Informed consent is modelled as a patient-driven policy object with hash integrity, which an authorisation module conjoins with other policies inside a smart contract. | Purpose is not a condition, the time and expiry conditions are specified but not enforced, the only multi-party element is a 2-of-2 co-signature at registration, and the Goerli evaluation reports no measured results. | Yes | No | No | No | No | No |
| S19 SooHoo et al. (2026) | The authentication and authorisation processes of the iAgree portal across three United States health systems, using OAuth2, SMART on FHIR, and one-time passwords, with a permissioned Ethereum audit contract. | Consent enforcement is outside its scope, a single patient decides, identity and authority are not separated, revocation is claimed but not tested, and there are no formal methods. | No | No | No | No | No | No |

| Study | Description of the study | Issues/ Limitations | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---|---|---|---|---|---|---|---|---|
| S22 Tremper et al. (2026) | Ten years of the Mainzelliste production service for pseudonymisation, record linkage, and informed consent management, with purpose-scoped FHIR consent directives and automated consent checks. | The consent checks have no specified semantics and no demonstrated enforcement of withdrawal, its multi-party computation parties are linkage units rather than authorisers, and no consent decision is verified. | No | No | No | No | No | No |

2.4.2 Decentralised identity and authority trust (Req 2)

Req 2, which needs both identity and authority, is graded Yes in only 7 of the 25 studies in Table 2.10. Phuyal et al. (2026b) present the most integrated system, with EUDI-compatible wallets, W3C decentralised identifiers, verifiable credentials, an on-chain consent object on Hyperledger Besu, and Groth16 access proofs. Its licensing-body credential asserts role and scope of practice separately from authentication, which is among the strongest Req 2 evidence in the corpus. However, a single patient grants consent, the stored expiry is not checked, there is no threat model, and the companion architecture (Phuyal et al. 2026a) is design-only. Tseng et al. (2025) verify authority-issued roles separately from X.509 identities, although without W3C identifiers and with purpose logged but never evaluated. Neither identity verification nor credential possession automatically establishes that the participant should be granted access to a particular patient's information.

Table 2.5 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

**Table 2.5:** Descriptions, issues and limitations of the studies on identity and authority

| Study | Description of the study | Issues/ Limitations | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---|---|---|---|---|---|---|---|---|
| S14 Phuyal et al. (2026b) | Cross-institution health data sharing with EUDI-compatible wallets, W3C decentralised identifiers, verifiable credentials, an on-chain consent object on Hyperledger Besu, and Groth16 access proofs, where a licensing-body credential asserts role separately from authentication. | A single patient grants consent, the stored expiry is not checked, purpose is handled only at the interface, and there is no threat model. | Yes | Yes | No | No | No | Yes |
| S15 Phuyal et al. (2026a) | A design-science architecture for dynamic and auditable patient consent in secondary use, using FHIR Consent with purpose, scope, actors, and validity period, anchored on chain, with conceptual VC validation at a gateway. | The architecture is design-only and is neither implemented nor evaluated, and delegation through VCs is not joint multi-party approval. | No | No | No | No | No | No |

| Study | Description of the study | Issues/ Limitations | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---|---|---|---|---|---|---|---|---|
| S23 Tseng et al. (2025) | EMR-Chain, a decentralised electronic medical record exchange that verifies authority-issued roles separately from X.509 identities and enforces token expiry at the validator. | It has no W3C identifiers, purpose is logged but never evaluated, scope is hospital-level only, the patient and requester signatures authenticate the request rather than add an independent authoriser, and revocation does not invalidate issued tokens. | No | Yes | No | No | No | No |

2.4.3 Multi-party authorisation and collaborative consent (Req 3)

Req 3 is graded Yes in 6 of the 25 studies and No in 19, across six mechanism classes. Madine et al. (2020) require a regulator and a guardian threshold on the incapacitated path, but a single patient key suffices on the normal path. Wu et al. (2022) apply a (t, n) investigator threshold to record admission and revocation, and Abbasi et al. (2026) use a Shamir (5, 3) threshold for key custody. Punia et al. (2025) conjoin an M-of-N multi-signature with an attribute and role policy, but a single emergency officer can bypass the threshold. Tan et al. (2024) use patient-appointed verifiers as a contingency, (Ekholm et al. 2025) reports guardian co-consent at registration time, and (Hagström et al. 2024) gates guardian access by the minor's consent and a clinician's capacity assessment. No reviewed study evaluates a threshold predicate over a patient-designated guardian set on every request, and none does so together with the policy, temporal, and lifecycle conditions. Multi-party verification of identity should not be considered equivalent to multi-party authorisation of data access.

Table 2.6 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

**Table 2.6:** Descriptions, issues and limitations of the studies on multi-party authorisation

| Study | Description of the study | Issues/ Limitations | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---|---|---|---|---|---|---|---|---|
| S1 Abbasi et al. (2026) | Decentralised EHR management in which a Shamir (5, 3) threshold reconstructs a symmetric key, and automated oracles release their shares according to the requester's on-chain role. | The threshold is over key custodians rather than authorisers, the patient share is not required, purpose is not evaluated, and no authorisation decision is verified despite extensive performance measurement. | No | No | No | No | No | No |
| S4 Ekholm et al. (2025) | A deployed electronic informed consent platform for rare disease genomics, in which a minor's consent is valid only when all legal guardians sign, and guardianship is verified against the Swedish Population Register. | The guardian co-consent applies at registration rather than at each access request, the platform is centralised and described with little technical detail, and there is no temporal, purpose, or formal assurance condition. | No | Yes | Yes | No | No | No |

| Study | Description of the study | Issues/ Limitations | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---|---|---|---|---|---|---|---|---|
| S6 Hagström et al. (2024) | A comparative case study of national patient portals, in which a clinician's capacity assessment and the minor's consent jointly gate guardian access, with register-verified guardianship and enforced age windows. | The mechanism is centralised and applied at documentation time, and the guardian is the party whose proxy access is gated rather than a co-authoriser of the patient's access decision. | No | Yes | No | No | Yes | Yes |
| S10 Madine et al. (2020) | Fully decentralised multi-party consent management in which, on the incapacitated path, approvals from a regulator and a guardian threshold are required on one access request, and stale attestations stop counting. | On the normal path a single patient key authorises, so multi-party approval is a contingency. Purpose and data-category policy are absent, revocation after delivery is not possible, and there is no formal assurance. | Yes | Yes | Yes | No | Yes | No |

| Study | Description of the study | Issues/ Limitations | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---|---|---|---|---|---|---|---|---|
| S16 Punia et al. (2025) | MedXBlock, a blockchain-driven access control system for cloud healthcare that combines an institutional M-of-N multi-signature with a conjunctive role and attribute policy evaluated with deny-by-default. | The signers are doctors and administrators rather than patient-side parties, the threshold sits outside the decision predicate and a single emergency officer can bypass it, there is no purpose term, and no authorisation decision is verified. | No | No | Yes | Yes | Yes | No |
| S20 Tan et al. (2024) | Sharing of personal health records with multi-party pre-authorisation verification, in which a (t, n) threshold of patient-appointed verifiers each validate the grant, its expiry, and the revocation list before releasing a key share. | The joint approval is a pre-delegated contingency for an unconscious patient rather than a standing condition, purpose and data scope are not evaluated, and the gate is not evaluated empirically as an authorisation decision. | Yes | Yes | Yes | No | No | No |

| Study | Description of the study | Issues/ Limitations | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---|---|---|---|---|---|---|---|---|
| S24 Wu et al. (2022) | Trust computing and privacy-preserving smart contracts for multi-site clinical trial data, in which a (t, n) investigator threshold signature governs trial admission to the ledger and consent revocation. | The consent grant is unilateral, the voters are institution-side investigators, the vote reduces to a hash-integrity check, there is no policy engine, and there is no formal assurance. | No | No | No | No | No | No |

2.4.4 Policy- and context-aware access control (Req 4)

Tith et al. (2020) match a purpose tree in chaincode, and Jaiman and Urovi (2020) match ontology terms against the patient's consent. Albalwy et al. (2021) evaluate a hashed policy tree of data type, role, and purpose, and Román-Martínez et al. (2023) evaluate the FHIR purpose-of-use through XACML. Req 4 is graded Yes in 10 studies and No in 15 in Table 2.10. However, purpose-of-use enters the decision in only six studies (Eneh et al. 2026; Panagoulias et al. 2026), and every one is graded No on Req 3. Consequently, purpose and data-scope constraints are not carried by the consent object C and evaluated together with the identity, authority, and multi-party conditions.

Table 2.7 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

**Table 2.7:** Descriptions, issues and limitations of the studies on policy and context

| Study | Description of the study | Issues/ Limitations | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---|---|---|---|---|---|---|---|---|
| S2 Albalwy et al. (2021) | A blockchain-based dynamic consent proof of concept for clinical genomic data, in which a hashed policy tree of data type, role, and purpose is evaluated by the smart contract. | A single patient sets and cancels consent, the requester's role and credentials are not verified, time is applied only at the delivery layer, and there is no formal assurance. | Yes | No | No | Yes | No | Yes |

| Study | Description of the study | Issues/ Limitations | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---|---|---|---|---|---|---|---|---|
| S7 Jaiman and Urovi (2020) | A consent model in which ontology terms requested by a data requester are matched against the patient's consent inside the smart contract, with denial tested across requester profiles. | Security assurance is explicitly outside its scope, and there is no multi-party approval. | Yes | No | No | Yes | No | Yes |
| S17 Román-Martínez et al. (2023) | A blockchain-based service-oriented architecture on Hyperledger Fabric for consent management, access control, and auditing, in which FHIR purpose-of-use limits are evaluated per resource through XACML. | There is no withdrawal or expiry path, and the experiments validate only the blockchain component. | Yes | No | No | Yes | No | No |
| S21 Tith et al. (2020) | A purpose-based consent model on Hyperledger Fabric, in which a consent tuple of role, doctor identifiers, action, and intended purpose is matched against a purpose tree in chaincode at request time. | Consent is given by a single patient, the tuple has no temporal element, the effect of withdrawal is not tested, identity uses Fabric certificates without DID or VC, and there is no formal verification. | Yes | No | No | Yes | No | No |

### 2.4.5 Temporal validity and consent lifecycle (Req 5)

A consent that is valid at one point in time cannot necessarily be assumed to remain valid indefinitely. Eneh et al. (2026) present EdgeConsent, which enforces temporal validity inside the decision predicate, although its lifecycle is only an active flag. Temporal validity must also be evaluated together with the lifecycle state of the consent. Hema et al. (2026) bind the expiry into key derivation, and Panagoulias et al. (2026) enforce revocation at decision time across 43,500 simulated attempts in a single-node ledger. Req 5 is graded Yes in 8 studies, a post-revocation denial is demonstrated only by Phuyal et al. (2026b), which enforces revocation but not expiry, so it does not fully satisfy Req 5, and the four stream-5 systems that enforce time inside the decision are all single-party, with Li et al. (2026a) doing so through the credential rather than the consent.

Table 2.8 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

**Table 2.8:** Descriptions, issues and limitations of the studies on temporal validity and lifecycle

| **Study** | **Description of the study** | **Issues/ Limitations** | **Req 1** | **Req 2** | **Req 3** | **Req 4** | **Req 5** | **Req 6** |
|---|---|---|---|---|---|---|---|---|
| S5 Eneh et al. (2026) | EdgeConsent, a demonstration of on-chain attribute-based access control in which consent rules with purpose, data category, and notBefore and notAfter bounds are evaluated at decision time. | A two-page demonstration with weak identity and authority trust and no DID or VC, no multi-party approval, a lifecycle that is only an active flag, and preliminary local evaluation without formal assurance. | Yes | No | No | Yes | Yes | No |
| S9 Li et al. (2026a) | A hybrid RBAC and smart contract scheme with attribute-based authentication for fine-grained EMR access in IoMT, which enforces credential expiry at every sharing interaction. | Time is enforced in the decision through the credential rather than the consent, which is why Req 5 is graded Yes, but the consent itself carries no enforced validity window, and there is no multi-party approval. | No | No | No | Yes | Yes | No |

| Study | Description of the study | Issues/ Limitations | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---|---|---|---|---|---|---|---|---|
| S13 Panagoulias et al. (2026) | Blockchain-enabled trust and compliance for clinical AI, in which an Allow predicate over time, revocation, role, and purpose is evaluated before execution and denials are recorded, verified across simulated attempts with zero consent drift. | A simulated single-node prototype with set-membership policy and aggregate deny attribution, without multi-party approval or identity depth, and the authors declare no formal assurance. | Yes | No | No | Yes | Yes | Yes |
| S18 Hema et al. (2026) | Patient-centric cryptographic protection of cloud EHRs, in which a signed consent token, role, and expiry are inputs to key derivation, so that access becomes a cryptographic precondition and role-scoped keys separate authority from identity. | Consent is issued from a single patient key, identity relies on a cloud authentication service without DID or VC, and assurance is limited to an adversary model. | Yes | No | No | Yes | Yes | No |

2.4.6 Formal security assurance and empirical validation (Req 6)

Experimental success alone cannot establish that unauthorised access is impossible under the stated model, while formal reasoning establishes security properties only under explicitly defined assumptions. Consequently, the two forms of evidence are complementary rather than interchangeable. Wu and Zhang (2025) present HealthDID, with three game-based definitions and three theorems proved by reduction, although the proofs cover only the identity and authority fragment. Zhao and Su (2024) and Maruthi and Singh (2025) prove threshold gates in isolation, and Mei et al. (2026) prove a static encryption predicate. Req 6 is graded Yes in 9 of the 25 studies: formal assurance is provided by only 4 of them, and the other 5 rest on empirical validation. An inverse relation between predicate breadth and assurance strength was

observed. Few studies execute adversarial scenarios that examine whether security controls can resist deliberate attempts to circumvent the authorisation process.

Table 2.9 summarises the description, the issues and limitations, and the requirement grades of the studies in this stream.

**Table 2.9:** Descriptions, issues and limitations of the studies on security assurance

| **Study** | **Description of the study** | **Issues/ Limitations** | **Req 1** | **Req 2** | **Req 3** | **Req 4** | **Req 5** | **Req 6** |
|---|---|---|---|---|---|---|---|---|
| S8 Zhao and Su (2024) | A threshold traceable delegation scheme in which the patient delegates a threshold of l already-authorised users, who must jointly authorise an out-of-policy requester, with unforgeability argued under DBDH. | The authorisers are consumer-side delegates rather than patient-side stakeholders, the patient's own decision is unilateral, a trusted authority escrows keys, and there is no temporal, lifecycle, or purpose condition. | No | No | Yes | No | No | Yes |
| S11 Maruthi and Singh (2025) | Protection of IoMT data for unconscious patients, in which t-of-n patient-designated relatives release access through threshold proxy re-encryption, and the hospital and relatives are authenticated on chain. | Policy and temporal conditions are not evaluated, and the proofs cover the threshold gate in isolation rather than the complete decision. | No | No | Yes | No | No | Yes |

| Study | Description of the study | Issues/ Limitations | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---|---|---|---|---|---|---|---|---|
| S12 Mei et al. (2026) | An efficient dual-revocation CP-ABE scheme for IoMT that terminates access immediately through ciphertext update, motivated by consent withdrawal, with a security reduction under q-BDHE. | The proof covers a static encryption predicate, revocation operates at scheme level rather than on a consent object, and there is no multi-party approval. | No | No | No | Yes | Yes | Yes |
| S25 Wu and Zhang (2025) | HealthDID, a DID-based privacy-preserving EMR sharing system with three game-based definitions and three theorems proved by reduction, in which a zero-knowledge proof binds the authorisation to a specific requester. | The proofs cover only the identity and authority fragment, multi-party refers to the privacy requirements of several stakeholders rather than joint approval, and there are no policy, temporal, or lifecycle conditions. | Yes | Yes | No | No | No | Yes |

### 2.4.7 Research Gaps in the Existing Studies from the Requirement Perspective

The systematic literature review indicates that substantial research has been conducted on individual mechanisms for securing healthcare data sharing, including blockchain-based consent management, decentralised identity, verifiable credentials, cryptographic access control, policy-based authorisation, and multi-party approval. These approaches have demonstrated the value of decentralisation, tamper-resistant records, verifiable identity, fine-grained access control, and distributed decision-making in addressing different aspects of healthcare data security. However, the literature also reveals a significant conceptual and architectural fragmentation among these mechanisms. They are commonly investigated as independent technical solutions rather than as coordinated components of a unified trust-oriented authorisation model.

The central gap is therefore not the absence of technologies for recording consent, verifying identity, or restricting data access. Rather, it is the absence of a sufficiently integrated model explaining how these mechanisms collectively establish a trustworthy authorisation decision. In particular, existing consent-oriented approaches tend to treat consent primarily as a record of a patient's permission. Once the permission has been created and stored, subsequent access control may depend predominantly on the existence of the consent record and the successful authentication of the requester. Such a model establishes evidence that a consent decision occurred, but it does not necessarily establish that the

requester possesses the required authority, that all required parties have independently approved the access, or that the requested operation is consistent with the purpose and data scope originally authorised by the patient, or that the consent is still valid in time and lifecycle state at the moment of the request.

This distinction is important because recording consent and enforcing trustworthy authorisation represent fundamentally different security problems. A blockchain may provide an immutable representation of a consent event, but immutability does not establish the legitimacy of the entities involved in that event. Similarly, a valid decentralised identity can establish who a participant is, but it does not necessarily establish what that participant is authorised to do. Multi-party approval can strengthen collective decision-making, but approval alone does not guarantee that the resulting access request conforms to the patient's authorised purpose or data scope. Consequently, trust cannot be attributed to any individual mechanism in isolation.

From a Trust Computing perspective, this leads to a more fundamental research problem. Trustworthy access should be understood as an outcome of the coordinated satisfaction of multiple independently verifiable conditions. The relevant conditions include the legitimacy of the participating identities, the authority associated with those identities, the satisfaction of required collective approval conditions, and compliance between the requested operation and the policy defined by the consent, and the temporal validity and lifecycle state of the consent at the time of the request. The research therefore conceptualises trust not as a static attribute possessed by a particular entity or technology, but as an emergent property of a verifiable authorisation process.

This perspective also introduces an important distinction between authentication, authorisation, and trustworthy access. Authentication determines whether an entity can be identified and verified. Authorisation determines whether the entity is permitted to perform a particular operation. Trustworthy access requires an additional consideration: whether the authorisation decision itself has been established through sufficient, verifiable, and policy-compliant conditions. The research consequently investigates how these layers can be connected within a single framework without reducing trust to any individual credential, transaction, or access-control rule.

The identified gap can therefore be stated as follows: existing healthcare consent and access-control research provides many of the necessary technological building blocks, but there remains a need for an integrated Trust Computing framework that treats patient consent as a security-bearing and evaluable authorisation object. Such a framework should be capable of representing the relevant trust conditions, verifying the participating entities and their authority, establishing collective authorisation where required, and enforcing the policy and data-scope constraints associated with the consent, and ensuring that the authorisation remains valid only within the time interval and lifecycle state of the consent. The research addresses this gap by developing a trust-oriented authorisation model in which consent is not simply evidence that permission was granted, but the basis for evaluating whether a particular access request should be trusted. The resulting research direction places Trust Computing at the centre of the investigation, while treating blockchain, decentralised identity, verifiable credentials, and policy mechanisms as enabling technologies supporting the broader trust model.

Existing approaches solve single dimensions of trustworthy data sharing, each at a different layer of the security problem. No individual mechanism can independently establish that a healthcare data-access decision is trustworthy. The systems that enforce purpose and time are authored by a single patient and lack a formal argument. The multi-party systems carry no purpose condition, whereas the proved schemes either omit policy, temporal validity, and lifecycle or, as in (Mei et al. 2026), prove only a static encryption predicate. Table 2.10 summarises the 25 studies against the six requirements. In the Req 6 column each study takes the higher of its formal assurance grade and its empirical validation grade.

**Table 2.10:** Comparison of the included studies against the key requirements

| **Study** | **Req 1** | **Req 2** | **Req 3** | **Req 4** | **Req 5** | **Req 6** |
|---|---|---|---|---|---|---|
| S1 Abbasi et al. (2026) | No | No | No | No | No | No |
| S2 Albalwy et al. (2021) | Yes | No | No | Yes | No | Yes |
| S3 Al Amin et al. (2023) | Yes | No | No | No | No | No |
| S4 Ekholm et al. (2025) | No | Yes | Yes | No | No | No |

| Study | Req 1 | Req 2 | Req 3 | Req 4 | Req 5 | Req 6 |
|---|---|---|---|---|---|---|
| S5 Eneh et al. (2026) | Yes | No | No | Yes | Yes | No |
| S6 Hagström et al. (2024) | No | Yes | No | No | Yes | Yes |
| S7 Jaiman and Urovi (2020) | Yes | No | No | Yes | No | Yes |
| S8 Zhao and Su (2024) | No | No | Yes | No | No | Yes |
| S9 Li et al. (2026a) | No | No | No | Yes | Yes | No |
| S10 Madine et al. (2020) | Yes | Yes | Yes | No | Yes | No |
| S11 Maruthi and Singh (2025) | No | No | Yes | No | No | Yes |
| S12 Mei et al. (2026) | No | No | No | Yes | Yes | Yes |
| S13 Panagoulias et al. (2026) | Yes | No | No | Yes | Yes | Yes |
| S14 Phuyal et al. (2026b) | Yes | Yes | No | No | No | Yes |
| S15 Phuyal et al. (2026a) | No | No | No | No | No | No |
| S16 Punia et al. (2025) | No | No | Yes | Yes | Yes | No |
| S17 Román-Martínez et al. (2023) | Yes | No | No | Yes | No | No |
| S18 Hema et al. (2026) | Yes | No | No | Yes | Yes | No |
| S19 SooHoo et al. (2026) | No | No | No | No | No | No |
| S20 Tan et al. (2024) | Yes | Yes | Yes | No | No | No |
| S21 Tith et al. (2020) | Yes | No | No | Yes | No | No |
| S22 Tremper et al. (2026) | No | No | No | No | No | No |
| S23 Tseng et al. (2025) | No | Yes | No | No | No | No |
| S24 Wu et al. (2022) | No | No | No | No | No | No |
| S25 Wu and Zhang (2025) | Yes | Yes | No | No | No | Yes |

The matrix supports four observations. First, counting only full satisfaction, Req 1 is met by 12 of the 25 studies, Req 2 by 7, Req 3 by 6, Req 4 by 10, Req 5 by 8, and Req 6 by 9. Second, no study satisfies all six, the maximum of four is reached by (Madine et al. 2020) and (Panagoulias et al. 2026), and five studies fully satisfy none. Third, Req 1 with Req 4 is the most frequent pair, in seven studies, whereas Req 2 and Req 4 never co-occur in full. Req 3 co-occurs with Req 4 only in (Punia et al. 2025), whose threshold lies outside the policy predicate and whose policy carries no purpose term. Similarly, Req 3 co-occurs with Req 6 only in (Maruthi & Singh 2025; Zhao & Su 2024). Fourth, the two quadruples are complementary, since Madine et al. (2020) lack full policy and assurance, whereas Panagoulias et al. (2026) lack multi-party approval and full identity depth.

The comparison shows that the contribution of this research is the explicit relationship it establishes among existing technologies, not their replacement. The consent object C carries the identity, authority, threshold, policy, temporal, and lifecycle conditions together, so that their relationship is verifiable. Section 2.5 positions the proposed framework relative to these requirements. The conjunction is formally specified and validated through allow-and-deny test cases and attack cases, whereas its formal verification and the remaining lifecycle extensions of RQ5 are left for the next stage (Sections 10 and 11).

The literature review identifies a consistent pattern of fragmentation across existing research. Across the corpus, Req 3 is the least satisfied requirement, while within Req 6, formal assurance alone is provided by 4 studies, argued informally by 9, and absent in 12. The other five Yes grades for Req 6 in Table 2.10 rest on empirical validation.

The review corrects one framing. Multi-party authorisation of patient consent is not absent from the literature, since the full-text coding shows it in six forms. These range from contingency-path joint

approval and admission gates to delegated, witness, and custodial thresholds and guardian co-consent at registration, but no reviewed study treats it as a constitutive predicate that every access decision must satisfy together with the identity, policy, and temporal conditions. The gap is therefore not the absence of technologies for recording consent, verifying identity, or restricting data access. Rather, it is the absence of a sufficiently integrated model explaining how these mechanisms collectively establish a trustworthy authorisation decision.

The review establishes two gaps. The first is a **conjunction gap**, since no study conjoins identity, authority, threshold, policy, temporal, and lifecycle conditions in one decision predicate in which multi-party approval is a standing condition and the patient defines the approving set. The second is an **assurance gap**, since the studies that combine several conditions test their own decisions, but none proves or tests the complete conjunction that includes multi-party approval, and any proof covers only a fragment of the predicate. As shown in Figure 2.2, the proposed research addresses both gaps by developing a trusted multi-party consent governance framework in which consent is represented as an evaluable authorisation object. Each of Req 1 to Req 6 also leaves a requirement-level gap, termed Gap 1 to Gap 6 and stated in Section 3, and each gap corresponds to the research question and objective of the same number in Section 3. The figure also shows how the proposed framework addresses the two gaps and gives, for each requirement, the number of the 25 analysed studies graded Yes in Table 2.10.

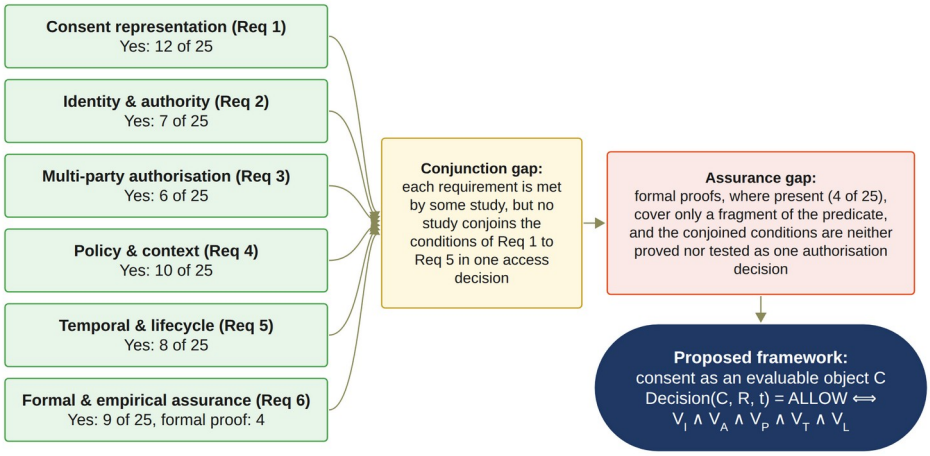



**Figure 2.2:** Synthesis of the review: the conjunction gap and the assurance gap

As presented in Tables 2.4 to 2.10, researchers have focused on securing individual aspects of healthcare data sharing: recording consent, verifying identity, approving access, and restricting the data that are released. However, from the perspective of the six requirements stated in Section 2.2, the existing work has the following drawbacks:

- *Inability to represent consent as an evaluable authorisation object (Req 1):* Existing consent approaches treat consent primarily as a record of a patient's permission (Akter & Sanam 2025; Prashanth et al. 2024), and some claim consent but leave it out of the access decision (Sawant & Gomes 2026). The evaluable consent objects reported since 2020 (Albalwy, Brass & Davies 2021; Eneh et al. 2026; Phuyal et al. 2026b; Shanmugham & Senthilkumar 2026; Tith et al. 2020) carry only a subset of the identity, authority, threshold, policy, temporal and lifecycle conditions, and they are issued by a single party. Without such a representation, the existing literature does not allow an access request to be evaluated against the conditions that the patient actually set.
- *Inability to verify authority separately from identity (Req 2):* A valid decentralised identity establishes who a participant is (Mazzocca et al. 2025), but it does not establish what that participant is authorised to do. Authority is verified separately from authentication in only 10 of the 25 studies, and Req 2 is graded Yes in 7 of them (Table 2.10). Without this separation, an authenticated participant is treated as an authorised one.

- *Absence of multi-party approval as a standing condition of every access decision (Req 3):* Multi-party approval appears in the reviewed studies as a contingency path, an admission gate or a registration-time co-consent (Madine et al. 2020; Punia et al. 2025; Tan, Chi & Lam 2024). The approving set is defined on the institutional or delegate side (Punia et al. 2025; Wu et al. 2022; Zhao & Su 2024), or it is appointed by the patient but evaluated only as a contingency path or as a key-custody threshold (Maruthi & Singh 2025; Tan, Chi & Lam 2024). Req 3 is the least satisfied requirement, graded Yes in 6 studies (Table 2.10). None of the papers examined makes approval by a patient-defined set a condition of every access decision.
- *Inability to bind purpose and data scope to the same decision as identity, authority and approval (Req 4):* Policy controls on purpose or data scope are enforced by 10 of the 25 studies (Table 2.10), only six of which evaluate purpose-of-use as part of the access decision, and in none of them are they bound to the same decision as identity, authority and multi-party approval; in the reviewed studies, multi-party approval is never conjoined with a purpose condition (Madine et al. 2020; Punia et al. 2025; Tan, Chi & Lam 2024). Without this binding, a valid identity and sufficient approvals can be used to obtain data outside the authorised scope.
- *Absence of temporal and lifecycle evaluation integrated with the complete access decision (Req 5):* Req 5 is graded Yes in 8 of the 25 studies (Table 2.10). While some of them, such as (Eneh et al. 2026; Panagoulias et al. 2026), evaluate the validity period or the revocation of a consent at the time of the request, the others enforce them on a credential or at registration, and none integrates them with the complete multi-party authorisation decision. Without such integration, a consent that has expired or been revoked can remain usable once its approvals have been recorded.
- *Absence of formal and empirical assurance of the complete decision (Req 6):* Within Req 6, formal assurance is provided by 4 studies, argued informally by 9, and absent in the rest (Section 2.4.6). The studies that coordinate several mechanisms in one decision (Ferreira et al. 2025; Panagoulias et al. 2026; Phuyal et al. 2026b; Punia et al. 2025; Shanmugham & Senthilkumar 2026) test their own decisions, but none of them proves or tests a conjunction that includes multi-party approval, and any proof covers only a fragment of the predicate. Without such assurance, the correctness of the decision as a whole rests on the correctness of its parts.

The review has limitations. A single search string and a single round of coding mean that a small number of relevant studies may have been missed.

In the next section, we present our proposed framework to address the gaps.

## 2.5 Trust-Oriented Multi-Party Consent Authorisation Framework

The research addresses this gap by developing a trust-oriented authorisation model in which consent is not simply evidence that permission was granted, but the basis for evaluating whether a particular access request should be trusted. The resulting research direction places Trust Computing at the centre of the investigation, while treating blockchain, decentralised identity, verifiable credentials, and policy mechanisms as enabling technologies supporting the broader trust model. Sections 2.5.1 to 2.5.6 state how the proposed framework, implemented in the HALAH prototype, addresses each requirement and the research objective that delivers it.

### 2.5.1 Representation of Consent as an Evaluable Authorisation Object (Req 1)

Consent is represented as the evaluable object C = (I, A, P, T, L, E), created through Algorithm 1 and evaluated at every access request. This requirement is addressed through RO1, presented in Section 6.

### 2.5.2 Decentralised Verification of Identity and Authority (Req 2)

DID and VC verification separates identity from authority and is evaluated as VI through Algorithm 2. The prototype checks the DID format, verifies each guardian's credential before the signature is added, and verifies the requesting doctor's credential at every access request. This requirement is addressed through RO2, presented in Section 7.

### 2.5.3 Multi-Party Authorisation through a Verifiable Threshold (Req 3)

N-of-N approval by the guardian set G with EIP-712 guardian signatures (Bloemen, Logvinov & Evans 2017), evaluated as VA through Algorithm 3. This requirement is addressed through RO3, presented in Section 8.

#### 2.5.4 Policy- and Context-Aware Enforcement at the Time of Access (Req 4)

Purpose and a non-empty data scope within the consent are evaluated as VP through Algorithm 4. This requirement is addressed through RO4, presented in Section 9.

#### 2.5.5 Temporal Validity and Lifecycle Control of Consent (Req 5)

The validity window VT, revocation, the lifecycle states, and the on-chain revocation on Sepolia are implemented, as specified in Algorithm 5. This requirement is addressed through RO5, presented in Section 10.

#### 2.5.6 Verifiable Auditability and Security Assurance (Req 6)

Audit ledger evidence and 46 automated tests, including twelve attack scenarios A1 to A12. This requirement is addressed through RO6, presented in Section 11.

### 2.6 Conclusion

This section reviewed the literature on multi-party consent and trustworthy data sharing in healthcare. Six requirements were stated for a trustworthy multi-party consent authorisation: an evaluable consent object, decentralised verification of identity and authority, multi-party authorisation through a verifiable threshold, policy- and context-aware enforcement at the time of access, temporal validity and lifecycle control, and verifiable auditability and security assurance. The literature was searched in seven databases, screened under the PRISMA 2020 statement, and evaluated against six quality questions, and 25 primary studies were analysed in full against the requirements.

The review shows that each requirement is met by some of the studies, but that no study meets them together. Multi-party approval, where it appears, is a contingency path, an admission gate or a registration-time co-consent, not a standing condition of every access decision with an approving set defined by the patient. Purpose and data scope are rarely bound to the same decision as identity, authority and approval, and temporal validity and revocation are usually enforced on a credential rather than at the time of each request. Where several conditions are combined, some studies test their own decisions, but none proves or tests the complete conjunction defined in this review, including patient-defined multi-party approval as a standing condition of access. These findings form the conjunction gap and the assurance gap. The next chapter states these gaps, the research questions that follow from them, and the objectives of this thesis.

# 3. Research Gaps & Questions

## 3.1 Research Gap

From a thorough review of the existing literature documented in Section 2, we have identified the following six gaps:

1. There is no existing representation of patient consent that carries the identity, authority, threshold, policy, temporal and lifecycle conditions of access as one evaluable object. Consent is recorded as a permission, and the evaluable objects that exist carry only a subset of the conditions and are issued by a single party.
2. There is no method that verifies the authority of a participant separately from the authentication of that participant within the same access decision, so a valid identity is taken as permission.
3. There is no mechanism by which multi-party approval, with the approving set defined by the patient, is a standing condition of every access decision rather than a contingency path, an admission gate or a registration-time co-consent.
4. There is no enforcement that binds the purpose and the data scope of a request to the same decision as identity, authority and collective approval.
5. There is no evaluation of temporal validity, lifecycle state and revocation that is integrated with the complete access decision; where they are evaluated at the time of the request, they stand apart from the identity, authority and approval conditions, and elsewhere they are enforced on a credential or at registration.
6. There is no formal definition or systematic testing of the complete authorisation decision under valid, invalid and adversarial conditions; any proof covers only a fragment of it.

The patient, as the data subject, may create a consent specification and identify the relevant healthcare participant, authorised purpose, permitted data categories, and required approval conditions. The guardian set G is the set of designated participants whose independent approval is required. Depending on the consent configuration, G may contain healthcare professionals, guardians, institutional representatives, or other authorised parties. In the current prototype, the members of G are guardians. Each member of G is checked to determine whether the individual or entity possesses the required authority to participate in consent-related decisions. The threshold N is the number of valid approvals from members of G needed for activation. If the number of valid approvals is below the required threshold N, the consent cannot produce an effective authorisation decision. The authorised doctor D is the requester whose access request R is evaluated against the consent object C.

## 3.2 Main Research Question

From the systematic literature review documented in Section 2, and the shortcomings outlined in Section 2.5, it is clear that there are several gaps in the existing literature on trustworthy multi-party consent authorisation for healthcare data sharing.

Based on the identified research gap, the overarching research question is formulated as follows: **"How can a trust-oriented computing framework establish and enforce trustworthy multi-party consent for decentralised healthcare data sharing under identity, authority, and policy constraints?"** The formulation of this question deliberately emphasises trust-oriented computing rather than any individual implementation technology. The terms establish and enforce represent two complementary aspects of the research problem. Establishment concerns how trustworthy participants, authority relationships, and collective consent decisions are created. Enforcement concerns how these established conditions are evaluated when a healthcare data-access request is made.

## 3.3 Sub-Research Questions

The research objectives are operationalised through six corresponding sub-research questions. Each sub-research question addresses a distinct dimension of the proposed trust-oriented healthcare authorisation framework. For brevity, SRQ1 to SRQ6 are referred to as RQ1 to RQ6 throughout this report.

- **SRQ1 (Trust-Centric Consent Modelling):** How can patient consent be modelled as a trust-aware authorisation object that explicitly represents identity, authority requirements, policy constraints, and authorisation evidence?
- **SRQ2 (Decentralised Identity and Authority Trust):** How can decentralised identities and verifiable credentials establish trustworthy participants while explicitly separating identity authentication from authorisation authority?
- **SRQ3 (Trustworthy Multi-Party Authorisation):** How can multiple independently verified participants jointly establish a trustworthy consent decision without allowing a single participant to unilaterally authorise sensitive healthcare data access?
- **SRQ4 (Policy- and Context-Aware Access Control):** How can policy, purpose, and data-scope constraints be incorporated into authorisation decisions so that valid identities and sufficient approvals cannot be used to obtain unauthorised healthcare data?
- **SRQ5 (Temporal and Lifecycle Trust):** How can temporal validity and consent lifecycle controls ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and is rejected after expiration, revocation, or an unauthorised state transition?
- **SRQ6 (Formal Security Assurance and Empirical Validation):** How can the security properties of the proposed trust-oriented authorisation mechanism be formally defined and empirically evaluated to demonstrate that the implemented framework correctly enforces authorised and unauthorised healthcare data-access decisions?

The consent object against which these questions are evaluated is defined in Equation (3.1), where I represents identity information, A represents authority and authorisation requirements, P represents policy and data-scope constraints, and E represents authorisation evidence. Within A, the guardian set G and the threshold N define the required approvals. T is the temporal validity window, and L represents the current state of the consent object and its permissible transitions, including whether the consent remains active or has been revoked. This formulation changes the role of consent from a passive record into an evaluable authorisation object.

$$C = (I, A, P, T, L, E) \tag{3.1}$$

## 3.4 Research Questions as an Integrated Problem

The six sub-research questions are not independent technical questions. RQ1 establishes the conceptual object. RQ2 establishes the trustworthiness of the participants. RQ3 then extends this participant-level trust into a collective decision. RQ4 determines whether the resulting authorisation is applicable to the specific data-access request. RQ5 further introduces the dynamic dimension of trust by determining whether the authorisation remains valid with respect to its temporal conditions and lifecycle state. Finally, RQ6 establishes the assurance layer by formally defining the resulting security properties and empirically evaluating whether the implemented framework enforces them correctly. The integrated authorisation condition can therefore be expressed as Equation (3.2). Here, $V_I$ represents identity and authority validity, $V_A$ collective authorisation validity, $V_P$ policy and contextual compliance, $V_T$ temporal validity, and $V_L$ consent lifecycle validity.

$$\text{Decision}(C, R, t) = \text{ALLOW} \iff V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \tag{3.2}$$

A valid authorisation decision requires the simultaneous satisfaction of all relevant trust conditions. Consequently, failure of any individual condition results in denial. In the prototype, an ALLOW decision additionally requires the Groth16 ZK proof (Groth 2016) to verify, so a request that satisfies the five predicates is still denied when the proof fails, as in attack A9 (Section 11.6). Formal security assurance does not constitute another authorisation condition to be evaluated at runtime. Instead, it provides a means of specifying, analysing, and verifying the security properties of the integrated authorisation mechanism. Thus, RQ6 operates as an assurance layer over the mechanisms established by RQ1–RQ5.

# 4. Research Objectives and Methodology

The research objectives turn the research gap into concrete research and development activities. The complete research programme consists of six research objectives, corresponding to six research questions.

## 4.1 RO1: Trust-Centric Consent Model

The first research objective is to develop a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object. The model incorporates identity information, authority requirements, policy constraints, and authorisation evidence so that a consent decision can be evaluated when a subsequent data-access request is made. RO1 directly addresses RQ1 and establishes the conceptual foundation for the remaining objectives. It defines the information that must be represented before consent can be interpreted as an authorisation decision rather than merely as a static approval record.

## 4.2 RO2: Decentralised Identity and Authority Trust

The second research objective is to develop a decentralised identity and authority verification mechanism using decentralised identifiers and verifiable credentials. The objective is to establish trustworthy participants while explicitly separating identity authentication from authorisation authority. RO2 addresses RQ2 and provides the trust inputs required by the subsequent multi-party authorisation process. The objective is based on the principle that successful identity verification does not automatically imply permission to access healthcare data.

## 4.3 RO3: Trustworthy Multi-Party Authorisation

The third research objective is to develop a threshold-based multi-party authorisation mechanism through which multiple independently verified participants and guardians can jointly establish a trustworthy consent decision. The objective is to prevent unilateral authorisation where collective approval is required. The required participant set G, fixed at consent creation, defines which participants are eligible to contribute an approval to the authorisation process. Depending on the consent configuration, G may contain healthcare professionals, guardians, institutional representatives, or other authorised parties, and the threshold N satisfies $1 \leq N \leq |G|$. In the current prototype, the members of G are guardians. Each participant must submit an approval that can be independently verified through EIP-712 signature recovery. Invalid approvals are rejected and must not contribute to the threshold count. In the current prototype, a valid signature is required from every listed guardian, so the threshold equals $|G|$, an N-of-N condition demonstrated in the 2-of-2 configuration. In this case, one valid approval is insufficient, whereas two valid approvals satisfy the threshold. RO3 addresses RQ3 and extends the consent model from an individual permission statement to a collective authorisation decision.

## 4.4 RO4: Policy- and Context-Aware Access Control

The fourth research objective is to develop a policy-aware authorisation mechanism that evaluates the purpose and data scope of a requested operation against the constraints defined by the consent. The objective is to ensure that a valid identity and sufficient multi-party approval cannot be used to obtain healthcare information outside the authorised scope. A request is permitted only when the purpose is compatible with the consent and the requested data scope is a non-empty subset of the authorised EMR modules. In the current prototype, the request purpose is taken from the consent, so the purpose check confirms that the consent purpose is a supported healthcare use, while the comparison with a separately declared request purpose is left to the next stage. RO4 directly addresses RQ4 and completes the foundational authorisation model. Together, RO1–RO4 establish the representation, verification,

collective authorisation, and policy-enforcement mechanisms required for a trust-oriented healthcare data-sharing decision.

## 4.5 RO5: Temporal and Lifecycle Trust

The fifth research objective is to extend the trust-oriented framework with temporal validity and consent lifecycle controls. The objective is to ensure that an authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, revocation, and unauthorised state transitions are correctly enforced. RO5 addresses RQ5 and extends the foundational authorisation model into a dynamic consent environment. The current HALAH code already collects a start time and expiry time during consent creation. The prototype records them on-chain as notBefore and expiry within the consent token, enforces the temporal validity window at every access decision through $V_T$, implements end-to-end revocation, including an on-chain revoke transaction, and manages the consent through an explicit lifecycle state machine. Access can be granted only in the ACTIVE state, and $V_L$ checks this state at every access decision. A consent that has expired or been revoked must not remain usable merely because its original approval threshold was satisfied. The remaining work concerns the SUSPENDED state, the lifecycle transition check, a formal lifecycle model, and hardening these controls and extending them to consent modification, delegation, and guardian-set changes.

## 4.6 RO6: Formal Security Assurance and Empirical Validation

The sixth research objective is to formally analyse and empirically evaluate whether the implemented framework satisfies its defined trust and authorisation properties under representative healthcare data-sharing scenarios. RO6 addresses RQ6 and combines formal security assurance with empirical validation of the proposed framework. The prototype must execute valid consent workflows, and it must also behave correctly when one or more trust conditions are violated. RO6 is not done; so far, the HALAH prototype has been used for the initial scenario-based validation of RO1 to RO4. In particular, 46 automated tests cover signature rejection, proof tampering, credential checks, and twelve attack scenarios, A1 to A12, against the components of C and the contract. All twelve attacks are refused. Preliminary measurements of on-chain cost, confirmation latency, and processing time have been obtained. The formal component will specify and analyse the security properties, consistency requirements, and soundness conditions of the trust-oriented authorisation mechanism. Although preliminary implementation and scenario-based testing support the current stage findings, the complete formal analysis, through proofs or model checking, and a larger evaluation under load will be conducted as part of next stage works.

## 4.7 Relationship Between Research Questions and Objectives

The relationship between the six research questions and the six research objectives, with the status of each objective, is summarised in Table 4.1. The mapping follows the structure of the research programme and maintains a direct correspondence between each research question and its associated objective. RO1 to RO6 are realised in Section 6 to Section 11 respectively, each in the section presenting the solution for the corresponding research question. Because each research question corresponds to one gap identified in Section 2, each objective addresses the gap of the same number, so that RO1 addresses Gap 1 and RO6 addresses Gap 6. Each research question therefore has one research activity, and each objective contributes to the framework. RO1 to RO4 are delivered in this stage, together with their validation through the implemented prototype, whereas, as stated in Section 1, RO5 and RO6 are not done: RO5 is in progress and RO6 is limited to validation. The evaluation of the framework will be carried out when the full system is done. Their remaining work is detailed in Section 10 and Section 11, and its schedule is presented in Section 13. The distinction between current stage and next stage is therefore based on research scope and maturity rather than on a different set of research questions or objectives.

**Table 4.1:** Research questions, research objectives, and the status of each objective

| RQ | Research objective | Description | Status |
|---|---|---|---|
| RQ1 | RO1: Trust-Centric Consent Model | To develop a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object. | Done |
| RQ2 | RO2: Decentralised Identity and Authority Trust | To develop a decentralised identity and authority verification mechanism using decentralised identifiers and verifiable credentials. | Done |
| RQ3 | RO3: Trustworthy Multi-Party Authorisation | To develop a threshold-based multi-party authorisation mechanism through which multiple independently verified participants and guardians can jointly establish a trustworthy consent decision. | Done |
| RQ4 | RO4: Policy- and Context-Aware Access Control | To develop a policy-aware authorisation mechanism that evaluates the purpose and data scope of a requested operation against the constraints defined by the consent. | Done |
| RQ5 | RO5: Temporal and Lifecycle Trust | To extend the trust-oriented framework with temporal validity and consent lifecycle controls. | Not done (in progress) |
| RQ6 | RO6: Formal Security Assurance and Empirical Validation | To formally analyse and empirically evaluate whether the implemented framework satisfies its defined trust and authorisation properties under representative healthcare data-sharing scenarios. | Not done (validation only) |

## 4.8 Research Methodology

This research follows the Design Science Research (DSR) methodology, based on the process model of Peffers et al. (2007), as shown in Figure 4.1. DSR fits this research because its aim is to design and evaluate an artefact, the trust-oriented authorisation framework and its HALAH prototype, that addresses an identified problem. The process has five stages. Knowledge gained in each stage feeds back into the process through iteration, so that the design is refined over successive cycles.

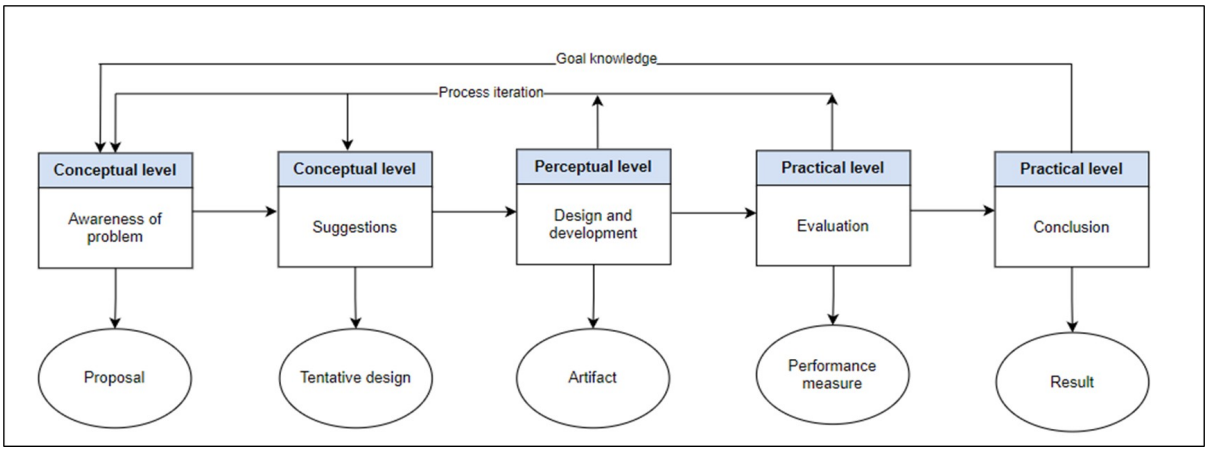



**Figure 4.1:** Design Science Research Methodology process model (Peffers et al. 2007).

In the awareness-of-problem stage, the systematic literature review of Section 2 identified the fragmentation of trust conditions in existing consent mechanisms, and its output is the research proposal. In the suggestion stage, the research gap was turned into the research questions RQ1 to RQ6, the research objectives RO1 to RO6, and the integrated trust model, which together form the tentative design. In the design and development stage, the consent object C, the MVC architecture, and Algorithms 1 to 6 were designed, and the HALAH artefact was implemented on the Sepolia testnet (Sections 5 to 11). In the evaluation stage, the artefact has so far been validated through access scenarios, 46 automated tests including twelve attack scenarios, and preliminary measurements of gas and processing time (Section

11); the evaluation of the complete framework will be carried out when the full system is done. In the conclusion stage, the results, the contributions, and the remaining lifecycle and assurance work are reported.

# 5. Research Architecture: MVC

The proposed research architecture adopts a Model–View–Controller (MVC) design to provide a structured implementation foundation for the trusted multi-party consent management framework. In the proposed framework, MVC does more than separate data, interfaces, and application logic. It is extended to support a separation between the representation of consent, the interaction of independent stakeholders, and the enforcement of security-critical authorisation decisions. A healthcare consent decision may involve patients, guardians, healthcare professionals, and auditors, each of whom may possess different identities, authorities, and responsibilities. Consequently, the system cannot rely on a single user authentication event or a static permission entry to determine whether access should be granted. Instead, the authorisation decision is the result of evaluating independently verifiable security conditions together. Section 5.1 describes the layers and their components, Section 5.2 explains where trust is evaluated and where the architectural boundaries lie, Section 5.3 walks through the authorisation workflow, and Section 5.4 maps the architecture to the research objectives.

## 5.1 Layered Architecture and Component Decomposition

At the highest level, the architecture consists of three complementary layers. The View Layer represents the interaction boundary with independent healthcare stakeholders. The Controller Layer represents the security decision and coordination boundary. The Model Layer represents the persistent trust, consent, policy, and authorisation state. Figure 5.1 illustrates the conceptual relationship among these layers. The protected healthcare data are deliberately positioned outside the three MVC layers as a protected resource whose access is mediated by the Controller rather than directly exposed to the View.

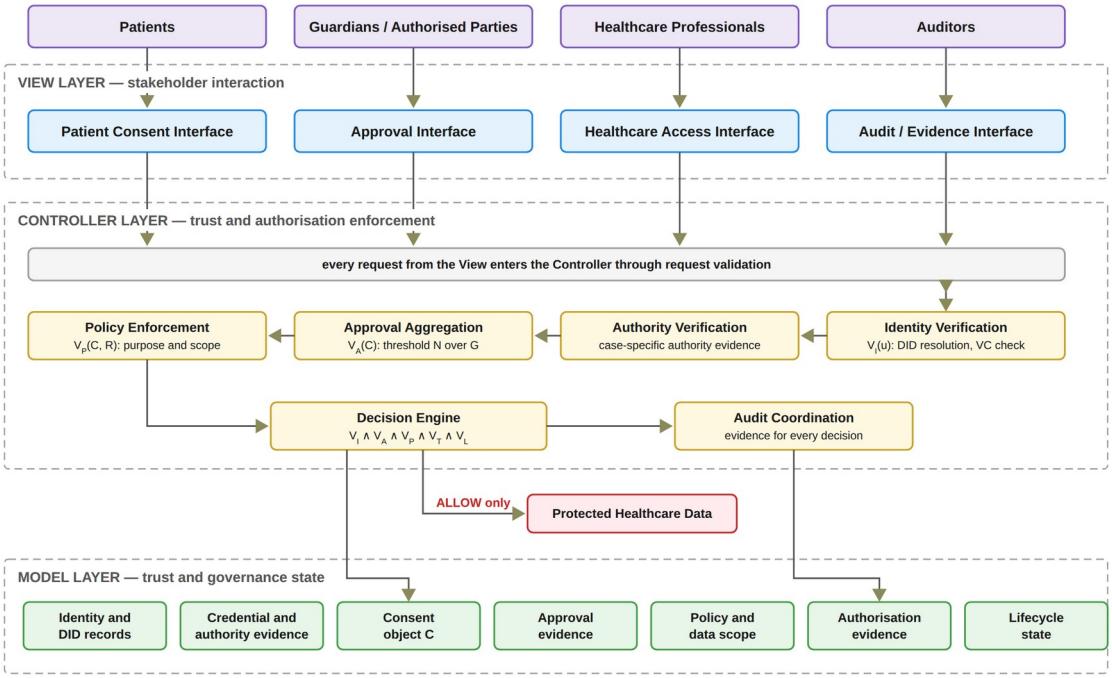



**Figure 5.1:** Layered MVC architecture and component decomposition of the HALAH framework.

An action submitted through the View represents a request or claim rather than a trusted authorisation outcome. The Controller Layer constitutes the principal security enforcement boundary. It receives requests from the View and coordinates the evaluation of the relevant trust conditions. These include decentralised identity verification, credential and authority verification, multi-party approval evaluation, policy and data-scope evaluation, and final authorisation. The Controller also generates audit evidence

associated with the resulting decision. Consequently, the Controller acts as the coordination point through which sensitive operations must pass before protected healthcare data can be accessed. The Model therefore provides the information required for the Controller to evaluate an access request, but the existence of a Model object does not itself imply that access is permitted. MVC was selected in preference to a purely on-chain design for two reasons. First, the authorisation decision must combine the identity, threshold, policy, temporal, and lifecycle evaluation performed by the Controller with the anchoring of consent state on the blockchain. Second, each stakeholder interface can be replaced without altering the enforcement logic, so the trust predicates are evaluated independently of any particular user interface.

Figure 5.2 presents this decomposition. The View is decomposed according to the principal stakeholder roles. The patient interface supports consent specification and consent-related actions. The guardian or other authorised-participant interface supports independent approval. The healthcare professional interface supports authorised data-access requests. The auditor interface supports inspection of authorisation evidence and audit history. These interfaces represent different interaction responsibilities but share the same architectural principle: none of them independently determines whether access should be granted. The Controller is decomposed into six principal security functions. Identity Verification establishes whether a participant can be identified through the relevant decentralised identity mechanism. Authority Verification evaluates whether the participant possesses appropriate evidence concerning the required role or authority. Approval Aggregation determines whether independently verified approvals satisfy the predefined threshold. Policy Enforcement evaluates whether the requested purpose and data scope comply with the consent policy. Decision Engine combines the resulting predicates into the final authorisation decision. Finally, Audit Coordination records the relevant evidence and decision events. The Model is decomposed into seven principal state representations: DID, VC, Consent, Approval, Policy, Evidence, and Lifecycle. This decomposition establishes an explicit distinction between state, interaction, and enforcement.

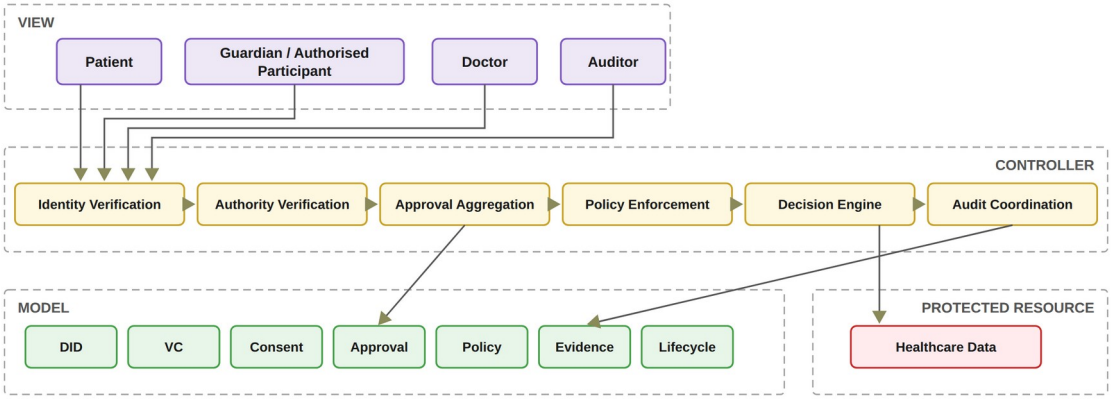



**Figure 5.2:** Functional decomposition of the MVC components.

In the implemented prototype, the Controller comprises eight principal functions rather than six, since a Validity Proof Service checks the consent once more before any data are released, as Section 9 presents, and an On-chain Anchor Service anchors the Sepolia mint as a background process. A revoke transaction is sent when the patient revokes a consent, and the patient view waits for its confirmation. The Model correspondingly contains the ConsentSBTv3 soulbound contract deployed on Sepolia together with the application audit ledger, both of which an independent verification tool reads, as described in Section 11. In the present prototype, each DID must be well formed, and the doctor and each guardian must hold a valid verifiable credential from a demo issuer. The guardian's credential is checked before the guardian signs, and $V_1$ combines the doctor's credential check with the EIP-712 verification of each listed guardian's signature. The requester's DID is declared in the interface rather than authenticated, and

wallet-held signing keys, full DID resolution and proof that the user controls the DID are deferred to the next stage. However, each guardian approval is an EIP-712 typed-data signature bound to the consent identifier, so the multi-party threshold is enforced over signed approvals rather than over interface actions.

## 5.2 Trust Evaluation and Architectural Boundaries

The architectural layers cooperate through a controlled authorisation sequence rather than through unrestricted direct communication. A healthcare data-access request is not evaluated according to a single authentication event. As illustrated in Figure 5.3, the Controller coordinates a sequence of trust predicates representing the conditions established by the sub-research questions. The first condition, $V_I(u)$, determines whether the requesting participant possesses valid identity and authority evidence. The second condition, $V_A(C)$, determines whether the required independently verified participants have collectively satisfied the authorisation threshold N. The third condition, $V_P(C, R)$, determines whether the requested operation complies with the consent policy, including purpose and data-scope restrictions. The fourth condition, $V_T(C, t)$, determines whether the consent remains valid at the time of the request. The fifth condition, $V_L(C)$, determines whether the consent remains in a valid lifecycle state. The integrated decision can therefore be expressed as Equation (3.2). In the current prototype, the Consent Engine derives the lifecycle state, a request proceeds only when this state is ACTIVE, and the revocation flag and the token are also checked within $V_A$.

In the current prototype, VI also checks the EIP-712 signature of each listed guardian, and a refusal for a consent that is not ACTIVE is recorded in the audit ledger like any other refusal.

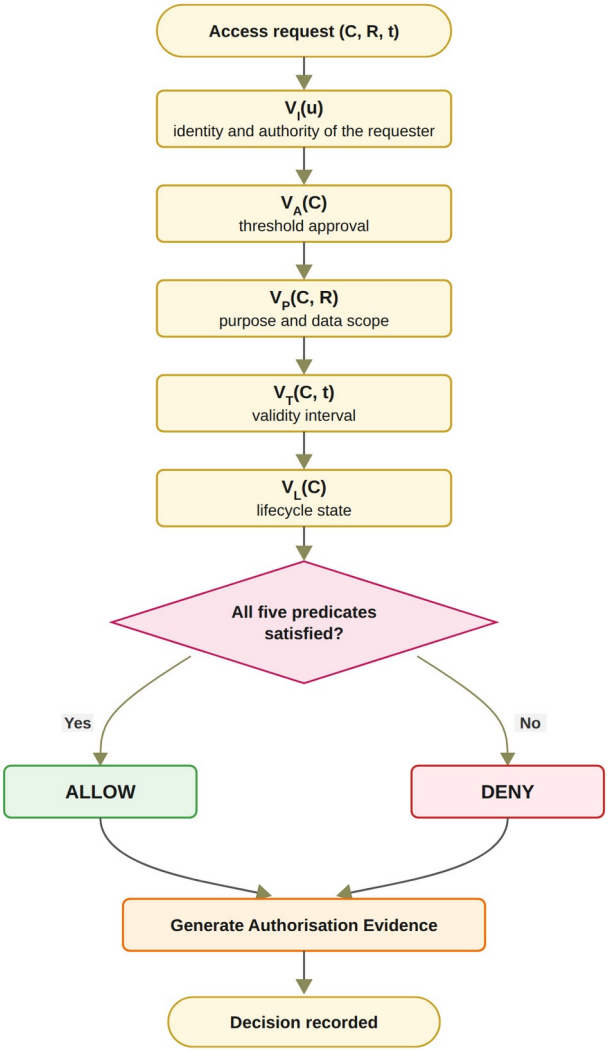



**Figure 5.3:** Trust predicate evaluation and authorisation decision flow

If any required predicate evaluates to false, the decision is DENY. The Controller does not itself create these trust conditions. Instead, it evaluates evidence represented by the Model and coordinates the resulting decision. For the interpretation of the architecture: the Controller is a decision-enforcement mechanism, whereas the Model is a representation of trust and governance state. Both successful and unsuccessful decisions are subsequently associated with authorisation evidence, which supports accountability and subsequent verification. The layered architecture also establishes explicit trust boundaries. The View is considered an interaction boundary and therefore cannot be treated as a trusted source of authorisation decisions. The Controller represents the security enforcement boundary. It is responsible for applying the authorisation rules consistently and for preventing direct access to protected healthcare data when the required trust conditions are not satisfied. The Model represents the security-state boundary. Its records provide the evidence and state required for authorisation evaluation, but stored state alone does not constitute permission. In particular, the presence of a consent record, credential, or approval record cannot independently produce an access decision. The protected healthcare data represent the final resource boundary, and access is permitted only through the authorisation path enforced by the Controller. The proposed framework does not claim that MVC itself provides security. Instead, security arises from the explicit placement of trust-sensitive operations within the Controller, the structured representation of security state within the Model, and the prevention of direct security decisions at the View layer. In the present prototype, the Controller is a single trusted server that both

evaluates the predicates and writes the audit ledger, and accordingly, the on-chain anchoring of consent state and the independent verification tool provide the external evidence against which the Controller's own records can be checked. Figure 5.4 puts the same conditions in the order a request meets them. A DID answers who is asking, a verifiable credential and a signed approval answer what that participant may do, the threshold answers whether the members of G agreed, and the policy, temporal and lifecycle checks answer whether the consent is still valid for this request. The figure also states, gate by gate, what the current prototype checks, so the reader can see where the design and the prototype differ before the detailed sections.

The four gates of Figure 5.4 are identity (DID), authority (VC and signed approval), collective approval (threshold), and validity of the consent for the request (policy, time and lifecycle). Each gate names what the current prototype checks, and a failure at any gate produces DENY. The prototype records the decision matrix in the audit ledger for every request, including one against a consent that is not ACTIVE.

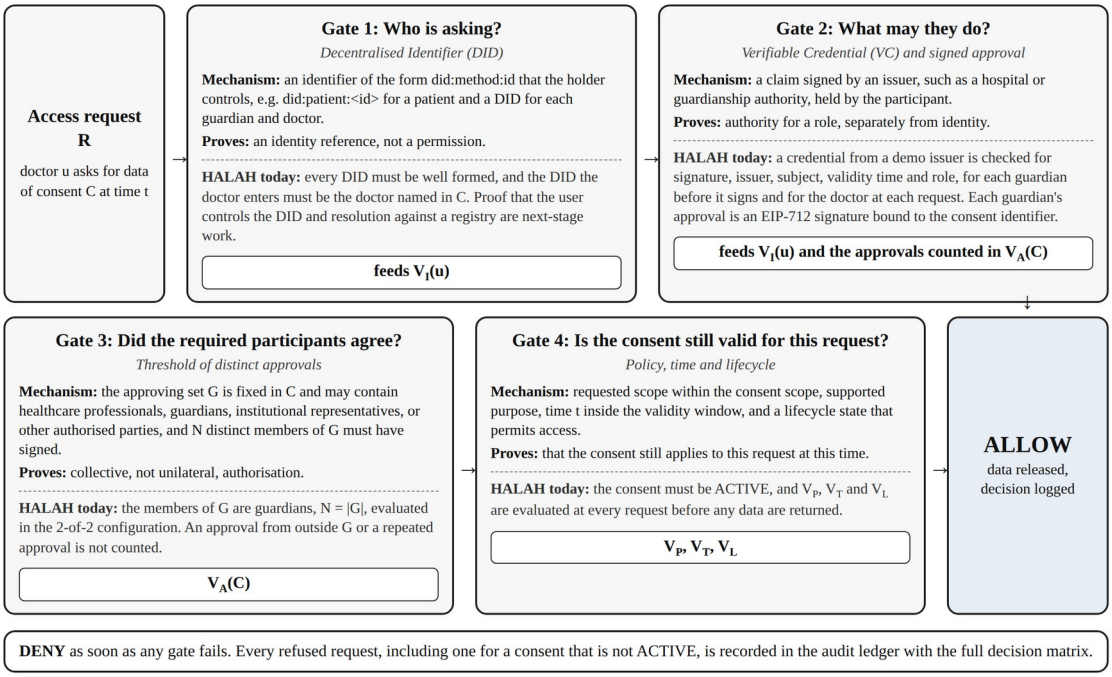



**Figure 5.4:** The four gates that an access request passes before data are released

## 5.3 Trust-Oriented Consent Authorisation Workflow

Figure 5.5 presents the end-to-end workflow of the proposed framework. The workflow begins when the patient creates a consent request. The consent specification defines the intended purpose, permitted data scope, and other authorisation conditions. This step establishes what the patient intends to authorise and provides the policy context against which subsequent access requests can be evaluated. The next step of the workflow applies a decentralised identity and authority verification mechanism using Decentralised Identifiers and Verifiable Credentials. The framework separates identity authentication from authorisation. A successfully verified DID or VC does not, by itself, grant permission to access patient data. The framework then collects the participants' independent approvals and evaluates whether the predefined authorisation threshold has been satisfied. Let $A_V$ denote the set of participants whose approvals have been verified and let N denote the required authorisation threshold, as in Equation (5.1). Here, Token(C) ≠ ∅ means that C has been assigned a token identifier, and Revoked(C) = 0 means that the consent has not been revoked.

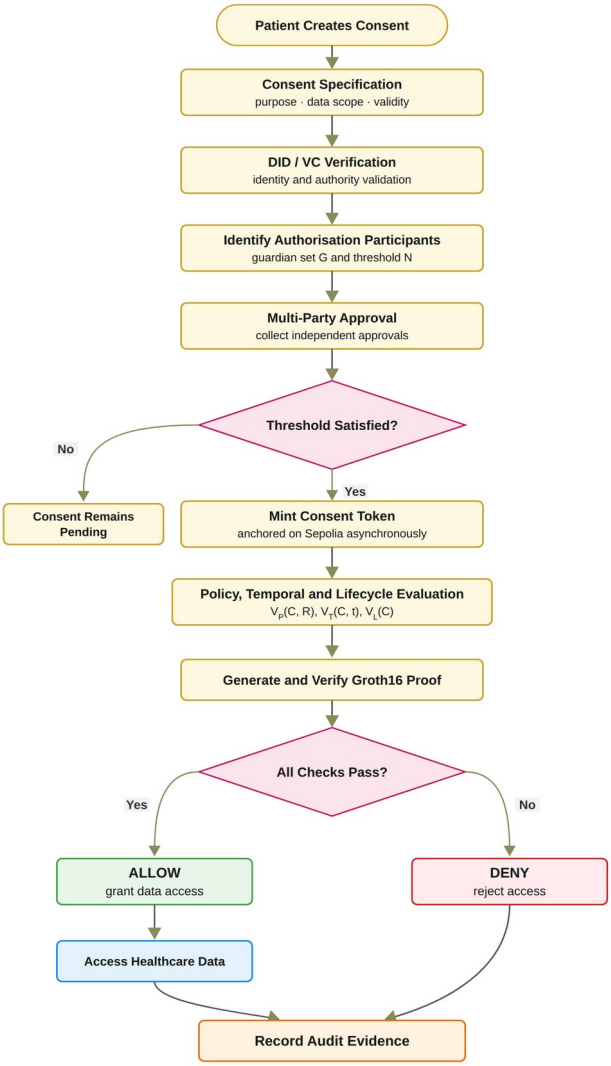



**Figure 5.5:** End-to-end workflow of the trust-oriented consent authorisation framework.

$$V_A(C) = 1 \text{ if } |A_v| \geq N \wedge \text{Token}(C) \neq \varnothing \wedge \text{Revoked}(C) = 0, \text{ and 0 otherwise.} \tag{5.1}$$

Only independently verified participants can contribute to the set of verified approving participants $A_v$, as defined in Equation (5.2), where $A_s$ denotes the set of approvals submitted for C. $A_v$ therefore contains each member of G at most once, and an approval from a signer outside G does not enter $A_v$. Consequently, an arbitrary number of unverified or unauthorised approvals cannot satisfy the multi-party authorisation requirement. A compromised or unauthorised participant cannot independently activate access when the threshold has not been satisfied. This distinguishes the framework from reviewed systems in which joint approval is a contingency path, a witness or notary threshold, a registration-time co-consent, a documentation-time gate on guardian access, an institution-side admission gate, a custodial M-of-N signature, a key-share reconstruction, or a threshold proxy re-encryption.

$$A_v = \{g \in G \mid \exists\, a_i \in A_s \text{ submitted by } g \text{ with } V_I(g) = 1\}. \tag{5.2}$$

In the implemented prototype, the threshold is fixed at N = |G|, as justified in Section 8, and once the N-of-N condition is satisfied, the consent token is minted in the local ledger and a background job anchors the mint on Sepolia asynchronously. The policy, temporal and lifecycle checks VP, VT and VL are then evaluated before access is granted, and the audit evidence is recorded. Beyond the access decision shown in Figure 5.5, the prototype continues through patient-initiated revocation and the corresponding on-chain revoke transaction, after which the auditor reviews the record and the verification tool performs an

independent verification. If the required threshold is not satisfied, the consent remains pending, and any access request made against it is denied. This prevents a single participant from unilaterally establishing authorisation when the consent policy requires collective approval. When the authorisation threshold is satisfied, the requested access is evaluated against the purpose and data-scope constraints defined in the consent object. This step addresses a limitation of identity-based and approval-based access control: a legitimate participant may still request data that fall outside the scope of the patient's consent. For example, if a consent authorises access to observations and medications, a request for observations, medications, and procedures should be rejected because the request exceeds the authorised data scope. Similarly, the purpose must be a supported healthcare use. The full design also requires the requested purpose to match the purpose recorded in the consent, which the prototype does not yet compare, as Section 9.4 explains. Consequently, a valid identity and sufficient multi-party approval are necessary but not sufficient conditions for access. Both successful and denied decisions should be recorded because a trustworthy authorisation framework requires accountability not only for data that were released but also for access attempts that were rejected. In the prototype, every denial, including one against a consent that is not ACTIVE, is recorded with its complete decision matrix.

## 5.4 MVC Architecture and the Research Objectives

The MVC architecture also provides a direct implementation structure for the research objectives, as summarised in Table 5.1. RO1 is primarily represented in the Model through the development of the trust-aware consent object C = (I, A, P, T, L, E). RO2 is implemented through the identity and authority verification mechanisms coordinated by the Controller. RO3 is realised through the multi-party approval and threshold evaluation process. RO4 is implemented through the policy evaluation mechanisms that constrain the authorised purpose and healthcare data scope. For RO5, temporal conditions and lifecycle state are represented in the Model, while $V_T$ and $V_L$ are evaluated by the Controller before an access decision is produced. RO6 operates across the complete architecture rather than being confined to a single MVC layer. Formal security assurance evaluates the logical properties of the integrated model, while empirical validation evaluates whether the implementation consistently realises those properties. The evidence generated by the Controller and stored in the Model is what the empirical validation and the independent verifier examine.

**Table 5.1:** Mapping between research objectives and MVC components

| Research Objective | Primary MVC Component | Core Mechanism | Expected Contribution |
|---|---|---|---|
| RO1 | Model | Trust-aware consent representation | Transforms consent from a passive permission record into a structured and evaluable authorisation object. |
| RO2 | Controller and Model | DID and VC verification | Establishes trustworthy participants while explicitly separating identity from authorisation authority. |
| RO3 | Controller | Verified multi-party threshold evaluation | Establishes collective trust and prevents unilateral authorisation when multiple approvals are required. |
| RO4 | Controller and Model | Policy, purpose, and data-scope evaluation | Ensures that valid participants and sufficient approvals remain constrained by the authorised purpose and healthcare data scope. |
| RO5 | Model and Controller | Temporal validity and consent lifecycle enforcement | Ensures that authorisation remains valid only within its permitted time interval and lifecycle state, and that expiration, revocation, and unauthorised state transitions are correctly enforced. |
| RO6 | Model, View, and Controller | Formal security analysis and empirical validation | Will provide formal assurance (next stage) of the defined trust and authorisation properties and empirically evaluate whether the implemented framework correctly enforces authorised and unauthorised healthcare data-access decisions. |

Table 5.2 summarises how the proposed framework differs from traditional EHR access control.

**Table 5.2:** Traditional EHR access control compared with the HALAH framework

| Aspect | Traditional EHR access control | HALAH framework |
|---|---|---|
| Identity | Central identity provider; institution login | A DID for every participant; identity kept separate from authority |
| Consent | A stored record that permission was given | An object C = (I, A, P, T, L, E), checked at every request |
| Approval | A static permission set by one party | All listed guardians sign (EIP-712); no single party can approve alone |
| Access check | Log in, then check a static permission | VI ∧ VA ∧ VP ∧ VT ∧ VL, evaluated at every request |
| Time and revocation | Hard to verify once the permission is stored | Validity window and revocation checked each time; on-chain revoke |
| Audit | A record that consent occurred | Every access decision, allowed or denied, logged off-chain with its decision matrix; consent state anchored on Sepolia |

The contribution of the proposed architecture is the way MVC is used to carry a trust-oriented authorisation model, not the use of MVC itself. This design transforms multi-party consent management from a conventional record-management problem into a distributed security-governance problem. The evaluable consent object as such is already present in the literature. The key innovation is that consent effectiveness depends on the joint satisfaction of identity, authority, collective approval, policy, temporal, and lifecycle conditions on every access decision. Blockchain or other tamper-resistant storage

mechanisms are integrated as infrastructure for preserving selected authorisation evidence. However, the blockchain itself is not treated as the source of trust. Its role is to strengthen integrity, non-repudiation, and auditability of the evidence generated by the authorisation process. The detailed solutions for RQ1 to RQ6 are presented in Sections 6 to 11, and the formal assurance of the complete decision model remains for the next stage. The next section presents the solution for RO1, the consent object on which the other objectives build.

# 6. The Proposed Solution for RO1

## *RO1 – Trust-Centric Consent Model*

**Status: Done**

This section presents the solution for RO1. Section 6.1 gives an overview of the trust-centric consent model, Section 6.2 shows the consent creation workflow, Section 6.3 defines the structure of the consent object, Section 6.4 presents the creation procedure and the algorithm, and Section 6.5 describes how the model is realised in the prototype.

## 6.1 Overview of the Trust-Centric Consent Model

RO1 addresses RQ1 by developing a trust-aware consent model that represents patient consent as a structured and evaluable authorisation object. The purpose of this objective is to establish a formal representation of what the patient intends to authorise, who is permitted to participate in the authorisation process, which healthcare data may be accessed, and under what conditions. The proposed consent object is represented as Equation (6.1).

$$C = (I, A, P, T, L, E) \tag{6.1}$$

In Equation (6.1), I represents patient and participant identity information, A represents authorisation requirements, P represents policy constraints, and E represents authorisation evidence. T represents the temporal validity window, and L represents the current state of the consent object and its permissible transitions. The temporal component bounds the consent in time, and the lifecycle component states whether the consent can currently be used. The identity component identifies the patient and relevant participants. The authorisation component defines the required participants and approval threshold. The policy component specifies the permitted purpose and healthcare data scope. The evidence component records the information required to support subsequent verification and audit. The consent model therefore separates the specification of consent from the final access decision. A consent object does not automatically imply that every subsequent request is authorised. Instead, the object provides the conditions against which a request can be evaluated.

## 6.2 Consent Creation Workflow

Figure 6.1 describes the creation of a trust-aware consent object. The process begins with a patient request and ends with a structured consent record that can be verified by subsequent authorisation services. The workflow first collects the patient identity and the intended healthcare participants. It then specifies the purpose and data scope of the consent. In the HALAH implementation, the patient interface allows the patient to select a patient DID, specify an authorised doctor, identify guardian DIDs, and select healthcare data modules such as Observation, Medication, Condition, and Procedure. The implementation also collects the start and expiry time of the consent. In the current interface, the purpose is fixed to Treatment and is not selected by the patient, and the purpose vocabulary check is therefore exercised by the automated tests rather than by the interface.

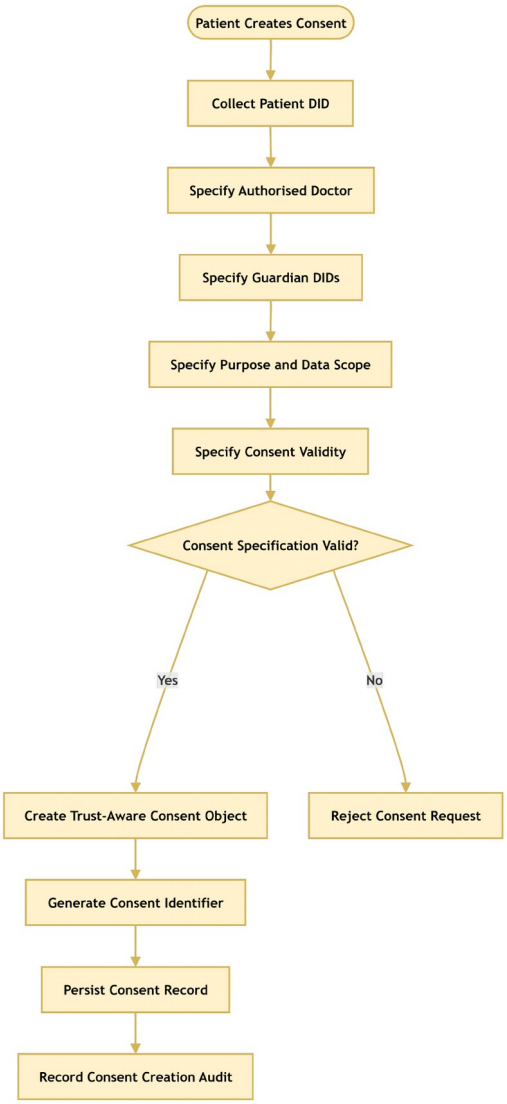



**Figure 6.1:** RO1 workflow for trust-centric consent creation.

The specification is accepted only when the required fields are valid. For example, the expiry time must be later than the start time, the data scope must not be empty, and each guardian DID must be well formed. After validation, the system creates the consent object, assigns a consent identifier, persists the record, and records the creation event in the audit layer. This process ensures that the consent object contains sufficient information for subsequent identity verification, multi-party authorisation, policy evaluation, and auditability. Once the consent object is created, its lifecycle state L becomes PENDING, because the consent cannot produce an effective authorisation decision until the required approvals have been obtained. In the current prototype, this state is PENDING_SIGNATURE.

## 6.3 Structure of the Consent Object

Figure 6.2 shows how the validated information is combined to construct the consent object. The resulting object therefore captures the patient's preference and the evidence needed for later authorisation decisions.

Figure 6.2 shows the content and the supplier of each component, where L is the lifecycle state. The states shown are those of the design, and the states implemented in the prototype are given in Section 10.3.

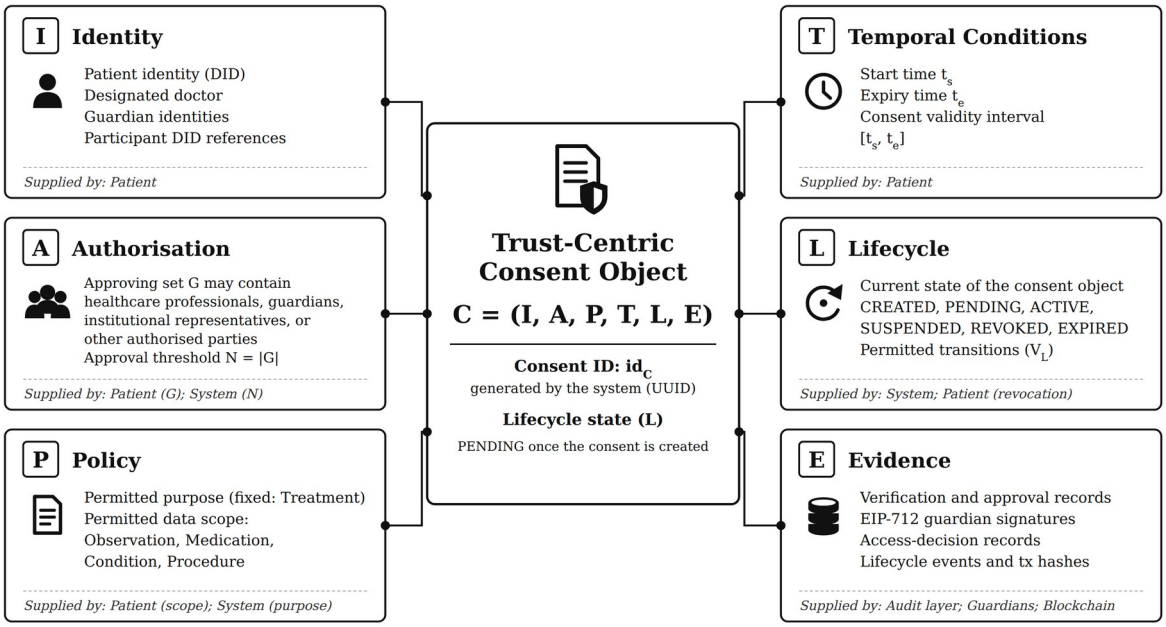



**Figure 6.2:** Six-component consent model C = (I, A, P, T, L, E)

Unlike the consent objects reported in the literature, this object carries the guardian set and threshold together with the purpose, data scope, validity interval, and lifecycle state.

## 6.4 Trust-Aware Consent Creation Procedure and Algorithm

The Trust-Aware Consent Creation procedure establishes a valid and auditable consent object by sequentially validating the participating entities, consent purpose, data scope, and temporal constraints before the consent is persisted. The procedure consists of the following steps.

- **Step 1 – Validate Patient Identity.** The system first validates the patient's identity Ip. The identity is checked against the available identity and credential verification mechanisms to ensure that the consent request originates from a recognised patient entity. If Ip cannot be successfully validated, the procedure terminates immediately and returns REJECT.
- **Step 2 – Validate the Authorised Doctor.** The system validates the identity and authorisation status of the designated doctor D. This step determines whether the doctor is a recognised healthcare participant and whether the presented credentials are sufficient for participation in the requested consent relationship. An invalid or unauthorised doctor results in rejection of the consent request.
- **Step 3 – Validate Guardian or Proxy Participants.** If a guardian or proxy is specified, the system validates the guardian set G. Each guardian is checked to determine whether the individual or entity possesses the required authority to participate in consent-related decisions. This step prevents an arbitrary third party from being treated as an authorised representative of the patient.
- **Step 4 – Validate the Intended Purpose.** The intended data-use purpose Pu is validated to ensure that the purpose is explicitly specified and conforms to the supported healthcare-use policies. The purpose is subsequently bound to the consent object so that authorisation is not interpreted as unrestricted access to the patient's healthcare information.
- **Step 5 – Validate the Data Scope.** The requested data scope SC is validated to determine precisely which healthcare resources may be accessed under the consent. The scope may

represent specific resource categories, such as observations, medications, procedures, or other resource categories. This step establishes the principle of least privilege by ensuring that consent is associated with explicitly defined data resources rather than the patient's entire healthcare record.

- **Step 6 – Validate the Consent Validity Interval.** The system validates the temporal validity interval T = (ts, te), where ts represents the consent start time and te represents the expiration time. The system verifies that the interval is logically valid by requiring te > ts. If this condition is not satisfied, the consent request is rejected.
- **Step 7 – Define the Authorisation Requirement.** After all input elements have been validated, the system defines the authorisation requirement A. This requirement specifies the conditions that must subsequently be satisfied before access can be granted. Depending on the system configuration, A may incorporate patient approval, guardian approval, doctor authority, role requirements, multi-party approval, scope restrictions, purpose restrictions, and temporal constraints.
- **Step 8 – Generate a Unique Consent Identifier.** The system generates a unique consent identifier idC. This identifier provides a persistent reference to the consent object and enables subsequent operations, including consent verification, access authorisation, modification, revocation, and audit.
- **Step 9 – Construct the Consent Object.** The validated information is combined to construct the consent object C = (I, A, P, T, L, E), where I represents the verified identity information, A represents the authorisation requirements, P represents the consent purpose and associated permissions, T represents the validity interval, L represents the lifecycle state, and E represents the evidence associated with the consent decision. The resulting object therefore captures not only the patient's preference but also the evidence required to support subsequent authorisation decisions.
- **Step 10 – Persist the Consent Object.** The constructed consent object C is persisted in the consent-management infrastructure. The persistence mechanism provides a stable representation of the consent state that can subsequently be referenced by the access-control and authorisation components.
- **Step 11 – Record Consent Creation Evidence.** Finally, the system records evidence associated with the creation event, including the consent identifier, participating entities, relevant timestamps, and the resulting consent state. This evidence provides an auditable record that can be used to reconstruct and verify the consent lifecycle.
- **Step 12 – Return the Consent Result.** If all validation and construction operations are completed successfully, the system returns the newly created consent object C. If any mandatory validation fails during the process, the system terminates the procedure and returns REJECT.

The overall procedure can therefore be represented as a sequential trust establishment process that Ip → D → G → Pu → SC → T → A → idC → C → E.

This sequence ensures that consent is created only after the relevant identity, authority, purpose, scope, and temporal constraints have been validated. Consequently, the resulting consent object serves not merely as a record of patient preference, but as a structured authorisation artefact that can provide evidence for subsequent healthcare data-access decisions.

**Algorithm 1** Trust-Aware Consent Creation

**Require:** Patient identity $I_p$, authorised doctor D, guardian set G, purpose $P_u$, data scope $S_C$, validity interval T
**Ensure:** Consent object C or rejection

```
Validate I_p
if I_p is invalid then
    return REJECT
end if
Validate authorised doctor D, guardian set G, purpose P_u and data scope S_C
if any of them is invalid then
    return REJECT
end if
Validate validity interval T = (t_s, t_e)
if t_e ≤ t_s then
    return REJECT
end if
Define authorisation requirement A
Generate consent identifier id_C
Construct C = (I, A, P, T, L, E)
Persist C
Record consent creation evidence
return C
```

Algorithm 1 formalises the creation process. The algorithm does not grant data access directly. Instead, it creates a consent object that can later be evaluated by the authorisation mechanism. The consent is placed in the PENDING state (PENDING_SIGNATURE in the prototype), and nothing is anchored on-chain until all guardians approve. The algorithm also establishes the relationship between RO1 and the remaining objectives. RO2 uses the identity and authority information contained in I, RO3 evaluates the authorisation requirements contained in A, and RO4 evaluates the policy constraints contained in P. Consequently, RO1 provides the data structure upon which the subsequent trust-oriented authorisation mechanisms operate.

## 6.5 Realisation in the Prototype

RO1 has been completed at the conceptual and prototype level, and the HALAH patient interface creates the consent object, assigns the identifier, and records the creation event in the audit layer. The main contribution of RO1 is that consent is represented as an evaluable authorisation object rather than as a binary permission. In the current prototype, the patient DID is selected from the loaded record set. The doctor DID and each guardian DID must be well formed and must hold a valid credential for its role, issued by a demo issuer, before the consent is stored, as qualified in Section 7. The validation evidence for consent creation, including the demonstration scenarios and the unit-level tests, is presented in Section 11. The next section presents the solution for RO2, which verifies who the participants are and what authority they hold.

Table 6.1 brings the validation of RO1 together by component of the consent object. For each component of C it gives the check that Algorithm 1 applies at creation, the evidence from the live scenarios and the automated tests of Section 11, and the result observed. It is a validation of the consent model, not its evaluation, which will be carried out when the full system is done.

Table 6.1: Validation results of the prototype for consent creation

| Component | Check at creation (Algorithm 1) | Evidence | Result |
|---|---|---|---|
| I Identity | Steps 1 to 3: the patient identity, the authorised doctor DID holding a valid doctor credential, and each guardian DID holding a valid guardian credential. | Since 11 October 2026, a doctor DID or a guardian DID without a valid credential for its role is refused before the consent is stored (Section 11.4). Attack A12 (Section 11.6). | Identifiers without a valid credential rejected before anything is stored; valid identifiers holding valid credentials accepted. |
| A Authorisation | Steps 3 and 7: the guardian set G, and the threshold N derived from it as \|G\|; no guardian may appear twice. | A guardian listed twice is refused (Section 11.4). Scenario 1 created consent f050c29a with two designated guardians. Attacks A1 and A3 (Section 11.6). | Duplicate guardian rejected; consent created with N set to the number of guardians. |
| P Policy | Steps 4 and 5: the purpose and the data scope; the data scope must not be empty. | A consent with an empty data scope is rejected (Section 11.4). Attack A5 (Section 11.6). Scenario 1 recorded the four EMR modules and the purpose Treatment. | Empty scope rejected; purpose and scope recorded in the consent object. |
| T Time | Step 6: the validity interval T = (ts, te); the expiry time must be later than the start time. | The expiry time must be later than the start time (Section 11.4). Attack A6 and the expiry run of 11 October 2026 (Section 10.3). | Validity interval recorded; the interval is enforced at every request by VT (Section 10). |
| L Lifecycle | Steps 8 to 10: the consent identifier is generated, the object is constructed and persisted, and its state becomes PENDING_SIGNATURE. | The functional tests check that a new consent starts as PENDING_SIGNATURE and is ACTIVE once both guardians have signed and the token is recorded, and that consents persist after a reload (Section 11.2). | Created in PENDING_SIGNATURE; no access is possible until the state is ACTIVE (Section 10). |
| E Evidence | Step 11: the CREATE_CONSENT event is written to the audit ledger with the consent identifier, participants and timestamp. | The creation events of f050c29a and 04da25f5 are in the exported audit ledger of Section 11.5, each with the result SUCCESS. Nothing is logged for a rejected specification. | Every creation is logged; a rejected specification stores and logs nothing. |

# 7. The Proposed Solution for RO2

## *RO2 – Decentralised Identity and Authority Trust*

**Status: Done**

This section presents the solution for RO2. Section 7.1 gives an overview of decentralised identity and authority trust, Section 7.2 shows the identity and authority verification workflow, Section 7.3 presents the verification model and the algorithm, and Section 7.4 describes how the verification is realised in the prototype.

## 7.1 Overview of Decentralised Identity and Authority Trust

RO2 addresses RQ2 by developing a decentralised identity and authority verification mechanism using Decentralised Identifiers and Verifiable Credentials. The objective is to establish trustworthy participants while separating identity authentication from authorisation authority. RO2 provides the trust inputs required by the subsequent multi-party authorisation process. The objective is based on the principle that successful identity verification does not automatically imply permission to access healthcare data. The central principle of RO2 is Equation (7.1).

$$\text{Identity} \neq \text{Authorisation}. \tag{7.1}$$

A valid DID provides an identity reference, while a valid VC provides evidence associated with a participant's role, authority, or other relevant attribute. Neither mechanism should automatically grant access to patient data. Instead, the verified identity and authority information become inputs to the subsequent authorisation process. The identity and authority verification condition can be expressed as Equation (7.2), where u is the requesting participant and Authority(u, C) establishes whether the verified authority matches the role required by the consent. The DID verification process establishes whether the identity reference is valid. In the current prototype this check is structural, as Section 7.4 explains. The VC verification process establishes whether the participant possesses valid authority evidence. The final authorisation decision remains dependent on the consent requirements and access policy.

$$V_I(u) = \text{VerifyDID}(u) \wedge \text{VerifyVC}(u) \wedge \text{Authority}(u, C). \tag{7.2}$$

## 7.2 Identity and Authority Verification Workflow

The workflow begins when a participant attempts to participate in the consent process or requests access to healthcare data. The system resolves and verifies the participant's DID and then retrieves the associated VC. The credential is checked for validity and its claims are examined to determine whether the participant possesses the authority required by the consent. In the HALAH implementation, the Guardian workflow uses a selected guardian DID and invokes VC verification before adding the guardian's signature to the consent. As shown in Figure 7.1, the output of RO2 is not an access-grant decision. It is a verified identity and authority result that can be consumed by RO3 and RO4. This separation prevents a participant from obtaining access merely by presenting a valid identity credential.

Figure 7.1 shows the target design. Full DID resolution is planned for the next stage, whereas the current prototype performs a DID-format check, a check of a demo-issuer credential and EIP-712 signature recovery.

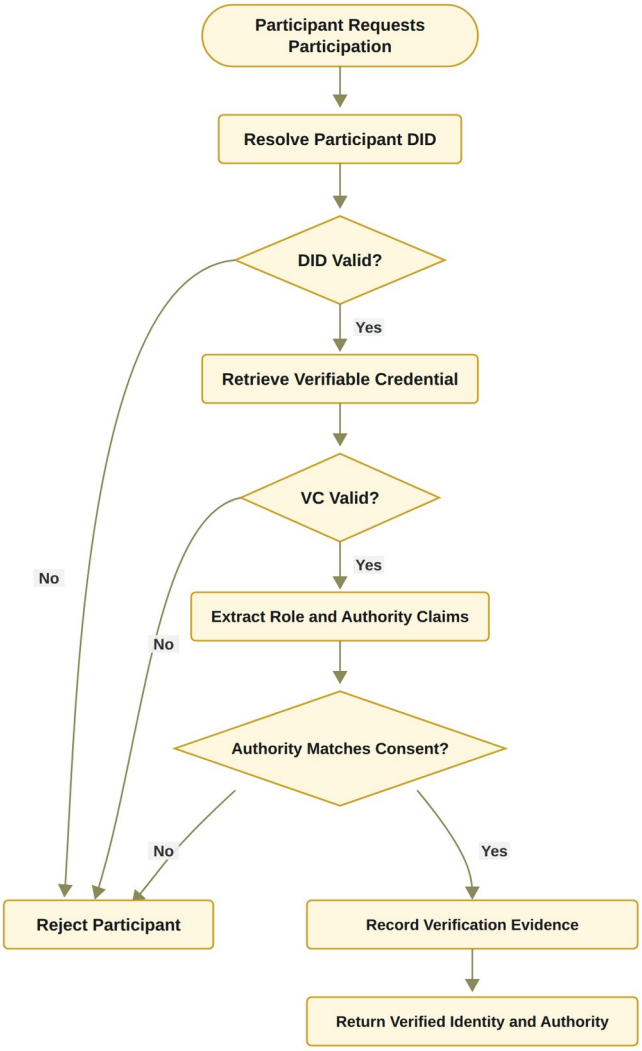



**Figure 7.1:** RO2 workflow for decentralised identity and authority verification

## 7.3 Verification Model and Algorithm

The procedure establishes a verifiable relationship between the participant u, the identity information represented by the DID, the attributes contained in the associated VC, and the authority requirements specified by the consent object C. The system first resolves the decentralised identifier (DID) associated with participant u. The system verifies the DID document and whether the relevant cryptographic information, such as verification methods and public keys, can be trusted. The VC provides machine-verifiable claims, such as professional role, organisational affiliation, or delegated authority. Formally, the credential can be considered valid only when $VC_{valid} = Sig_{VC} \wedge Issuer_{valid} \wedge Subject_{match} \wedge Time_{valid}$. The system determines whether the credential was issued by an acceptable issuer, whether it refers to the current participant, whether its signature is valid, and whether the credential remains within its validity period. If any of these conditions fails, the verification process returns INVALID.

The system extracts the relevant role and authority claims associated with participant u. These claims may identify a doctor, guardian, researcher, auditor, or another authorised participant. The extracted claims are compared against the authorisation requirements specified in the consent object C. The authority verification condition can therefore be represented as $Authority(u, C) = Claims(u) \models A_C$, where Claims(u) denotes the verified claims, and $A_C$ denotes the authority requirements defined by consent object C. The system establishes the binding between the verified participant identity and the

corresponding authority, thereby reducing the possibility of an unrelated credential being used to obtain access. Consequently, the procedure can be interpreted as a two-layer verification mechanism, $\text{VerifyDID}(u) \land \text{VerifyVC}(u) \land \text{Authority}(u, C) \Rightarrow V_I(u) = 1$, where VALID corresponds to $V_I(u) = 1$ and INVALID to $V_I(u) = 0$. A participant is not considered valid merely because a DID can be resolved or because a VC has a valid cryptographic signature. The overall verification process can therefore be represented as $\text{DID}_{\text{resolve}} \rightarrow \text{DID}_{\text{verify}} \rightarrow \text{VC}_{\text{retrieve}} \rightarrow \text{VC}_{\text{verify}} \rightarrow \text{Claims}_{\text{extract}} \rightarrow \text{Authority}_{\text{match}} \rightarrow \text{Evidence}_{\text{record}} \rightarrow V_I(u)$.

Algorithm 2 formalises the procedure. If DID resolution, DID verification, VC retrieval, VC verification, and authority validation are all successfully completed, the system returns $V_I(u) = \text{VALID}$. Otherwise, the procedure terminates at the first failed mandatory verification condition and returns $V_I(u) = \text{INVALID}$. The system records the evidence. The evidence may include the resolved DID, verification status, credential identifier, issuer information, relevant authority claims, and verification timestamp. This evidence provides an auditable basis for subsequent access-authorisation decisions.

**Algorithm 2** DID and VC Identity and Authority Verification

**Require:** Participant u, consent object C
**Ensure:** Verification result $V_I(u) \in \{\text{VALID}, \text{INVALID}\}$, where VALID corresponds to $V_I(u) = 1$

```
Resolve DID of u
if DID resolution fails then
    return INVALID
end if
Verify DID document and associated identity information
if DID verification fails then
    return INVALID
end if
Retrieve VC associated with u
if VC retrieval fails then
    return INVALID
end if
Verify VC signature, issuer, subject, and validity
if VC verification fails then
    return INVALID
end if
Extract role and authority claims from VC
if claims do not satisfy the authority requirements of C then
    return INVALID
end if
Record identity and authority verification evidence
return VALID
```

Algorithm 2 establishes that identity verification and authority verification are related but distinct operations. A participant may possess a valid DID while lacking the authority required by the consent. Similarly, a credential may be structurally valid but irrelevant to the specific authorisation requirement. Therefore, the algorithm verifies both credential validity and authority relevance. This mechanism turns identity and authority claims into verifiable evidence. However, it does not independently establish collective consent or policy compliance. Those conditions are evaluated by RO3 and RO4 (Sections 8 and 9).

## 7.4 Realisation in the Prototype

RO2 has been completed at the conceptual and prototype level. The current implementation demonstrates the separation between participant identity and authorisation authority. A valid healthcare participant identity can be verified independently from the question of whether that participant is authorised to access a particular patient's data. Each credential used by the prototype comes from a demo issuer, and the

check covers the four conditions of $VC_{valid}$, namely the signature, issuer, subject and validity time, together with the role claim. The doctor and guardian credentials are checked when the consent is created. Each guardian's credential is checked again before the guardian signs, as Section 7.2 describes, and the doctor's credential is checked again at each access request, where the DID that the doctor enters must also be the doctor named in the consent. $V_I$ in the current prototype combines this doctor check with EIP-712 verification of the signature of each listed guardian, and its outcome is recorded in the audit ledger. A request that fails $V_I$ is refused before any data is released, and the refusal is recorded. An invalid or forged credential is also refused (attack scenario A12). Because the demo issuer key can be rebuilt from the source code, this check shows the verification steps, not the secrecy of the issuer key. The prototype also derives each guardian's signing key from the guardian DID. Full DID resolution against a registry (Algorithm 2, lines 1 to 8), proof that the user controls the DID entered, and wallet-held keys are acknowledged limitations reserved for the next stage. The validation evidence for RO2, including the scenarios and the unit-level adversarial tests, is presented in Section 11. The next section presents the solution for RO3, the multi-party approval of the consent.

# 8. The Proposed Solution for RO3

### *RO3 – Trustworthy Multi-Party Authorisation*

**Status: Done**

RO3 directly addresses RQ3 and extends the consent model from an individual permission statement to a collective authorisation decision. RO3 introduces threshold-based multi-party authorisation for consent approval to prevent a single participant from unilaterally establishing sensitive healthcare data access when the consent requires several independently verified parties. Section 8.1 defines the threshold condition, Section 8.2 shows the multi-party authorisation workflow, Section 8.3 gives the procedure and the algorithm, and Section 8.4 states the outcome of RO3.

## 8.1 Threshold Condition

Let $A_v$ represent the set of independently verified authorisation participants and N represent the required approval threshold. The authorisation condition can then be represented as Equation (8.1), where Token(C) and Revoked(C) are defined as in Section 5.3.

$$V_A(C) = 1 \text{ if } |A_v| \geq N \wedge \text{Token}(C) \neq \varnothing \wedge \text{Revoked}(C) = 0, \text{ and } 0 \text{ otherwise.} \quad (8.1)$$

This mechanism allows the framework to distinguish between insufficient and sufficient collective authorisation. For example, a consent may require two valid guardian approvals. In this case, one valid approval is insufficient, whereas two valid approvals satisfy the threshold. Decentralised identity systems with multi-party verification strengthen the way identity claims are established and validated. Nevertheless, multi-party verification of identity should not be considered equivalent to multi-party authorisation of data access. The first concerns whether an identity claim can be trusted, whereas the second concerns whether a group of independent participants has collectively established a valid permission decision.

The N-of-N configuration was adopted for the prototype because it is the most conservative instantiation of the threshold condition, in which no designated guardian can be bypassed, and it also avoids the quorum-selection and key-management questions that a general k-of-n threshold introduces. A configurable k-of-n threshold is a direct generalisation of the implemented mechanism and is therefore left to future work.

## 8.2 Multi-Party Authorisation Workflow

The workflow first identifies the participants required by the consent. Each participant must submit an approval that can be independently verified. Invalid approvals are rejected and must not contribute to the threshold count. The authorisation becomes active only when the number of valid approvals reaches the required threshold. In the HALAH implementation, as shown in Figure 8.1, the guardian workflow verifies the guardian VC and then the EIP-712 signature. It then appends the guardian DID to the consent signatures and displays the current approval count relative to the threshold. The code therefore demonstrates the separation between participant identity verification and the subsequent authorisation operation. When the threshold is reached, the implementation assigns an SBT identifier and records the corresponding minting event. Figure 8.1 shows the three checks of Algorithm 3 in the same order. It joins the three rejections into one box and shows activation last, after the token and the evidence. The dashed box shows that the mint on Sepolia runs in the background, so it does not delay the guardians or the doctor. In the prototype, the consent becomes active once its start time is reached.

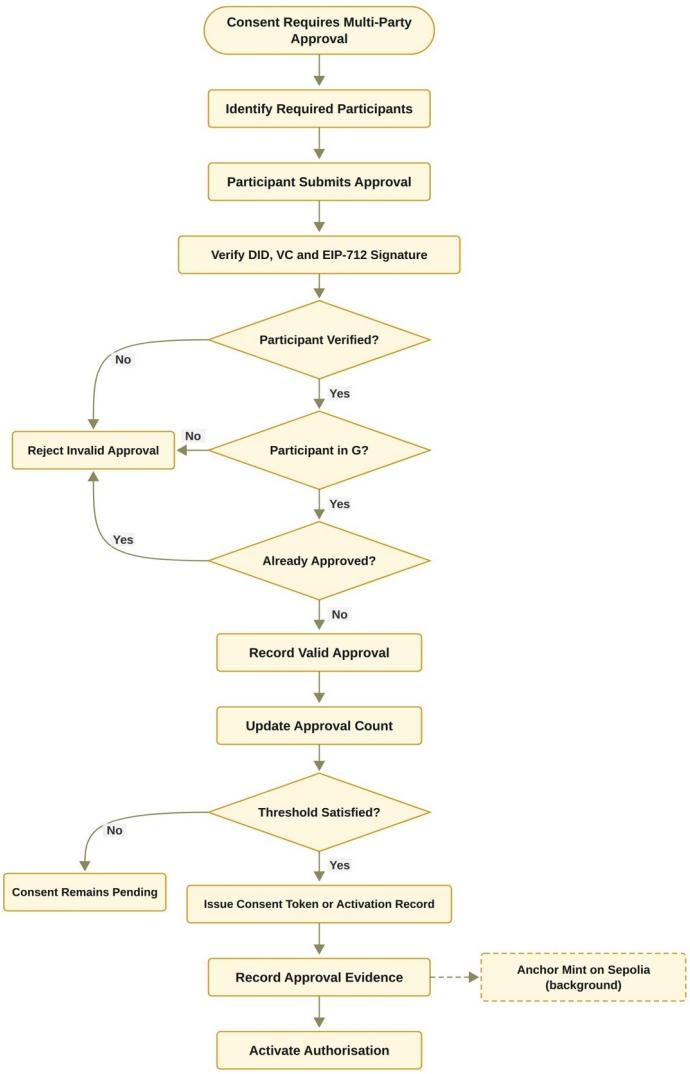



**Figure 8.1:** RO3 workflow for threshold-based multi-party authorisation.

The SBT should be interpreted as an activation mechanism for the consent state rather than as the fundamental source of trust. The trust decision is established by the verification of participants and the satisfaction of the authorisation threshold. The blockchain layer provides persistence, traceability, and evidence of the resulting state.

In the HALAH implementation, guardian authority is evidenced by an EIP-712 typed-data signature bound to the consent identifier, the guardian DID, and the Sepolia chain identifier, and verified through off-chain signer recovery. The preceding VC verification checks the signature, issuer, subject, validity time and role of the guardian's credential, and a refused credential is recorded in the audit ledger. The signing keys are derived deterministically from the guardian DIDs rather than held in wallets, which is a limitation of the prototype. At access time, the recovery is repeated for every recorded signature within the identity predicate $V_I$. $V_A$ then counts only the distinct approvals of the members of G against N, and it checks the token identifier and the revocation flag.

## 8.3 Procedure for Threshold-Based Multi-Party Authorisation

The procedure determines whether a consent-defined authorisation requirement has received sufficient valid approvals from the designated participants. The system first retrieves the required participant set G associated with the consent object C. The set G defines which participants are eligible to contribute an

approval to the authorisation process. Depending on the consent configuration, G may contain healthcare professionals, guardians, institutional representatives, or other authorised parties. The system obtains the threshold value N, which specifies the minimum number of valid and distinct approvals required to activate the authorisation. The threshold must satisfy $1 \leq N \leq |G|$. The threshold therefore determines how many eligible participants must independently approve the consent before the authorisation becomes active. The approval a is not considered valid until the identity and authority of the submitting participant have been verified. The verification process may invoke the DID and VC verification procedure described in Algorithm 2. If the verification fails, the approval is classified as invalid. The system records the invalid approval event and returns DENY for that approval attempt.

The system then determines whether the participant belongs to the required participant set G ($g \in G$). If the participant is not a member of G, the system records the event as an unauthorised approval attempt and returns DENY. The system checks whether the participant has already approved consent object C. This prevents a single participant from submitting multiple approvals and artificially satisfying the threshold. Only approvals that have passed identity, authority, membership, and duplicate checks are counted, and the corresponding participant g is added to $A_v$, according to $A_v \leftarrow A_v \cup \{g\}$.

If $|A_v| \geq N$, the required threshold has been satisfied. The system activates the authorisation associated with consent object C. Following successful threshold satisfaction, the system generates activation or token evidence associated with the authorisation decision. The evidence may include the consent identifier, threshold value N, identities of the approving participants, and approval timestamps. The system records a threshold-satisfied event. If $|A_v| < N$, the system maintains the consent in a PENDING state and records a threshold-pending event so that the remaining approval requirement can be reconstructed during subsequent verification or audit. The overall procedure can therefore be represented as Equation (8.2).

$$G \rightarrow N \rightarrow a \rightarrow \text{Identity/Authority} \rightarrow \text{Eligibility} \rightarrow \text{Duplicate Check} \rightarrow A_v \rightarrow |A_v| \geq N \rightarrow \{ \text{ ALLOW, PENDING } \} \tag{8.2}$$

The threshold is not calculated from the number of submitted approvals alone. Instead, only valid, authorised, eligible, and non-duplicate approvals contribute to the threshold. Consequently, an arbitrary number of unverified or unauthorised approvals cannot satisfy the multi-party authorisation requirement. An individual approval represents one participant's contribution to the decision, whereas authorisation is activated only when the collective evidence satisfies the predefined threshold. From a trust perspective, the procedure can therefore be interpreted as Equation (8.3).

$$\text{Individual Trust Evidence} \rightarrow \text{Collective Approval Evidence} \rightarrow \text{Threshold Satisfaction} \rightarrow \text{Authorisation Activation} \tag{8.3}$$

Algorithm 3 explicitly distinguishes between invalid, duplicate, and valid approvals. This distinction is important because simply counting submitted signatures could incorrectly treat unauthorised or repeated approvals as independent evidence.

**Algorithm 3** Threshold-Based Multi-Party Authorisation

**Require:** Consent object C, participant approval a, threshold N
**Ensure:** Authorisation result

```
Retrieve required participant set G
Verify identity and authority of participant submitting a
if verification fails then
    Record invalid approval
    return DENY
end if
if participant is not in G then
    Record unauthorised approval attempt
    return DENY
end if
if participant has already approved C then
    Record duplicate approval
    return DENY
end if
Record valid approval a
Update valid approval set A_v
if |A_v| ≥ N then
    Activate authorisation
    Generate activation or token evidence
    Record threshold-satisfied event
    return ALLOW
else
    Keep consent in pending state
    Record threshold-pending event
    return PENDING
end if
```

The algorithm also shows that multi-party authorisation is a trust mechanism, not a user-interface feature. The final decision depends on independently verified participants and a predefined collective requirement. Therefore, a single participant cannot unilaterally activate the consent when the threshold has not been satisfied. In the prototype, the on-chain mint is submitted as a background job through the owner account, and the contract stores keccak256($P_u$) rather than the purpose itself. Activation is distinct from the access decision. This mechanism complements the DID/VC verification procedure in Algorithm 2. Algorithm 2 establishes whether an individual participant possesses a valid identity and sufficient authority, whereas Algorithm 3 determines whether a sufficient number of independently verified participants have collectively satisfied the consent-defined authorisation requirement. The resulting activation evidence can subsequently be consumed by the policy and scope enforcement layer described in Section 9.

## 8.4 Outcome of RO3

RO3 has been completed at the conceptual and prototype level. If the threshold is not satisfied, the consent cannot be used to authorise the requested access, as stated in Equation (8.4).

$$|A_v| < N \Rightarrow \text{Decision}(C, R, t) = \text{DENY}. \tag{8.4}$$

The prototype demonstrates that a consent object remains unable to establish valid authorisation until the required number of independently verified participants has approved it. For example, where N = 2, Equation (8.5) holds for a consent that has a token identifier and has not been revoked, whereas Equation (8.6) holds when only one valid approval has been given.

$$|A_v| = 2 \wedge \text{Token}(C) \neq \varnothing \wedge \text{Revoked}(C) = 0 \Rightarrow V_A(C) = 1, \tag{8.5}$$

$$|A_v| = 1 \Rightarrow V_A(C) = 0. \tag{8.6}$$

This provides preliminary evidence that the proposed framework can enforce collective rather than unilateral authorisation. The implemented threshold is derived from the designated guardian set as N = |G|, and the prototype therefore enforces an N-of-N instantiation of Equation (8.1) and has been evaluated in the 2-of-2 configuration. The unit-level adversarial tests include an approval from a signer outside G and a repeated approval from the same guardian, and before the hardening of 1 October 2026, both attacks were blocked only by the interface. However, since that hardening, the decision rule and the lifecycle evaluation count only distinct approvals from members of G towards N, and both attacks are refused. Section 11 presents the corresponding scenarios and test results. The next section presents the solution for RO4, which checks the purpose and the data scope of each request.

# 9. The Proposed Solution for RO4

### *RO4 – Policy- and Context-Aware Access Control*

**Status: Done**

RO4 directly addresses RQ4 and completes the foundational authorisation model investigated during the current stage. The objective is to ensure that an otherwise valid requester cannot access healthcare information outside the purpose and data scope authorised by the consent. RO4 develops a policy-aware access-control mechanism capable of evaluating purpose and data-scope constraints before an access decision is issued. The objective is based on the observation that a valid identity and sufficient approval do not necessarily imply that every requested operation is permitted. A doctor may be a legitimate participant and may possess a valid consent, but the requested data may exceed the authorised scope or the requested purpose may not match the purpose specified by the patient. Section 9.1 defines the scope and policy conditions, Section 9.2 shows the policy-aware access workflow, Section 9.3 gives the decision algorithm, Section 9.4 qualifies what the prototype checks, and Section 9.5 states the outcome of RO4.

## 9.1 Scope and Policy Conditions

The system evaluates whether the requested data scope $S_R$ is non-empty and contained within the data scope authorised by the consent, denoted by $S_C$, and Equation (9.1) defines the scope condition $V_S$.

$$V_S(C, R) = 1 \iff S_R \neq \varnothing \wedge S_R \subseteq S_C. \tag{9.1}$$

The policy condition can therefore be expressed as Equation (9.2) where $V_U(C, R)$ represents purpose compatibility and $V_S(C, R)$ represents data-scope compatibility.

$$V_P(C, R) = V_U(C, R) \wedge V_S(C, R). \tag{9.2}$$

At every access request, the system performs the final policy evaluation, and access can proceed only when all required conditions evaluate to true, namely the five verification predicates in Equation (9.3). If any of these conditions is false, the request is denied. This creates a conjunctive trust model in which the failure of any required condition prevents the final authorisation decision. In the current version, each request, whatever the state of the consent, has its decision matrix recorded in the audit ledger with the GRANTED or DENIED outcome, although the three earliest grants of 22 September 2026 predate this logging. Both successful and denied decisions should be recorded, because accountability covers the data that were released and the access attempts that were rejected.

$$\text{Decision}(C, R, t) = \text{ALLOW} \iff V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L \tag{9.3}$$

In the prototype, the matrix column $V_P$ records the purpose check $V_U$ only, while the scope condition $V_S$ is evaluated separately by the scope check of the doctor subsystem at request time. The lifecycle condition VL of Equation (9.3) corresponds to the requirement that the consent state be ACTIVE. The final decision therefore combines the decision matrix with that scope check, with the ACTIVE-state check and with the verified access proof.

## 9.2 Policy-Aware Access Workflow

The workflow begins when a doctor submits a request for patient data. The system retrieves the consent object and verifies the requesting participant. It then checks whether the required multi-party authorisation has been established. After the identity and authorisation conditions are satisfied, the system evaluates the consent purpose and the requested data scope. The HALAH implementation provides a concrete basis for this objective. In the prototype, the Doctor interface retrieves a consent, checks that the requester's DID holds a valid doctor credential and is the doctor named in the consent,

evaluates the consent state, allows a requested scope to be selected from the consent scope, generates a proof, checks the requested scope, and invokes the authorisation function before returning data. Figure 9.1 shows the workflow. It has the same checks as Algorithm 4, but it checks the consent state before the identity, and it shows the validity interval and the Groth16 proof as separate steps. If any check fails, access is denied and the denial is recorded in the audit ledger. In the prototype, as in Algorithm 4, a requester who fails $V_I$ is refused first. Suppose that a consent permits access to the data categories given in Equation (9.4), and a healthcare professional then requests the categories given in Equation (9.5).

In the current prototype, every access decision, allowed or denied, is recorded in the audit ledger, the requested purpose is the consent purpose.

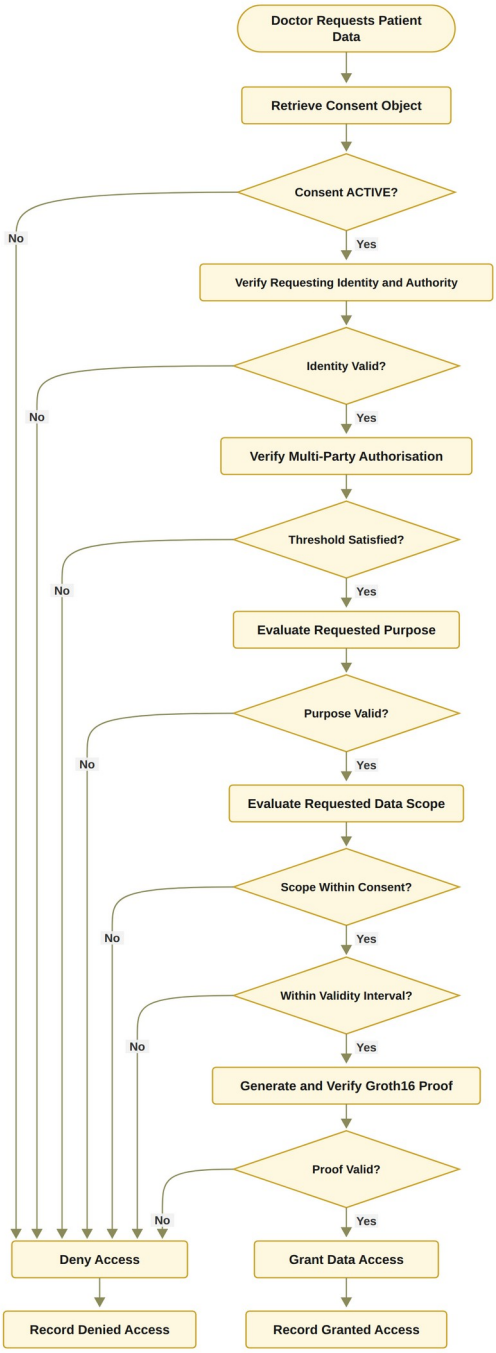



**Figure 9.1:** RO4 workflow for policy- and context-aware access control

$$S_C = \{\text{Observation, Medication}\}, \tag{9.4}$$

$$S_R = \{\text{Observation, Medication, Procedure}\}. \quad (9.5)$$

In this case, Equation (9.6) holds, and the request must be denied. This rule prevents a legitimate participant from obtaining data outside the patient's authorised scope. If the requested data exceeds the authorised scope, the request must be rejected even if the requester has successfully authenticated and the required number of participants has approved the consent. Authorisation to access one category of healthcare information does not imply authorisation to access all categories of the patient's record.

$$S_R \not\subseteq S_C. \quad (9.6)$$

## 9.3 Policy-Aware Access Decision Algorithm

Rather than treating successful authentication as sufficient for access, Algorithm 4 evaluates the complete set of conditions defined by the consent and applicable access-control policies. If any mandatory condition fails during the evaluation process, the system returns DENY and records the corresponding denial evidence. In the prototype, this also holds for a consent that is not ACTIVE and for an empty request.

**Algorithm 4** Policy-Aware Access Decision

**Require:** Consent object C, access request R, requesting participant u
**Ensure:** Access decision

```
Verify DID and VC of u
if identity or authority verification fails then
    Record denied decision
    return DENY
end if
Evaluate consent state
if consent is not active then
    Record denied decision
    return DENY
end if
Verify multi-party authorisation
if threshold is not satisfied then
    Record denied decision
    return DENY
end if
Evaluate requested purpose
if purpose is incompatible with consent then
    Record denied decision
    return DENY
end if
Evaluate requested data scope
if S_R ⊄ S_C then
    Record denied decision
    return DENY
end if
Generate or verify access evidence
Retrieve authorised healthcare data
Record granted decision
return ALLOW
```

The algorithm demonstrates that policy evaluation is performed after identity and multi-party authorisation verification but before data release. This ordering prevents the system from treating identity validity or collective approval as unrestricted permission. A successfully authenticated participant is not automatically granted access. The system must not only determine whether a consent exists, but also evaluate whether the current request satisfies the consent's scope and purpose constraints. The decision is based on the conjunction of identity validity, active consent, sufficient multi-party approval, purpose

compatibility, scope containment, and temporal validity. Once the request has been successfully authorised, the system retrieves only the healthcare data satisfying the authorised scope, so that the returned data remain a subset of $S_C$. This prevents a mismatch between the policy decision and the actual data returned to the requester. Both granted and denied requests should be recorded to support accountability and auditability.

## 9.4 Implementation Qualifications

If the policy evaluation succeeds, the system requires the evidence supporting the access decision to be a Groth16 zero-knowledge proof that has verified. In the prototype, the doctor subsystem generates and verifies this proof after the decision matrix has been evaluated, and the decision combines the two. The circuit is written in circom (iden3 2026b), and the proof is generated and verified with snarkjs (iden3 2026a). The proof shows that the prover knows the secret and the expiry time behind a Poseidon commitment (Grassi et al. 2021) held in the application's consent record, and that the consent has not expired at time t. The proof mode is recorded with the decision in the audit ledger, and the proof constitutes the access evidence required by Algorithm 4 before any data are retrieved. This evidence provides an auditable relationship between the access request and the conditions that justified the resulting authorisation.

In the demonstrated prototype, the doctor does not declare a separate request purpose. The consent purpose is validated to ensure that the purpose is explicitly specified and conforms to the supported healthcare-use policies of Treatment, Research, and Emergency. The purpose is subsequently bound to the consent object as keccak256(purpose) stored on-chain. Consequently, $V_P$ does not yet compare the purpose specified in the access request with the purpose permitted by the consent object. The formal analysis showing that there is no execution path where the system can violate the privacy policy will be conducted as part of next stage works.

The denial for a consent that is not ACTIVE is reported in the doctor interface and is written to the audit ledger in the current prototype. Every request produces the STATE_CHECK and DATA_ACCESS records, whether the decision is GRANTED or DENIED, and the refusal that follows revocation is therefore evidenced by a ledger row as well as by the interface and the automated tests.

## 9.5 Outcome of RO4

RO4 has been completed at the conceptual and prototype level. RO4 represents the third layer of the framework beyond identity and multi-party approval. In the formal model, $V_P$ evaluates to 0 for the over-scope request given above, and the prototype refuses such a request with the scope named as the failed check. The interface itself allows a requested scope to be selected from the consent scope only. The unit-level adversarial tests verify that a participant cannot obtain healthcare resources outside the scope authorised by the patient's consent, even when the participant possesses a valid identity and authority credential. The adversarial test set matters because a framework must show that legitimate requests succeed and that foreseeable attempts to bypass its security controls fail. An empty request scope was blocked only by the interface before the hardening of 1 October 2026, and it is now also refused by the scope check itself.

Every denial is shown in the interface together with the decision matrix of the request. Each consent specification and access request is accepted only when the required fields are valid. Malformed guardian identifiers and empty scopes therefore do not reach the decision logic, and the doctor and each guardian must hold a valid credential with the right role before the consent is created. The procedure also implements the principle of least privilege through the explicit scope-containment condition $S_R \subseteq S_C$. Consequently, even when a participant possesses a valid DID, a valid VC, and sufficient authority, the participant cannot retrieve healthcare resources outside the scope explicitly authorised by the consent.

Similarly, a valid consent cannot be used for an unsupported purpose or before the required multi-party authorisation threshold has been reached.

From an architectural perspective, Algorithm 4 therefore acts as the final policy-enforcement layer of the proposed authorisation lifecycle. Algorithm 1 establishes the consent constraints, Algorithm 2 establishes trustworthy identity and authority evidence, and Algorithm 3 establishes collective authorisation evidence. Algorithm 4 integrates these evidence sources with the specific access request and determines whether the requested healthcare data can actually be released. This architecture transforms healthcare data access from a simple credential-based permission check into an evidence-based authorisation process. Consent therefore becomes an active authorisation constraint rather than a historical indication that a participant was once granted permission. This policy-centric approach also provides a basis for future extensions. While the current stage implementation focuses on purpose and healthcare data scope, the same mechanism can subsequently incorporate additional contextual conditions, including location, organisation, treatment relationship, emergency status, and other regulatory constraints. Section 11 demonstrates on the live system that a request is permitted only when the requested data scope is contained within the authorised scope. The next section presents the solution for RO5, which keeps a consent valid only within its time interval and lifecycle state.

# 10. The Proposed Solution for RO5

## *RO5 – Temporal and Lifecycle Trust*

**Status: Not done (in progress)**

RO5 addresses RQ5 and extends the foundational authorisation model with temporal validity and consent lifecycle controls. This objective was originally planned for the next stage because it investigates how an authorisation remains trustworthy as time passes and as the consent state changes. The objective is to ensure that an authorisation remains valid only within its permitted time interval and lifecycle state. It must also ensure that expiration, revocation, and unauthorised state transitions are correctly enforced. Section 10.1 defines the temporal and lifecycle conditions, Section 10.2 presents the validation algorithm, Section 10.3 describes the controls that are already implemented, and Section 10.4 sets out the remaining work and the expected outcome.

## 10.1 Temporal and Lifecycle Trust Conditions

A consent that is valid at one point in time cannot necessarily be assumed to remain valid indefinitely. The system compares the current time t with the consent validity interval, and Equation (10.1) defines the temporal predicate $V_T$.

$$V_T(C, t) = 1 \text{ if } t_s \leq t \leq t_e, \text{ and } 0 \text{ otherwise.} \tag{10.1}$$

Temporal validity must also be evaluated together with the lifecycle state of the consent. The lifecycle can be represented as

$$\text{Specification} \rightarrow \text{Verification} \rightarrow \text{Approval} \rightarrow \text{Active} \rightarrow \text{Expiration/Revocation.} \tag{10.2}$$

Typical lifecycle states may include CREATED, PENDING, ACTIVE, SUSPENDED, REVOKED, and EXPIRED, depending on the system configuration. The current state is used to determine whether the requested operation q can legally and logically be performed. Different operations may be permitted only in specific lifecycle states. For example, activation may require a consent to be in a pending state, while data access may require the consent to be active. The state transition condition can be represented as

$$\text{State}(C) \vDash q. \tag{10.3}$$

If the consent is temporally valid, in an appropriate lifecycle state, and has not been revoked, the system validates the requested transition q. The transition is evaluated against the predefined lifecycle-transition policy:

$$\text{State}(C) \rightarrow^{q} \text{State}'(C). \tag{10.4}$$

The transition is valid only when q is explicitly permitted from the current state. The lifecycle validity predicate can therefore be represented as

$$V_L(C) = \text{ValidState}(C) \wedge \text{ValidTransition}(C). \tag{10.5}$$

An authorisation decision consequently requires both temporal and lifecycle validity. A consent that has expired, has been revoked, or has entered an invalid state must not be treated as an active authorisation even when its original identity, authority, and approval conditions were valid. The extended authorisation decision is therefore given by Equation (10.6). A valid authorisation decision requires the simultaneous satisfaction of all relevant trust conditions. Consequently, failure of any individual condition results in denial.

$$\text{Decision}(C, R, t) = \text{ALLOW} \Leftrightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R) \wedge V_T(C, t) \wedge V_L(C). \tag{10.6}$$

Authorisation is not permanent. A consent that was valid when approved can later become invalid through expiration or revocation. RO5 is therefore more than an expiry field. It is to ensure that the

validity of a consent depends on both its temporal interval and its current lifecycle state. A consent that has expired or been revoked must not remain usable merely because its original approval threshold was satisfied. The existence of a consent record in the system does not imply that the consent remains effective.

## 10.2 Temporal and Lifecycle Validation Algorithm

Algorithm 5 formalises the temporal and lifecycle validation, so that consent validity is dynamic rather than permanent. The algorithm receives the consent object C, the current time t and the requested transition q, which is the change of lifecycle state being asked for. It returns VALID when the consent can still be used at time t and in its current state, and INVALID when it cannot.

**Algorithm 5** Temporal and Lifecycle Validation

**Require:** Consent object C, current time t, requested transition q
**Ensure:** Lifecycle validity result

```
1:  Retrieve consent start time t_s and expiry time t_e
2:  if t < t_s or t > t_e then
3:      Record temporal invalidity
4:      return INVALID
5:  end if
6:  Retrieve current lifecycle state of C
7:  if current state does not permit the requested operation then
8:      Record invalid lifecycle state
9:      return INVALID
10: end if
11: Check whether C has been revoked
12: if C is revoked then
13:     Record revocation-based invalidity
14:     return INVALID
15: end if
16: Validate requested transition q
17: if transition q is not permitted then
18:     Record unauthorised state transition
19:     return INVALID
20: end if
21: Record valid temporal and lifecycle evidence
22: return VALID
```

Line 1 reads the start time $t_s$ and the expiry time $t_e$ of the consent. If t is before $t_s$ or after $t_e$, lines 2 to 5 record temporal invalidity and return INVALID. This is the temporal predicate $V_T$ of Equation (10.1). Line 6 reads the current lifecycle state of C, and lines 7 to 10 check whether this state permits the requested operation. For example, data access is permitted only when the consent is ACTIVE. If the state does not permit it, the algorithm records an invalid lifecycle state and returns INVALID. Lines 11 to 15 check whether C has been revoked. A revoked consent must not be used even if it was approved before, so the algorithm records revocation-based invalidity and returns INVALID. Lines 16 to 20 validate the requested transition q against the lifecycle-transition policy of Equation (10.4). If q is not permitted, the algorithm records an unauthorised state transition and returns INVALID. Lines 6 to 10 check ValidState(C) and lines 16 to 20 check ValidTransition(C), the two parts of $V_L$ in Equation (10.5). When all checks pass, line 21 records the temporal and lifecycle evidence, and line 22 returns VALID, so that the system continues with the remaining authorisation conditions of Equation (10.6).

## 10.3 Implemented Temporal and Lifecycle Controls

Figure 10.1 presents the RO5 workflow, which shows Algorithm 5 as a flowchart. It evaluates the consent's temporal interval, lifecycle state, and revocation status before the system proceeds with the

remaining authorisation conditions. If any check fails, access is denied and a lifecycle-based denial is recorded. The transition check is drawn with dashed lines because it is planned for the next stage. This design ensures that a consent is not treated as permanently valid after it has expired or entered a state that no longer permits access. Temporal conditions and lifecycle state are represented in the Model, while their validity is evaluated by the Controller before an access decision is produced. The Consent Engine evaluates $V_T$, derives the lifecycle state from the application record and evaluates $V_L$ as ValidState(C), which passes only when this state is ACTIVE. A consent that is not ACTIVE also fails $V_A$ or $V_T$, so $V_L$ does not yet refuse a request on its own. The Consent Engine also checks the revocation flag and the token within $V_A$, whereas the independent verification tool reads checkValid and checkValidAt on the deployed contract, which stores the notBefore and expiry fields.

Figure 10.1 is Algorithm 5 as a flowchart, where the dashed transition check is planned for the next stage.

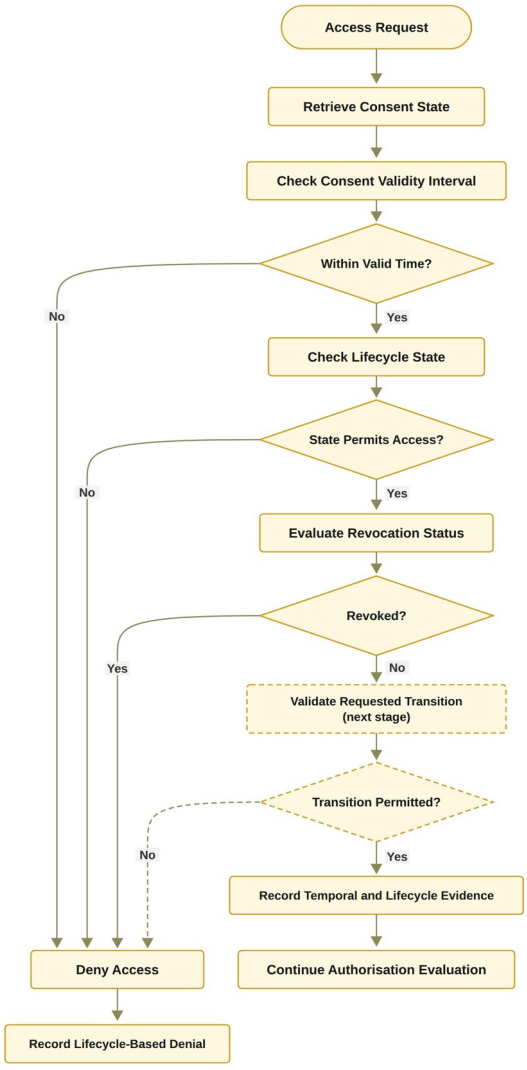



**Figure 10.1:** RO5 workflow for temporal and consent lifecycle trust

In the current prototype, Algorithm 5 is implemented except for the transition check of lines 16 to 20. The prototype works with six lifecycle states, listed below, and access can be granted only in the ACTIVE state. The validity interval, the lifecycle state and the revocation status are checked at every access request. The Consent Engine covers all three when it derives the lifecycle state, so the order of the checks in Figure 10.1 does not change the decision. The evidence of lines 3, 8, 13 and 21 is the STATE_CHECK

event in the audit ledger, described below. The next stage adds the transition check, which gives ValidTransition(C) in Equation (10.5), together with the SUSPENDED state, consent modification, delegation, guardian-set changes and a formal lifecycle model (Section 10.4).

The current HALAH code already collects a start time and expiry time during consent creation, and three elements of RO5 are now enforced.

- **Temporal validity.** At every access request, the system compares the current time t with the consent validity interval. This step prevents a consent from being used before its effective start time or after its expiration time. At consent creation, the expiry time must be later than the start time. These temporal attributes define the period during which the consent is potentially valid.
- **On-chain revocation.** Revocation represents a deliberate termination of the previously granted consent and must therefore override an otherwise valid temporal interval. The patient's withdrawal is confirmed as a revoke transaction on Sepolia in block 11,771,307, after which the contract reports the token as no longer valid. The blockchain or token layer provides persistence, traceability, and evidence of the resulting state. For subsequent requests, the system explicitly checks whether consent object C has been revoked in the local store. If the state is not ACTIVE, the access request is denied, and the refusal is reported in the doctor interface and recorded in the audit ledger as a DENIED DATA_ACCESS event.
- **Lifecycle states.** In the current prototype, the lifecycle is an explicit state machine with six states PENDING_SIGNATURE, PENDING_TOKEN, NOT_STARTED, ACTIVE, EXPIRED, and REVOKED. PENDING_SIGNATURE and PENDING_TOKEN refine the PENDING state of Section 10.1, a new consent enters PENDING_SIGNATURE directly rather than a separate CREATED state, NOT_STARTED marks an approved consent whose validity interval has not yet begun, and the SUSPENDED state is not yet implemented. Each evaluation derives the state from the distinct approvals of members of G, the token identifier, the revocation flag, and the current time. PENDING_TOKEN is the brief state between the last verified approval and the recording of the local token identifier. The implementation performs the two in one step, which is why Algorithm 3 and Figure 8.1 show them together. At each evaluation, the system verifies that the consent has not expired, been revoked, or otherwise transitioned into an inactive state.

Figure 10.2 summarises the implemented lifecycle. Each STATE_CHECK event in the audit ledger, recorded at every access request in any lifecycle state, establishes an auditable relationship between the consent’s lifecycle state and the operation performed at a particular point in time. The system therefore checks whether authorisation is still valid at the time an operation is requested, instead of treating authorisation as a one-time event. The expiry path is not shown in the demonstration of 24 September 2026, but a run on 11 October 2026 on a copy of the application database shows it. In that run, a consent was given a validity window of just under five minutes. Once the window had passed, the doctor's request was refused with the state EXPIRED and $V_T$ failing, and the refusal was recorded in the audit ledger. The automated tests in Section 11 also exercise this path.

In Figure 10.2, grey transitions are derived by the Consent Engine from the approvals, the token identifier and the current time, red transitions are anchored as Sepolia transactions, and dashed transitions show revocation before a token exists (off-chain only).

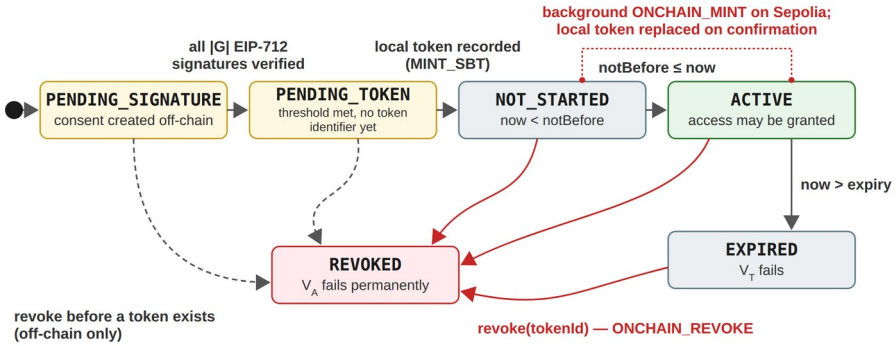



**Figure 10.2:** Implemented consent lifecycle

## 10.4 Remaining Work and Expected Outcome

In dynamic consent environments, permissions may expire, be revoked, suspended, renewed, or otherwise modified during the lifecycle of a healthcare data-sharing relationship. Five elements remain for the next stage.

- **Consent modification.** The current prototype assumes that the consent terms do not change after approval. The next stage will therefore extend the consent model to explicitly represent governed modification.
- **Delegation.** The consent Model will be expanded to include the delegation of consent.
- **Guardian-set changes.** Changes to the guardian set G after consent creation remain to be supported.
- **Transition check.** Lifecycle safety additionally requires that unauthorised state transitions be rejected, as in lines 16 to 20 of Algorithm 5. If the transition is not permitted, the system will record an unauthorised state-transition event and return INVALID, but this check is not yet implemented. The implemented temporal and revocation checks already ensure that a previously valid consent cannot be treated as permanently valid after expiration or revocation, but unauthorised transitions are examined only in part.
- **Formal lifecycle model.** The consent lifecycle will also be extended to represent controlled transitions formally, including the SUSPENDED state. Unauthorised transitions are thereby excluded by construction, with the central invariant that no REVOKED or EXPIRED consent can re-enter the ACTIVE state.

The expected outcome is a lifecycle-aware consent mechanism capable of rejecting access after expiration or revocation and preventing unauthorised lifecycle transitions. The lifecycle invariant will be verified by model checking of the state machine or by proof over the predicate definitions, with the formal component of RO6 in Section 11. The main activities of the next stage and their expected outcomes are summarised in Section 13. The next section presents RO6, the validation of the framework on the HALAH prototype.

# 11. The Proposed Solution for RO6

## *RO6 – Formal Security Assurance and Empirical Validation*

**Status: Not done (validation of RO1 to RO4 only)**

RO6 addresses RQ6 by formally analysing and empirically evaluating whether the proposed trust-oriented authorisation framework satisfies its defined security and authorisation properties. The objective combines two complementary forms of assurance. Formal security assurance specifies the conditions under which the authorisation mechanism should be considered secure and consistent. Empirical validation evaluates whether the implemented system behaves according to those conditions. Experimental success alone cannot establish that unauthorised access is impossible under the stated model, while formal reasoning establishes security properties only under explicitly defined assumptions. Consequently, the two forms of evidence are complementary rather than interchangeable. RO6 is not done. What has been carried out so far is the validation of the HALAH prototype for RQ1 to RQ4, and for the validity window and the revocation control of RQ5. The formal analysis and the evaluation of the complete framework will be conducted in the next stage, when the full system is done. Section 11.1 sets out the validation approach, Section 11.2 presents the validation algorithm, Section 11.3 describes the dataset, Section 11.4 presents the HALAH prototype and the live scenarios, Section 11.5 reports the measured results, Section 11.6 reports the unit-level adversarial tests, and Section 11.7 lists the remaining work.

## 11.1 Validation Approach

Figure 11.1 presents the RO6 workflow for formal security assurance and empirical validation. It shows Algorithm 6 of Section 11.2 as a flowchart, with the same main steps. It also adds a practical performance check and a loop that refines the framework and runs the validation scenarios again when a property fails. The algorithm itself does not include these two parts. Formal reasoning defines what the framework should guarantee, while empirical testing examines whether the implementation satisfies those guarantees in representative operational scenarios.

Figure 11.1 is Algorithm 6 as a flowchart, with a performance check and a refinement loop that the algorithm does not include.

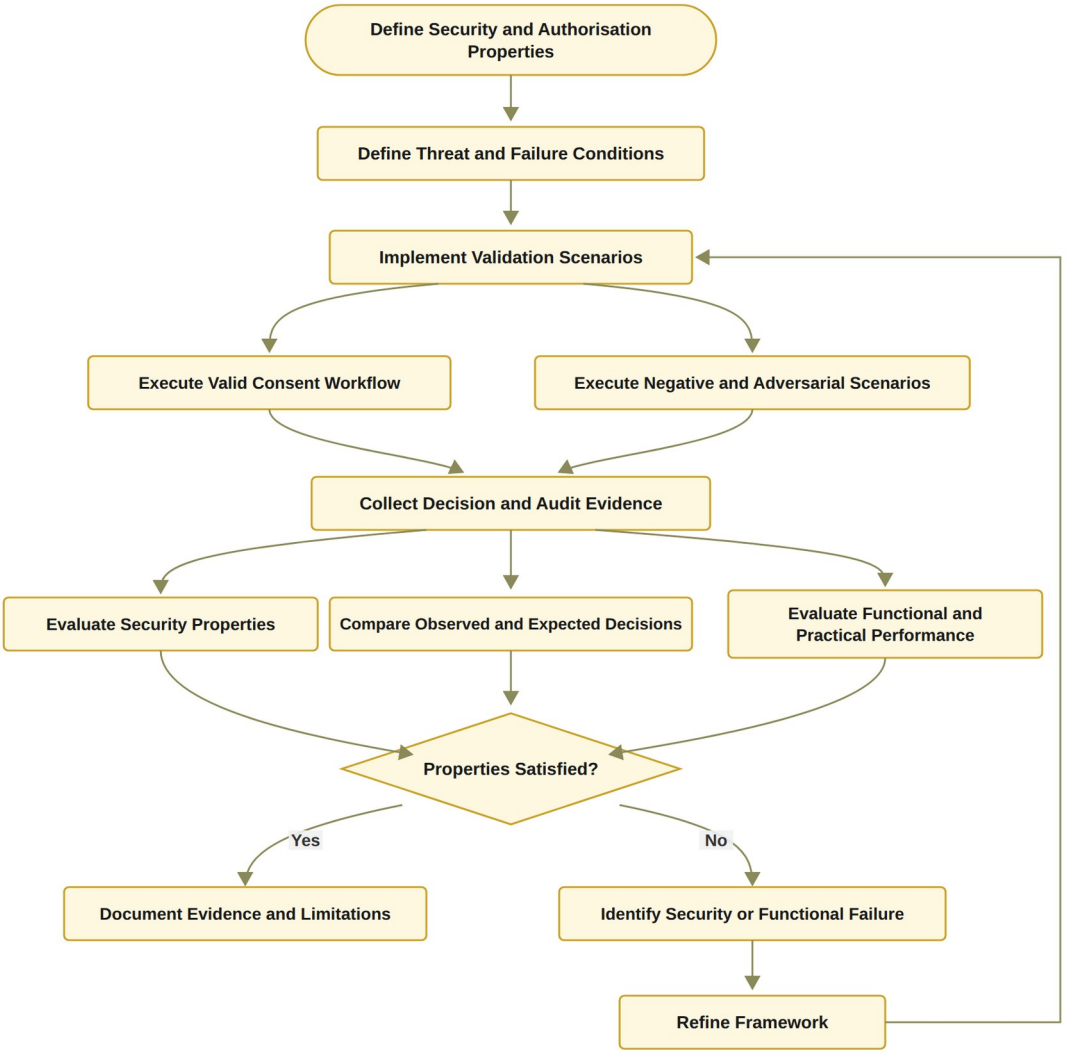



**Figure 11.1:** RO6 workflow for formal security assurance and empirical validation

The first step is to define the security and authorisation properties $P = \{P_{sound}, P_{deny}, P_{threshold}, P_{policy}, P_{scope}, P_{audit}\}$ that the framework is expected to satisfy. The three scenario classes are combined into the complete validation set $S = S_{valid} \cup S_{negative} \cup S_{adv}$. Valid scenarios establish that legitimate users can obtain authorised access, negative scenarios establish that invalid requests are correctly rejected, and adversarial scenarios examine whether security controls can resist deliberate attempts to circumvent the authorisation process. The observed decision is compared with the expected decision defined for scenario s, and the fundamental scenario-level validation criterion is $Pass(s) \iff D_{obs}(s) = D_{exp}(s)$. Otherwise, the scenario is classified as a validation failure. The framework is considered empirically consistent with the specified authorisation model when the observed decisions satisfy the expected outcomes across the defined validation scenarios and no critical security property is violated. Functional correctness and security correctness are therefore tested separately. The proposed validation therefore does not treat successful execution as sufficient evidence of correctness. Equation (11.1) expresses, in its foundational three-predicate form, the soundness requirement that every granted request must satisfy the identity, authorisation, and policy conditions.

$$Decision(C, R, t) = ALLOW \Rightarrow V_I(u) \wedge V_A(C) \wedge V_P(C, R). \quad (11.1)$$

Equivalently, Equation (11.2), the contrapositive of Equation (11.1), states that if any mandatory condition is violated, the request must be denied. Equation (11.1) is therefore examined through the

granted requests and Equation (11.2) through the negative scenarios, while the valid scenarios examine the opposite direction, namely that a request satisfying all conditions is granted. A valid authorisation decision requires the simultaneous satisfaction of all relevant trust conditions. Each of the five checks of the prototype decision matrix has a dedicated failure test, because successful operation under valid conditions alone cannot demonstrate that unauthorised access is reliably prevented. The tests confirm that failure of any individual condition results in denial.

$$\neg V_I(u) \vee \neg V_A(C) \vee \neg V_P(C, R) \Rightarrow \text{Decision}(C, R, t) = \text{DENY}. \tag{11.2}$$

The empirical component evaluates the implementation through representative consent workflows, negative and adversarial scenarios. Its 32 functional and regression tests check that each of these five checks can refuse a request on its own: an invalid guardian signature ($V_I$), a revoked consent ($V_A$), a purpose that is not a supported healthcare use ($V_P$), an expired consent ($V_T$) and a consent whose lifecycle state does not permit access (VL). They also check that a new consent starts as PENDING_SIGNATURE and is ACTIVE once both guardians have signed and the token is recorded. A tampered proof fails verification, and no proof can be produced for an expired consent. Consents, revocations and audit events persist after a reload. Since 11 October 2026, the functional tests also check the credential of the doctor and of each guardian, and that the requester is the doctor named in the consent. The 14 adversarial tests cover a baseline, twelve attack scenarios, and a check of the audit digest. Among them, an approval from outside G and a repeated approval leave the consent short of the threshold, and an over-scope or empty request is refused. In A12, an invalid or forged credential fails $V_I$.

## 11.2 Formal and Empirical Authorisation Validation Algorithm

Algorithm 6 formalises the validation procedure of Section 11.1, and Figure 11.1 shows it as a flowchart. It does not assume that successful execution of a consent workflow is sufficient evidence of security. Instead, it requires the system to demonstrate that invalid conditions produce appropriate denial decisions and that the recorded evidence is consistent with the decision. The algorithm receives the framework implementation F, the validation scenarios S and the security properties P. It returns the validation evidence and the evaluation results, which show whether the framework really meets these properties.

**Algorithm 6** Formal and Empirical Authorisation Validation

**Require:** Framework implementation F, validation scenarios S, security properties P
**Ensure:** Validation evidence and evaluation results

1: Define expected authorisation properties P
2: Define valid scenarios $S_{valid}$
3: Define negative scenarios $S_{negative}$
4: Define adversarial scenarios $S_{adv}$
5: **for** each scenario s in $S_{valid} \cup S_{negative} \cup S_{adv}$ **do**
6: Execute s using framework F
7: Collect authorisation decision
8: Collect identity, approval, policy, and audit evidence
9: Compare observed decision with expected decision
10: Record pass or failure result
11: **end for**
12: Evaluate soundness property
13: Evaluate denial property
14: Evaluate threshold correctness
15: Evaluate policy-scope enforcement
16: Evaluate audit consistency
17: Analyse failures and limitations
18: **return** Validation results

Line 1 defines the expected authorisation properties P, such as soundness, correct denial, threshold correctness, policy and scope compliance, and audit consistency. These are the criteria used to judge the

results. Lines 2 to 4 define the three scenario classes. $S_{valid}$ holds legitimate requests with valid identities, an active consent and enough approvals, so it shows that the framework does not wrongly reject valid requests. $S_{negative}$ holds requests that break at least one condition, such as an expired or revoked consent, too few approvals, or data outside the consent scope. $S_{adv}$ holds deliberate attempts to bypass the controls, such as replayed or duplicate approvals, forged credentials, or the use of a revoked consent. Line 5 combines the three classes into one set and repeats lines 6 to 10 for every scenario s, each of which has an expected decision $D_{exp}(s)$. Line 6 executes s on the implemented framework F, which performs its consent, identity, approval, policy, scope and lifecycle checks. Line 7 collects the observed decision $D_{obs}(s)$, for example ALLOW, DENY or PENDING. Line 8 collects the evidence behind it, such as the identity and credential results, the approvals, the policy checks, the timestamps and the audit records. Line 9 compares the observed decision with the expected decision, and the scenario passes only when the two are the same. Line 10 records the pass or failure result and, for a failure, keeps the details and the evidence for later analysis. Line 11 closes the loop.

Lines 12 to 16 then evaluate the properties. Line 12 checks soundness, so every allowed request must satisfy all five conditions of Equation (3.2), and Equation (11.1) states this for the three conditions $V_I$, $V_A$ and $V_P$. Line 13 checks denial, so every invalid or unauthorised request must be refused, as in Equation (11.2). This matters most for the negative and adversarial scenarios. Line 14 checks that a consent is authorised only when the number of verified approvals reaches the threshold N, without counting duplicate or unauthorised approvals. Line 15 checks that every allowed request matches the consent purpose and stays inside the permitted data scope, even when the requester has a valid identity and credential. Line 16 checks that the audit records match the decisions that were actually made, and that important evidence, such as the requester, the consent, the result and the time, is not missing. Line 17 analyses each failed scenario to find its cause, for example an implementation defect, a policy error, an integration problem or a limit of the test environment. The aim is to explain failures openly, not to hide them. Line 18 returns the validation results, which bring together the scenario results and the result for each security property.

In the current prototype, the testing part of Algorithm 6 is done. The scenario set holds the six live scenarios of Section 11.4 and the 46 automated tests, which include twelve attack scenarios, A1 to A12 (Section 11.6). All 46 tests pass, and all twelve attacks are refused. Lines 12 to 16 are evaluated over these scenarios, for example threshold correctness through A1 and A3, policy-scope enforcement through A4 and A5, and audit consistency through the ledger rows of Table 11.3. Line 17 was applied to A1, A3 and A5, which were accepted at unit level before the hardening of 1 October 2026. The on-chain cost, the confirmation latency and the processing time are also measured (Section 11.5), which gives the performance check of Figure 11.1. The next stage adds formal proofs or model checking of the security properties of lines 12 to 16, and a larger evaluation, with more scenarios and under load (Section 11.7).

## 11.3 Dataset Used for Validation

The prototype uses synthetic patient records from the Synthea 1K sample (Walonoski et al. 2018), taken from synthea.mitre.org in its CSV export rather than its FHIR R4 export (HL7 International 2019). Synthea generates realistic but artificial patients, so no real patient data is involved. The prototype loads a subset of patients together with their conditions, observations, medications and procedures, and these tables provide the healthcare data modules that a consent can authorise, such as Observation, Medication and Procedure. The records are used only to construct representative consent workflows. The authorisation decisions do not depend on the clinical content, and no medical content is written to the chain. The records are not changed. The only step is the selection of the subset loaded into the local database of the prototype.

## 11.4 The HALAH Prototype and Live Scenarios

The HALAH prototype provides the implementation basis for this evaluation. HALAH (History Access Link for Authorised Healthcare) is a consent management platform. The current system includes separate patient, guardian, doctor, and auditor interfaces, and the role shown in an interface is declared rather than authenticated, as noted in Section 5. It also records consent creation, guardian approval, token minting, state checks, and data-access events, allowed or denied. Following successful threshold satisfaction, the system generates activation or token evidence associated with the authorisation decision through ConsentSBTv3, a contract written in Solidity (Ethereum Foundation 2026a) for the Ethereum virtual machine (Wood 2014), compiled in Remix (Ethereum Foundation 2026c) and deployed on the Sepolia testnet (Ethereum Foundation 2026b) via MetaMask (Consensys 2026). Each token stores the pseudonymous patient and requester addresses, a hash of the purpose, the validity window, a two-letter context code, and a revocation flag. The SBT, a soulbound ERC-721 token (Entriken et al. 2018) that follows ERC-5484 (Cai 2022) and whose transfer between accounts is blocked, should be interpreted as an activation or representation mechanism for the consent state rather than as the fundamental source of trust. The blockchain or token layer provides persistence, traceability, and evidence of the resulting state. Blockchain or other tamper-resistant storage mechanisms may be integrated as infrastructure for preserving selected authorisation evidence, and no medical content is written to the chain. However, the plaintext purpose is passed as a parameter of the mint transaction and is therefore visible in the public transaction input. The system represents patients and healthcare participants using decentralised identities and provides mechanisms for consent creation, participant verification, multi-party approval, and access-control evaluation. The synthetic records that the prototype loads are described in Section 11.3.

The evaluated consent, f050c29a, was carried through the complete lifecycle as token #1, being granted access, refused access, and finally revoked. Figure 11.4 shows the evaluated consent f050c29a. The creation, approval, and record-display screens (Figure 11.2, Figure 11.3 and Figure 11.5) were captured from a second lifecycle, 04da25f5, which used the same code, contract, and configuration and was anchored as token #2. The evaluation considers both successful and unsuccessful authorisation scenarios.

**Scenario 1: consent creation (validates RQ1).** In the HALAH implementation, the patient interface allows the patient to select a patient DID, specify an authorised doctor, identify guardian DIDs, and select healthcare data modules such as Observation, Medication, Condition, and Procedure. The implementation also collects the start and expiry time of the consent. As shown in Figure 11.2, all four EMR modules were selected and two guardians were designated. The specification is accepted only when the required fields are valid. For example, the expiry time must be later than the start time. A consent with an empty data scope is rejected, and every guardian entry must be a well-formed DID. Since 11 October 2026, the authorised doctor and every guardian must also hold a valid credential with the right role, and a guardian listed twice is refused. The validated information is combined to construct the consent object C = (I, A, P, T, L, E) of Section 6. After validation, the system creates the consent object, assigns a consent identifier, persists the record, and records the creation event in the audit layer. The system therefore maintains the consent in a PENDING state rather than activating access, as PENDING_SIGNATURE, held only in the application ledger. The consent object therefore holds the information needed for identity verification, multi-party authorisation, policy evaluation, and auditability. It is a structured authorisation artefact, not only a record of patient preference that can provide evidence for subsequent healthcare data-access decisions.

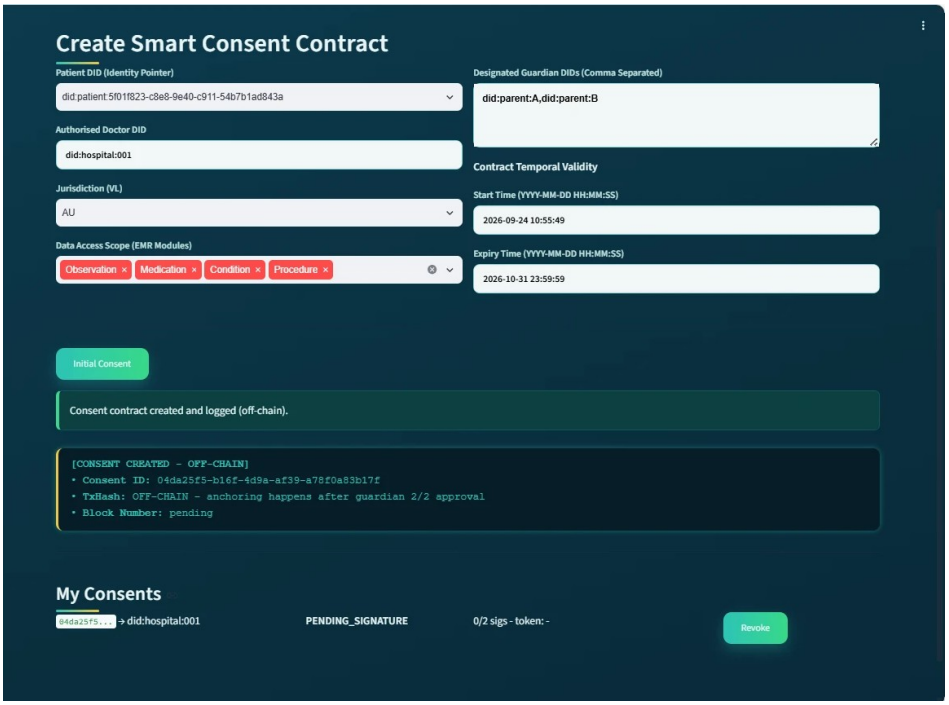



**Figure 11.2:** Patient subsystem after consent creation, in the state PENDING_SIGNATURE.

**Scenario 2: guardian approval and activation (validates RQ2 and RQ3).** Rather than relying on a single approval authority, the procedure requires a predefined number of eligible participants to independently provide valid approvals. Each participant must submit an approval that can be independently verified. Each guardian approves the consent with an EIP-712 typed-data signature that binds the approval to this consent, to this guardian, and to the Sepolia network (chainId 11155111). The system recovers the signer address and compares it with the address associated with the guardian DID, so a signature produced for another consent, another guardian, or another chain is rejected. If the participant has already submitted a valid approval, the system rejects the additional approval. Invalid approvals are rejected and must not contribute to the threshold count. Valid approvals are recorded and the current approval count is updated. In the implemented configuration, N = |G|, so all eligible participants must independently approve the consent before the authorisation becomes active. In this case, one valid approval is insufficient, whereas two valid approvals satisfy the threshold condition of Section 8. This mechanism allows the framework to distinguish between insufficient and sufficient collective authorisation. The prototype demonstrates that a consent object remains unable to establish valid authorisation until the required number of independently verified participants has approved it. When the threshold is reached, the implementation assigns an SBT identifier and records the corresponding minting event, and the anchoring starts in the background, as shown in Figure 11.3. The public anchoring of the evaluated consent f050c29a in block 11,771,243 (block 11,771,581 for consent 04da25f5 in Figure 11.3) provides an immutable or otherwise tamper-evident record of the transition from a pending consent state to an active authorisation state. The trust decision is established by the verification of participants and the satisfaction of the authorisation threshold. Since 11 October 2026, the guardian workflow also verifies the guardian's credential before it adds the signature to the consent, and an approval refused by this check is recorded in the audit ledger.




**Figure 11.3:** Guardian subsystem at the second approval: EIP-712 signature verified and 2/2 threshold reached.

**Scenario 3: authorised doctor access (validates RQ4).** The Doctor interface retrieves a consent, evaluates its state, allows a requested scope to be selected from the consent scope, generates a proof, checks the requested scope, and invokes the authorisation function before returning data. As shown in Figure 11.4, the decision matrix enables validation results to be traced from the final decision back to the individual authorisation conditions that produced that decision. A request is permitted only when the consent purpose is a supported healthcare use and the requested data scope is non-empty and contained within the authorised scope. Consequently, a valid identity and sufficient multi-party approval are necessary but not sufficient conditions for access. Here, the system generates or verifies the evidence supporting the access decision as a Groth16 zero-knowledge proof. Because the prover and the verifier run on the same server, the proof demonstrates the integration of the zero-knowledge toolchain rather than an additional privacy guarantee. As shown in Figure 11.5, once the request has been successfully authorised, the system retrieves only the healthcare data satisfying the authorised scope and displays them per EMR module. This rule prevents a legitimate participant from obtaining data outside the patient's authorised scope. These screens are from the version of 24 September 2026. Since 11 October 2026, the doctor also enters their own DID, and $V_I$ checks that this DID holds a valid doctor credential and is the doctor named in the consent.

Figure 11.4 was captured on 24 September 2026.

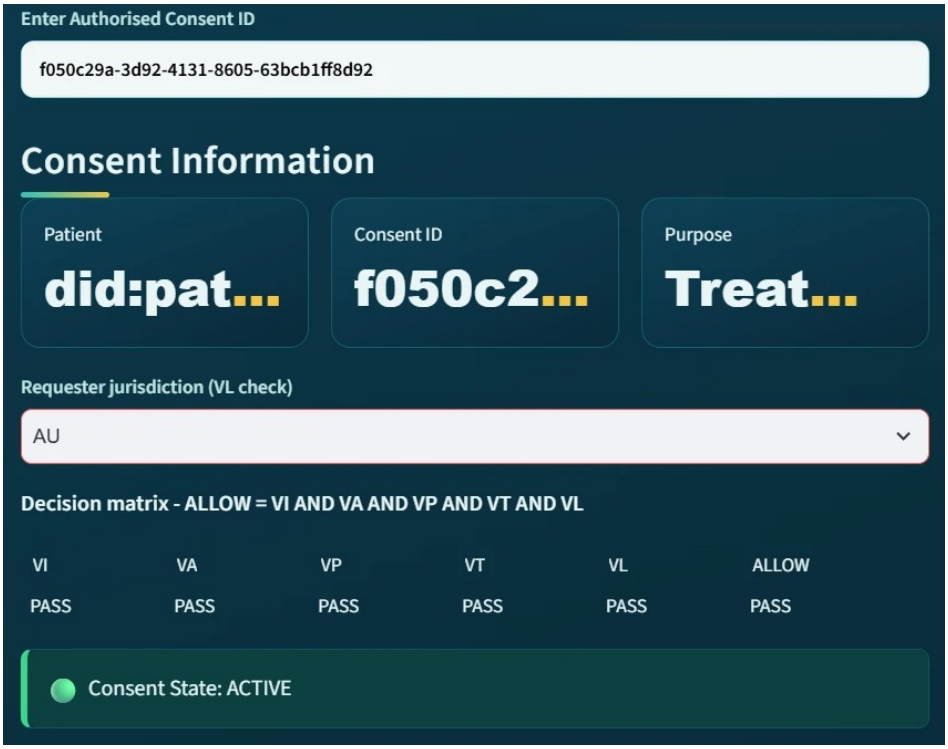



**Figure 11.4:** Doctor subsystem for the evaluated consent f050c29a: all five checks pass

Figure 11.5 joins two captures and shows the records per EMR module.

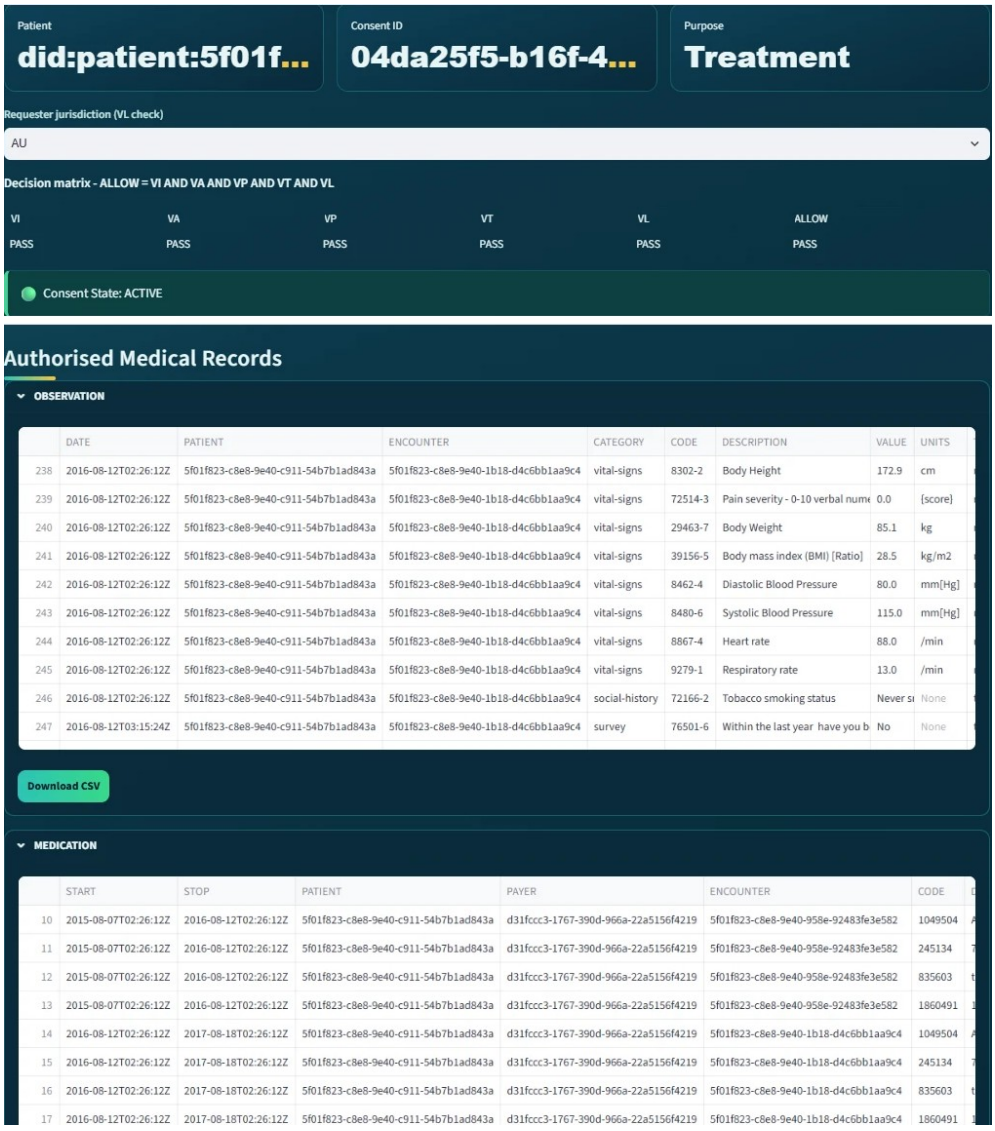



**Figure 11.5:** Doctor subsystem after verification for consent 04da25f5: access granted and records displayed

**Scenario 4: policy-context violation (exploratory check, supports RQ4).** A valid identity and sufficient approval do not necessarily imply that every requested operation is permitted. The same doctor repeated the request for the evaluated consent, which remained ACTIVE, while declaring a request context that differed from the one recorded in the consent, and all checks except that context check passed; the prototype interface of 24 September 2026 labels this check VL. Here, VL = FAIL and ALLOW = FAIL reflect a conjunctive trust model in which the failure of any required condition prevents the final authorisation decision. If any required condition is violated, the framework should produce a denial decision and preserve sufficient evidence to explain the reason for that decision, as the refusal in Figure 11.6 shows. Therefore, a consent object does not automatically imply that every subsequent request is authorised. Instead, the object provides the conditions against which a request can be evaluated.

In Figure 11.6 the failed check is the one labelled VL in the prototype interface.

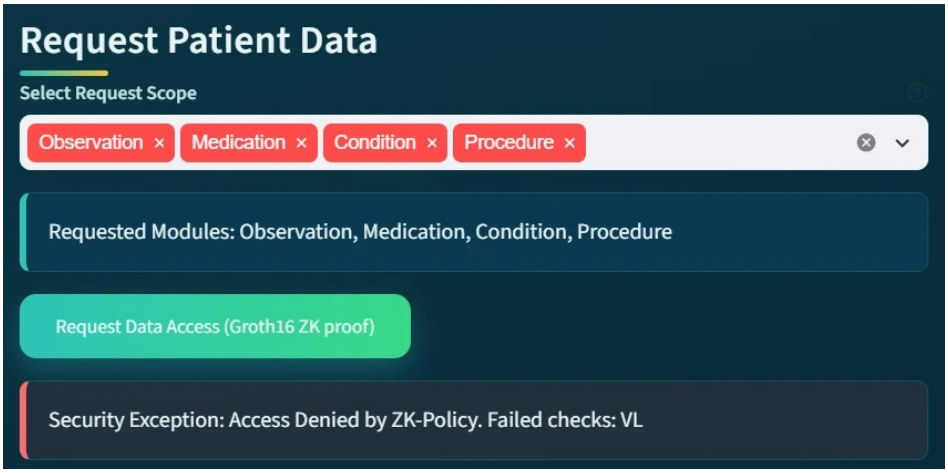



**Figure 11.6:** Refused request naming the failed check

**Scenario 5: revocation followed by refusal (validates the revocation control of RQ5).** Revocation should invalidate a previously established consent rather than merely create a new record indicating that the consent has changed. The patient revokes the evaluated consent, the system submits a revoke transaction to the contract, and the consent is displayed as REVOKED with its token number. A subsequent request by the doctor is refused by the doctor subsystem at the consent-state check, because the consent is no longer ACTIVE. The $V_A$ predicate itself rejects a revoked consent, which test A8 exercises. Since 11 October 2026, the lifecycle check $V_L$ also fails for a revoked consent, and the refusal is recorded in the audit ledger. Revocation represents a deliberate termination of the previously granted consent and must therefore override an otherwise valid temporal interval. The revocation control allows the framework to distinguish between a consent that was previously valid and a consent that remains valid at the time of a particular access request, and Figure 11.7 shows the publicly verifiable revocation transaction in block 11,771,307. The doctor subsystem does not read the chain, so this refusal follows from the revocation flag in the local store, while the on-chain state corroborates it separately.

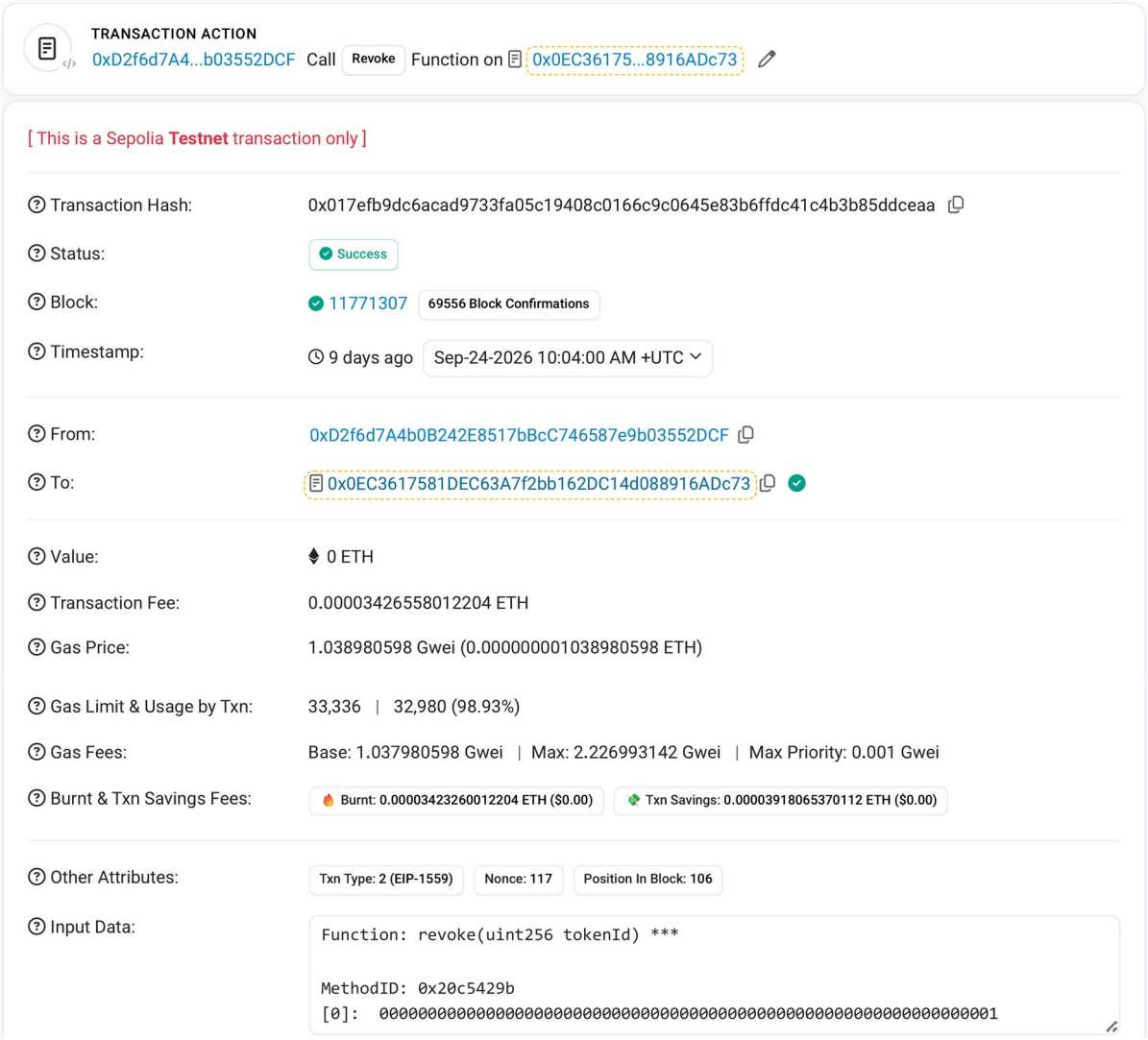



**Figure 11.7:** Revocation transaction of token #1 on Sepolia Etherscan, block 11,771,307.

**Scenario 6: audit and independent verification (supports RQ1 to RQ4).** An auditor can examine whether access occurred, whether the requester possessed a valid identity, whether the required authorisation threshold was satisfied, whether the requested data complied with the authorised scope, and which conditions produced the final decision. As shown in Figure 11.8, the auditor subsystem provides an auditable record that can be used to reconstruct and verify the consent lifecycle. For the evaluated consent, audit records are generated throughout the workflow to provide evidence of consent creation, participant verification, approval events, authorisation-state evaluation, data-access decisions, and relevant lifecycle transitions, including the on-chain mint and the revocation. However, the blockchain itself is not treated as the source of trust. Its role is to strengthen integrity, non-repudiation, and auditability of the evidence generated by the authorisation process. Because an application ledger could in principle contain fabricated entries, an independent verification tool fetches the receipt of every recorded transaction from Sepolia and compares the on-chain record and revocation state of tokens #1 and #2 on the current contract with the local state, with the result shown in Figure 11.9. Token #8 of the earlier deployment is skipped by the tool.

Figure 11.8 joins two captures.




| | timestamp | action | actor_role | onchain | tx_hash | block_number | consent_id | result | event_id |
|---|---|---|---|---|---|---|---|---|---|
| 36 | 2026-09-24T09:50:49.791935 | CREATE_CONSENT | Patient | ☐ | None | None | f050c29a-3d92-4131-8605-63bcb1ff8d92 | SUCCESS | 0346c077-d119-478a-bb12-11e711e2a2a2 |
| 37 | 2026-09-24T09:51:05.147730 | SIGN_CONSENT | Guardian | ☐ | None | None | f050c29a-3d92-4131-8605-63bcb1ff8d92 | SUCCESS | 79f4aa52-6c81-43aa-87f5-05f9de74f6fa |
| 38 | 2026-09-24T09:51:07.948663 | SIGN_CONSENT | Guardian | ☐ | None | None | f050c29a-3d92-4131-8605-63bcb1ff8d92 | SUCCESS | fcfb498b-94fe-46ca-96ad-f129c017c8f3 |
| 39 | 2026-09-24T09:51:07.958682 | MINT_SBT | SmartContract | ☐ | None | None | f050c29a-3d92-4131-8605-63bcb1ff8d92 | SUCCESS | 0b027299-7d16-4df9-a152-0493a6ee79e8 |
| 40 | 2026-09-24T09:51:12.812831 | ONCHAIN_MINT | SmartContract | ☑ | 0x8be1b9 | 11771243 | f050c29a-3d92-4131-8605-63bcb1ff8d92 | SUCCESS | a178e1a0-6695-4579-a276-dd7fa8156f3a |
| 41 | 2026-09-24T09:51:36.232885 | STATE_CHECK | ConsentEngine | ☐ | None | None | f050c29a-3d92-4131-8605-63bcb1ff8d92 | ACTIVE | 5d0425c3-aab5-431f-8a53-b76444273ba2 |
| 42 | 2026-09-24T09:51:38.844118 | DATA_ACCESS | Doctor | ☐ | None | None | f050c29a-3d92-4131-8605-63bcb1ff8d92 | GRANTED | 158b772e-4058-492e-9d68-2d5b6e194889 |
| 43 | 2026-09-24T09:51:39.310675 | STATE_CHECK | ConsentEngine | ☐ | None | None | f050c29a-3d92-4131-8605-63bcb1ff8d92 | ACTIVE | ed3885c3-0376-41bb-9d66-0ec09c78b440 |
| 44 | 2026-09-24T09:51:41.159213 | DATA_ACCESS | Doctor | ☐ | None | None | f050c29a-3d92-4131-8605-63bcb1ff8d92 | GRANTED | ea38d613-b8b4-4f72-90fa-8fde720a26df |
| 45 | 2026-09-24T10:02:50.025638 | STATE_CHECK | ConsentEngine | ☐ | None | None | f050c29a-3d92-4131-8605-63bcb1ff8d92 | ACTIVE | 51f2a504-6330-4070-b3aa-a611d372aacf |
| 46 | 2026-09-24T10:02:51.661961 | DATA_ACCESS | Doctor | ☐ | None | None | f050c29a-3d92-4131-8605-63bcb1ff8d92 | DENIED | 84d708f6-609e-4ae8-9d29-3bd2ead4748a |
| 47 | 2026-09-24T10:03:50.427292 | REVOKE_CONSENT | Patient | ☐ | None | None | f050c29a-3d92-4131-8605-63bcb1ff8d92 | SUCCESS | f0df938a-74bc-4f6c-8e4e-4d99274f8442 |
| 48 | 2026-09-24T10:04:00.807552 | ONCHAIN_REVOKE | SmartContract | ☑ | 0x017efb | 11771307 | f050c29a-3d92-4131-8605-63bcb1ff8d92 | SUCCESS | 6ed4aa46-7502-4644-bdbb-2e98f044d3c7 |

**Figure 11.8:** Auditor subsystem: aggregate indicators and the audit ledger rows of the evaluated consent

In Figure 11.9 the hashes and addresses are shortened, the notes on the earlier deployment are added, and the lines for unanchored consents and the skipped token #8 are omitted.

```
$ python3 -m tools.verify_poc
RPC https://ethereum-sepolia-rpc.publicnode.com | chainId 11155111 | head block 11820403
Contract 0x0EC3617581DEC63A7f2bb162DC14d088916ADc73 | code 16273 bytes | owner 0xD2f6d7A4b0B242E8517bBcC746587e9b03552DCF

Audit ledger: 60 events, 5 with a tx_hash
  [OK] ONCHAIN_MINT    0x5f9b2f14…6bc24994 block 11757272 (ledger 11757272) SUCCESS gas 156589 to 0xb0dA…4A6e7 (earlier deployment)
  [OK] ONCHAIN_REVOKE  0x2adf73d8…06044048 block 11757344 (ledger 11757344) SUCCESS gas 46226 to 0xb0dA…4A6e7 (earlier deployment)
  [OK] ONCHAIN_MINT    0x8be1b99e…98daf13d block 11771243 (ledger 11771243) SUCCESS gas 196406 to 0x0EC3…ADc73
  [OK] ONCHAIN_REVOKE  0x017efb9d…85ddceaa block 11771307 (ledger 11771307) SUCCESS gas 32980 to 0x0EC3…ADc73
  [OK] ONCHAIN_MINT    0x25ef5e2f…69d4c210 block 11771581 (ledger 11771581) SUCCESS gas 179306 to 0x0EC3…ADc73

Consent f050c29a-3d92-4131-8605-63bcb1ff8d92 -> token #1
  ownerOf            0x789997BFa84D1383379942E5Df6ABba4304E30C5  == did_to_address(patient) True
  requester          0xfE1efA136DCbc3B8eE405bB4F359148051a0fA6e  == did_to_address(doctor)  True
  purposeHash        0xff2a51e6eb5c67c2b1789c5fc8db6aaab2459d70d07eeac5c89f053cb18eb765  == keccak('Treatment') True
  notBefore/expiry   1790243449 / 1798761599
  jurisdiction       b'AU'  revoked(on-chain) True  burnAuth 2
  checkValid         False
  checkValidAt(AU)   False   checkValidAt(US) False
  local ledger state revoked=True  (matches chain: True)
Consent 04da25f5-b16f-4d9a-af39-a78f0a83b17f -> token #2
  ownerOf            0x167D9770dE0c9E603DCb33e745DCF145adA3BD2F  == did_to_address(patient) True
  requester          0xfE1efA136DCbc3B8eE405bB4F359148051a0fA6e  == did_to_address(doctor)  True
  purposeHash        0xff2a51e6eb5c67c2b1789c5fc8db6aaab2459d70d07eeac5c89f053cb18eb765  == keccak('Treatment') True
  notBefore/expiry   1790247349 / 1793491199
  jurisdiction       b'AU'  revoked(on-chain) False  burnAuth 2
  checkValid         True
  checkValidAt(AU)   True   checkValidAt(US) False
  local ledger state revoked=False  (matches chain: True)

RESULT: ALL CHECKS PASSED
```

**Figure 11.9:** Independent verification against Sepolia, abridged: RESULT: ALL CHECKS PASSED

Table 11.1 maps the framework components, each corresponding to a distinct responsibility within the trust-oriented authorisation process, to the HALAH subsystems. The mapping shows that the subsystems cooperate through a controlled authorisation sequence rather than through unrestricted direct communication. The subsystems have different responsibilities, and none of them decides on its own whether access should be granted.

**Table 11.1:** Correspondence between the HALAH framework components and the implemented subsystems

| HALAH Framework Component | Implementation Subsystem | Main Function |
|---|---|---|
| Consent Object Construction | Create Smart Consent Contract | Defines patient, authorised doctor, data scope, guardians and temporal validity |
| Identity & Authorisation | Guardian Cryptographic Approval | Checks the guardian DID format and credential, and verifies the EIP-712 signatures |
| Multi-party Consent | Guardian Cryptographic Approval | Implements the N-of-N approval condition (2-of-2 in the demonstration) |
| Consent Activation | Guardian Cryptographic Approval | Mints the SBT on Sepolia and marks the consent as fully activated |
| Consent-State Management | Secure Patient Data Access | Checks whether the consent is ACTIVE |
| Scope Enforcement | Secure Patient Data Access | Restricts access to authorised EMR modules |
| Cryptographic Access Control | Secure Patient Data Access | Verifies the request, including the doctor's DID and credential and a Groth16 proof, before granting data |
| Healthcare Data Access | Secure Patient Data Access | Provides the authorised Observation, Medication, Condition and Procedure records |
| Consent Lifecycle / Revocation (L) | My Consents (Patient) | Revokes the consent locally and on-chain |
| Lifecycle Traceability | Blockchain Audit & Consent Lifecycle | Reconstructs the chronological consent process |
| Accountability | Detailed Audit Records | Provides event-level evidence with transaction hashes |
| Ledger Integrity | Complete Ledger + independent verification | Confirms the anchored part of the recorded history against Sepolia |

## 11.5 Measured Results

The measurements are not intended as a high-throughput performance benchmark. The measurements are taken from the exported 60-event audit ledger, the receipts of the five anchored transactions, and repeated runs on 1 October 2026 in the development container used for the demonstration. The decision rule and the new credential check were timed in further runs on 11 October 2026. Table 11.2 presents the on-chain cost and the submit-to-confirmation latency of the five anchored transactions. The submit-to-confirmation time is the interval between the ledger timestamps of the local and on-chain events, so it includes signing and submission as well as the wait for the receipt.

**Table 11.2:** On-chain cost and submit-to-confirmation latency of the five anchored Sepolia transactions

| Transaction | Consent and token | Block | Gas used | Gas price (gwei) | Fee (ETH) | Submit-to-confirmation (s) |
|---|---|---|---|---|---|---|
| Mint, previous deployment | 011bbb21, token #8 | 11,757,272 | 156,589 | 1.07 | 0.000167 | 11.5 |
| Revoke, previous deployment | 011bbb21, token #8 | 11,757,344 | 46,226 | 1.10 | 0.000051 | 13.5 |
| Mint, ConsentSBTv3 | f050c29a, token #1 | 11,771,243 | 196,406 | 1.06 | 0.000209 | 4.9 |
| Revoke, ConsentSBTv3 | f050c29a, token #1 | 11,771,307 | 32,980 | 1.04 | 0.000034 | 10.4 |

| Transaction | Consent and token | Block | Gas used | Gas price (gwei) | Fee (ETH) | Submit-to-confirmation (s) |
|---|---|---|---|---|---|---|
| Mint, ConsentSBTv3 | 04da25f5, token #2 | 11,771,581 | 179,306 | 1.05 | 0.000189 | 22.1 |

As shown in Figure 11.10, on the current contract the revocation of token #1 used about one sixth of the gas of its mint, because a mint creates a token and writes a complete consent record, while a revocation changes only a single flag. No fee exceeded 0.00021 ETH, but Sepolia ether has no monetary value, so the portable measure of cost is the gas used rather than the fee.

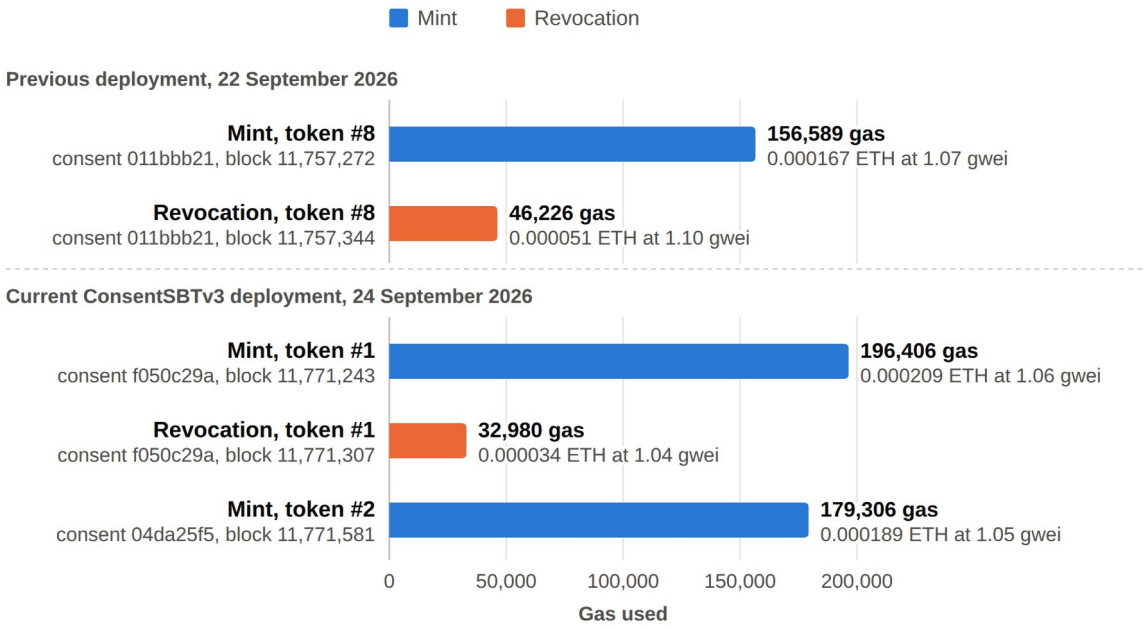



**Figure 11.10:** Gas used by the five anchored Sepolia transactions.

Table 11.3 shows how the validation procedure provides traceability between the final access decision and its supporting evidence. The ledger row of the single logged DENY, Scenario 4, records the proof check as passed and the scope as valid, so the refusal was produced by the decision matrix alone. Table 11.3 shows the proof mode of this row as not logged, because the prototype began to log it on denied requests later the same day. In each of the six logged evaluations, the recorded audit evidence is consistent with the actual authorisation decision. Validation therefore checks the evidence behind each decision as well as the final ALLOW or DENY. In the logged decisions, the implementation consistently produces an ALLOW decision only when the required trust conditions are satisfied and produces a DENY decision when one or more required conditions are violated. The three earlier grants of 22 September 2026 predate the logging of the matrix and of the proof mode. Similarly, the refusal after revocation on 24 September 2026 has no ledger row, because the doctor subsystem then stopped the request before it could be submitted. Since 11 October 2026, such a refusal is recorded in the audit ledger as a STATE_CHECK event and a DENIED DATA_ACCESS event. A later run on a copy of the application database shows this for the revoked consent f050c29a. That run came before $V_L$ became the lifecycle check, so its rows record $V_A$ = FAIL and $V_L$ = PASS. In a later run, after that change, consent 18ab9b62 was granted and then revoked, and the rows of the refused request that followed record $V_A$ = FAIL and $V_L$ = FAIL.

In Table 11.3, rows are the index numbers of the exported ledger, counted from 0, and n/l means not logged. VL is the fifth check as the prototype logged it on 24 September 2026.

**Table 11.3:** Access decisions recorded in the audit ledger with the decision matrix of each logged evaluation

| Rows | Date and time | Consent | $V_I$ | $V_A$ | $V_P$ | $V_T$ | $V_L$ | Decision | Access result | Proof mode |
|---|---|---|---|---|---|---|---|---|---|---|
| 41, 42 | 24 Sep 09:51:36 | f050c29a | PASS | PASS | PASS | PASS | PASS | ALLOW | GRANTED | groth16 |
| 43, 44 | 24 Sep 09:51:39 | f050c29a | PASS | PASS | PASS | PASS | PASS | ALLOW | GRANTED | groth16 |
| 45, 46 | 24 Sep 10:02:50 | f050c29a | PASS | PASS | PASS | PASS | FAIL | DENY | DENIED | n/l |
| 54, 55 | 24 Sep 11:02:52 | 04da25f5 | PASS | PASS | PASS | PASS | PASS | ALLOW | GRANTED | groth16 |
| 56, 57 | 24 Sep 11:04:16 | 04da25f5 | PASS | PASS | PASS | PASS | PASS | ALLOW | GRANTED | groth16 |
| 58, 59 | 24 Sep 11:04:26 | 04da25f5 | PASS | PASS | PASS | PASS | PASS | ALLOW | GRANTED | groth16 |
| 8, 21, 32 | 22 Sep 10:07 to 10:21 | f5a8ad89, cd9a24bd, 011bbb21 | n/l | n/l | n/l | n/l | n/l | n/l | GRANTED (3) | n/l |

Table 11.4 summarises the processing time of the decision components, with the decision rule timed on 11 October 2026 over 1,000 evaluations of the five checks of the prototype decision matrix on a loaded consent object without signature recovery or credential check. The credential check was timed over 20 checks of one credential.

The times in Table 11.4 were measured in the development container used for the demonstration, on 1 October 2026 (the decision rule and the credential check on 11 October 2026), with the anchoring confirmation taken from Table 11.2.

**Table 11.4:** Processing time of the decision components and of the on-chain reads of the verification tool

| Component | Median | Mean | Minimum | Maximum | n |
|---|---|---|---|---|---|
| Decision rule, five predicates (11 Oct) | 5.92 µs | 6.47 µs | 5.36 µs | 72.07 µs | 1,000 |
| EIP-712 signature recovery, one signature | 10.93 ms | 11.67 ms | 10.55 ms | 15.64 ms | 20 |
| Credential check, one credential (11 Oct) | 6.42 ms | 6.51 ms | 6.18 ms | 8.33 ms | 20 |
| Groth16 proof generation | 1,401.1 ms | 1,597.0 ms | 1,342.8 ms | 5,349.6 ms | 20 |
| Groth16 proof verification | 465.3 ms | 472.5 ms | 441.0 ms | 525.1 ms | 20 |
| On-chain checkValid read | 573.5 ms | 587.4 ms | 568.2 ms | 715.5 ms | 20 |
| On-chain checkValidAt read | 574.6 ms | 592.7 ms | 568.2 ms | 745.6 ms | 20 |
| Anchoring confirmation | 11.5 s | 12.5 s | 4.9 s | 22.1 s | 5 |

As shown in Figure 11.11, the time taken to evaluate the decision rule is negligible, the credential check takes about 6 ms per credential, and signature recovery takes about 11 ms per guardian, whereas the Groth16 proof dominates the interactive path of an access request. The proof times include process start-up as well as cryptographic work, and at the median the proof takes more than 98 per cent of the roughly 1.9 s of one access request. Anchoring confirmation, measured over three mints and two revokes, is the slowest step. The mint is anchored in the background, so it delays neither the guardians nor the doctor, whereas the patient waits for the confirmation of a revoke.

In Figure 11.11 the marker is the median and the bar runs from the minimum to the maximum. The checkValid read of Table 11.4 is not plotted, as its values are close to those of the checkValidAt read.

The decision rule and the credential check were measured on 11 October 2026, the other timings on 1 October 2026, and the anchoring comes from the five Sepolia transactions of September 2026.

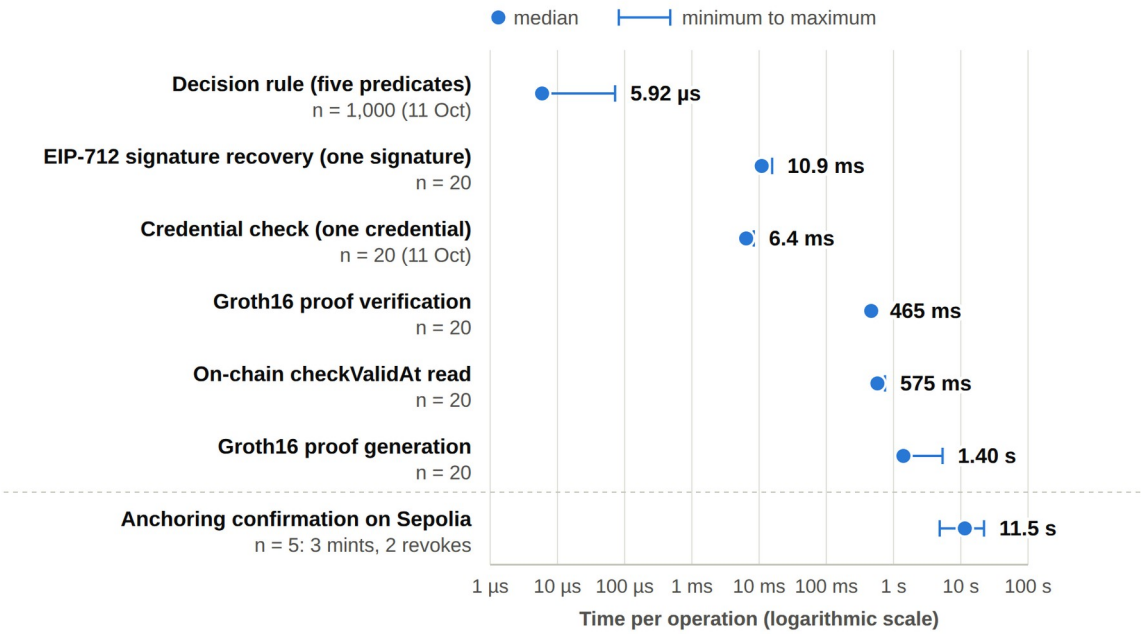



**Figure 11.11:** Processing time of the decision components on a logarithmic axis

## 11.6 Unit-Level Adversarial Tests

The adversarial test set matters because a framework must show that legitimate requests succeed and that foreseeable attempts to bypass its security controls fail. The adversarial tests assume honest infrastructure and exercise the decision functions, the credential check, the proof verifier, the audit digest function, and the contract at unit level, never the running application, its data store, or the Sepolia deployment. The adversary, whether an outside requester or a participant of the consent, tries to obtain or keep access without satisfying a condition of C, or to alter the anchored consent or the recorded evidence of a decision. It can supply crafted inputs to the decision functions, present a forged, tampered, expired or untrusted credential, alter the bits of a Groth16 proof or its public signals, and send transactions to the contract from an account that is not its owner. Several capabilities are outside the scope of this evaluation because the prototype does not defend against them, for example, the interface authenticates no role and guardian signing keys derive from the public guardian DIDs. In the same way, the key of the one demo issuer that signs the credentials can be reproduced from the source code. The adversary is also assumed to have no write access to the stores, apart from rewriting an audit event, and no control of the server clock.

The twelve scenarios A1 to A12 include replayed approvals, duplicate approvals, unauthorised participants attempting to satisfy a threshold, invalid or forged credentials, attempts to access data outside the authorised scope, and attempts to use a revoked or expired consent object. Each scenario is associated with an expected authorisation outcome and the component of C that it targets, as listed in Table 11.5. A scenario is counted as refused when the targeted predicate fails and the decision is DENY, or when the scope check, the Groth16 prover or verifier, or the contract rejects the input.

Table 11.5 records whether each scenario has passed or failed. Before the hardening, three attacks, A1, A3, and A5, were accepted when the service functions were called directly. A design can be correct while its implementation is not, and functional tests alone do not show this. Any failed scenario is analysed to determine the source and significance of the failure. The analysis records the unsuccessful cases and classifies each one as a violation of an intended security property or as a limitation to be addressed in the next stage. None of the three was reachable through the interface as used in the demonstration of 24

September 2026, so they represent a gap in defence in depth rather than a demonstrated breach of the deployed system. Accordingly, in the service layer, invalid, unauthorised, or duplicate approval attempts are rejected and do not contribute to the valid approval count, and an empty request is refused. This ensures that the threshold cannot be artificially satisfied by repeated or illegitimate approval submissions. After this hardening, all of the first eleven scenarios are refused. A12, an invalid or forged credential, came with the credential check of 11 October 2026 and is refused too. Before that change, a requester without a valid credential was accepted. All twelve scenarios are therefore refused and all 46 automated tests pass. A rewritten audit event also changes its digest, but no component of the prototype compares the digest yet, so this check is not counted as an attack scenario.

Table 11.5 gives the outcome before and after the hardening of 1 October 2026 and, for A12, before and after the credential check of 11 October 2026.

**Table 11.5:** Unit-level adversarial tests A1 to A12, their target and their outcome before and after the hardening

| ID | Attack | Target | Expected | Before hardening | After hardening | Evidence |
|---|---|---|---|---|---|---|
| A1 | Approval signed by a signer outside G | A | Refused | Accepted at unit level (blocked in the interface) | Refused | test_A1_signer_outside_G_ is_not_counted |
| A2 | Guardian signature replayed from another consent | I | Refused | Refused | Refused | test_A2_replayed_signature_ is_rejected |
| A3 | Same guardian approves twice to reach N | A | Refused | Accepted at unit level (blocked in the interface) | Refused | test_A3_duplicate_approval_ does_not_reach_threshold |
| A4 | Requested scope exceeds the authorised scope | P (scope check) | Refused | Refused | Refused | test_A4_over_scope_request_ is_rejected |
| A5 | Request with an empty scope | P (scope check) | Refused | Accepted at unit level (blocked in the interface) | Refused | test_A5_empty_scope_is_ rejected |
| A6 | Request before notBefore or after expiry | T | Refused | Refused | Refused | test_A6_outside_validity_ interval_is_denied |
| A7 | Requester declares a request context that differs from the consent | P | Refused | Refused | Refused | test_A7_jurisdiction_ mismatch_is_denied. Live application decision, 24 Sep: Figure 11.6 |
| A8 | Access after revocation | L (via VA and VL) | Refused | Refused | Refused | test_A8_revoked_consent_is_ denied (local flag). Separate on-chain revocation, Sepolia block 11,771,307, 24 Sep |
| A9 | Tampered Groth16 proof or public signal | E | Refused | Refused | Refused | test_A9_tampered_proof_ fails_verification |
| A10 | Honest proof generation for an expired consent | T | Refused | Refused | Refused | test_A10_honest_prover_ cannot_prove_expired_ consent (honest prover only) |
| A11 | Mint or revoke by a non-owner, or token transfer | Contract | Refused | Refused | Refused | test_A12_non_owner_ cannot_mint_or_revoke (in-memory EVM, not Sepolia) |

| ID | Attack | Target | Expected | Before hardening | After hardening | Evidence |
|---|---|---|---|---|---|---|
| A12 | Invalid or forged credential | I | Refused | Accepted before the credential check of 11 October 2026 | Refused | test_A13_invalid_or_forged_credential_is_rejected |

The analysis separates implementation defects from incomplete security controls and from limitations of the test environment. The validation has six limitations. First, A11 runs the contract source on an in-memory Ethereum virtual machine, so it does not show the behaviour of the deployed bytecode. Second, the SHA-256 digest of the audit ledger is neither keyed nor chained, so the ledger is not tamper-evident against a party with write access to the store. Third, the signed guardian message covers only the consent identifier, the guardian, and the network, so a change of scope, purpose, requester or expiry after approval is not detected. Fourth, A6 relies on the server clock, A7 on the request context declared by the requester, and A8 on the revocation flag of the local store. Fifth, the Groth16 result holds under a single-party development trusted setup, with the prover and the verifier on the same server. Sixth, the measurements come from a single container and five transactions, so they are indicative only.

## 11.7 Remaining Work for the Next Stage

The remaining security assurance and comprehensive empirical evaluation will be conducted in the next stage and consist of three parts.

- **Formal assurance.** The formal component will specify and analyse the security properties, consistency requirements, and soundness conditions of the trust-oriented authorisation mechanism. The soundness property Decision(C, R, t) = ALLOW $\Rightarrow V_I \wedge V_A \wedge V_P \wedge V_T \wedge V_L$ and the lifecycle invariant of Section 10 will be verified by model checking of the state machine or by proof over the predicate definitions. Formal analysis will be used to reason about whether unauthorised entities or invalid authorisation conditions can produce an apparently valid access decision under defined assumptions, and every property must be either verified or refuted by an explicit counterexample.
- **Full performance and scalability study.** The preliminary measurements will be repeated over a larger number of consents, guardians, and access requests, and the end-to-end decision latency will be measured under concurrent load.
- **Extended adversarial evaluation.** The next stage will extend the current prototype-based validation to include both successful and adversarial access requests. The twelve attack scenarios will be extended to larger sets of positive, negative, and adversarial scenarios, and enforcement accuracy will be reported over this extended set. The formal security model will be compared with the observed behaviour of the implemented system.

The next stage will address the prototype limitations that the evaluation has exposed, which include the N-of-N approval rule, the server-derived guardian keys, the unauthenticated requester role, the absence of full DID resolution, the purpose check that does not yet compare a separately declared request purpose, the missing lifecycle transition check, and the unkeyed and unchained audit digest. This work will establish explicit security properties and determine whether the proposed authorisation model provides the expected protection when relevant security conditions are violated, and Section 13 sets out its schedule.

# 12. Publications Summary

The published and accepted papers are listed in Table 12.1. Two papers were published in 2025 at the IEEE International Conference on E-Business Engineering (ICEBE). Three more papers have been accepted in 2026, one at ICEBE 2026 and two at BWCCA 2026. Paper 4, on trusted multi-party consent governance, comes from this research.

**Table 12.1:** Published and accepted papers

| No. | Title | Venue | Year | Status |
|---|---|---|---|---|
| 1 | A Blockchain-Based Framework for Evaluating User Identity Trustworthiness in Real Estate | 2025 IEEE International Conference on E-Business Engineering (ICEBE) | 2025 | Published |
| 2 | Blockchain-Based Reputation Borrowing Model to Address the Cold Start Problem for New Users in Real Estate | 2025 IEEE International Conference on E-Business Engineering (ICEBE) | 2025 | Published |
| 3 | A Smart Contract-Governed Lifecycle Protocol for Reputation Borrowing in Blockchain-Based Real Estate Platforms | ICEBE 2026 | 2026 | Accepted |
| 4 | A Trusted Multi-Party Consent Governance Framework for Decentralized Multi-Stakeholder Data Sharing | BWCCA 2026 | 2026 | Accepted |
| 5 | Blockchain-Based Reputation Provenance Tracing for Newcomer Bootstrapping in Real Estate | BWCCA 2026 | 2026 | Accepted |

The publication activities associated with this research are summarised in Table 12.2 according to their current development status and their structural contribution to the thesis chapters and research questions. Publication 1 in Table 12.2 is Paper 4 in Table 12.1, and BWCCA 2026 has accepted it.

**Table 12.2:** Publications of the research and their current status

| Publication | Research output | Target venue | Related RQs | Status |
|---|---|---|---|---|
| Publication 1 (Conference) | Trust-centric multi-party consent framework and the HALAH prototype on the Sepolia testnet | BWCCA 2026 | RQ1 to RQ4 | ☑️ Accepted (submitted September 2026) |
| Publication 2 (Journal) | Systematic literature review of blockchain-based multi-party patient consent (25 primary studies) | Journal | Section 2 | ⏳ Ready for submission (October 2026) |
| Publication 3 (Journal) | Formal security assurance, lifecycle trust and the complete evaluation of the HALAH framework | Journal | RQ5 and RQ6 | ⏳ Planned (January 2027) |

The current stage work establishes the conceptual and technical foundation, while the next stage work will strengthen the framework through formal analysis and comprehensive empirical validation. Publication 2 in Table 12.2 extends Section 2 into a stand-alone review, and Publication 3 completes the work that Sections 10 and 11 identify as remaining for the next stage. RO5 and RO6 constitute the principal research agenda for the next stage. RO5 extends the authorisation model with temporal and lifecycle trust, while RO6 provides formal security assurance and comprehensive empirical validation.

# 13. Research Plan

The research plan is divided into two major stages corresponding to current and next stage, and Table 13.1 lists their tasks, target dates and status.

**Table 13.1:** Research plan: thesis chapters, publications and assessments in chronological order

| Task | Description | Target date | Status |
|---|---|---|---|
| Chapters 1–4 | Introduction, SLR, Research Questions and Objectives, Research Methodology | Completed | ☑️ Done |
| Chapter 5 | Research Architecture (MVC) and framework design and Proposed solution for RO2 | May 2026 | ☑️ Done |
| Chapter 6 | Proposed solution for RO3 | Jul 2026 | ☑️ Done |
| Publication 1 Conference | Conference paper submission, BWCCA 2026: "A Trusted Multi-Party Consent Governance Framework for Decentralized Multi-Stakeholder Data Sharing" | Sep 2026 | ☑️ Done |
| Chapter 7 | Proposed solution for RO4 | Sep 2026 | ☑️ Done |
| Publication 2 Journal | SLR paper journal submission | Oct 2026 | ⏳ Ready for submission |
| Chapter 8 | Proposed solution for RO5 | Nov 2026 | ⏳ In Progress |
| Chapter 9 | Conclusion and future work | Dec 2026 | ⏳ Planned |
| Publication 3 Journal | Journal paper on formal security assurance, lifecycle trust and the evaluation of HALAH | Jan 2027 | ⏳ Planned |
| Final assessment | Candidature Assessment 3 | Feb 2027 | ⏳ Planned |
| Thesis submission | Complete thesis submission | May 2027 | ⏳ Planned |

As shown in Figure 13.1, the current stage focuses on establishing the foundational trust-oriented authorisation framework. The main activities are the development of the trust-centric consent model, decentralised identity and authority verification, multi-party authorisation, and policy-aware access control. The progression is RO1, RO2, RO3 and then RO4, which have been implemented and initially validated through the HALAH prototype. The next stage, which concentrates on RO5 and RO6, which are not done (RO5 in progress, RO6 validation only), will extend the framework of the current stage to dynamic consent governance, formal security assurance, and a fuller empirical validation. The SUSPENDED state, the lifecycle transition check, the formal lifecycle model, and consent modification, delegation, and guardian-set changes extend the lifecycle trust of Section 10, and contextual policy conditions extend the policy evaluation of Section 9, while the formal security assurance and the full performance, scalability, and adversarial evaluation complete the work of Section 11.

Figure 13.1 shows the completed milestones, the work in progress and the planned stages up to thesis submission.




**Figure 13.1:** Research timeline

The major next stage activities and their expected outcomes are summarised in Table 13.2.

**Table 13.2:** Next stage research activities and their expected outcomes

| Research Focus | Planned Activities | Expected Outcome |
|---|---|---|
| Consent Modification, Delegation and Lifecycle Extensions | Add the SUSPENDED state and the lifecycle transition check. Extend the implemented lifecycle mechanism to support consent modification, delegation and guardian-set changes, extend the policy evaluation with a declared request purpose, and formalise the state-transition model so that unauthorised transitions are excluded by construction. Evaluate access decisions under varying temporal and consent-state constraints. | A dynamic consent management mechanism capable of validating whether an authorisation remains active at the precise point of access. |
| Formal Security Assurance (Properties & Verification) | Formally define critical security properties and analyse system behaviour under adverse conditions, including invalid identities, insufficient multi-party approvals, policy violations, expired/revoked states, and illegal transitions. | A rigorous formal security model and verification proof establishing explicit security guarantees for the trust-oriented authorisation framework. |
| Empirical Validation (HALAH Prototype Scenarios) | Scale and extend the HALAH prototype experiments, including the twelve attack scenarios of Section 11, to larger sets of positive, negative and adversarial healthcare data-sharing scenarios. Extend the preliminary measurements of runtime performance, overhead and enforcement accuracy to operation under load. | Empirical evidence and benchmark datasets demonstrating that the implementation consistently and efficiently enforces the proposed authorisation model. |

| Research Focus | Planned Activities | Expected Outcome |
|---|---|---|
| Integrated Framework Evaluation (Synthesis & End-to-End) | Integrate temporal, lifecycle, formal verification, and empirical modules into a unified, cohesive framework. Evaluate cross-component interactions, scalability bottlenecks, and end-to-end feasibility in real-world settings. | A fully integrated, validated trust-oriented authorisation framework providing secure, multi-party patient consent and decentralised healthcare data sharing. |

# References


Abbasi, A., Humeidi, M.N. & Wang, Q. 2026, 'Nexa: Enabling secure, scalable, and decentralized management of electronic health records using threshold cryptography and public blockchains', *IEEE Access*, vol. 14, pp. 50791–50810, <https://doi.org/10.1109/ACCESS.2026.3677499>.

Akter, S. & Sanam, T.F. 2025, 'A blockchain framework for secure healthcare data management using role-based access control and smart contracts', *2025 International Conference on Electrical, Computer and Communication Engineering (ECCE)*, pp. 1–6, <https://doi.org/10.1109/ECCE64574.2025.11013162>.

Al Amin, M., Altarawneh, A. & Ray, I. 2023, 'Informed consent as patient driven policy for clinical diagnosis and treatment: A smart contract based approach', *Proceedings of the 20th International Conference on Security and Cryptography (SECRYPT 2023)*, pp. 159–170, SciTePress, <https://doi.org/10.5220/0012090600003555>.

Al Mamun, A., Azam, S. & Gritti, C. 2022, 'Blockchain-based electronic health records management: A comprehensive review and future research direction', *IEEE Access*, vol. 10, pp. 5768–5789, <https://doi.org/10.1109/ACCESS.2022.3141079>.

Albalwy, F., Brass, A. & Davies, A. 2021, 'A blockchain-based dynamic consent architecture to support clinical genomic data sharing (ConsentChain): Proof-of-concept study', *JMIR Medical Informatics*, vol. 9, no. 11, p. e27816, <https://doi.org/10.2196/27816>.

Andrew, J., Isravel, D.P., Sagayam, K.M., Bhushan, B., Sei, Y. & Eunice, J. 2023, 'Blockchain for healthcare systems: Architecture, security challenges, trends and future directions', *Journal of Network and Computer Applications*, vol. 215, p. 103633, <https://doi.org/10.1016/j.jnca.2023.103633>.

Arbabi, M.S., Lal, C., Veeraragavan, N.R., Marijan, D., Nygård, J.F. & Vitenberg, R. 2023, 'A survey on blockchain for healthcare: Challenges, benefits, and future directions', *IEEE Communications Surveys & Tutorials*, vol. 25, no. 1, pp. 386–424, <https://doi.org/10.1109/COMST.2022.3224644>.

Bloemen, R., Logvinov, L. & Evans, J. 2017, *EIP-712: Typed structured data hashing and signing*, Ethereum Improvement Proposals, no. 712, viewed 6 October 2026, <https://eips.ethereum.org/EIPS/eip-712>.

Cai, B. 2022, *ERC-5484: Consensual soulbound tokens*, Ethereum Improvement Proposals, no. 5484, viewed 6 October 2026, <https://eips.ethereum.org/EIPS/eip-5484>.

Consensys 2026, *MetaMask developer documentation*, viewed 7 October 2026, <https://docs.metamask.io/>.

Deng, H., Liang, J., Zhang, C., Liu, X., Zhu, L. & Guo, S. 2024, 'FutureDID: A fully decentralized identity system with multi-party verification', *IEEE Transactions on Computers*, vol. 73, no. 8, pp. 2051–2065, <https://doi.org/10.1109/TC.2024.3398509>.

Ekholm, K., Augustinsson, A., Sundström, J., Johansen, C., Storgärds, M., Ljöstad, L. et al. 2025, 'Implementing electronic informed consent in rare disease genomics', *Scientific Reports*, vol. 15, no. 1, p. 44419, <https://doi.org/10.1038/s41598-025-32740-1>.

Eneh, A.U., Ahakonye, L.A.C., Lee, J.M. & Kim, D.-S. 2026, 'Demo: EdgeConsent: On-chain attribute-based access control for data consent management', *2026 IEEE International Conference on Blockchain and Cryptocurrency (ICBC)*, pp. 1–2, <https://doi.org/10.1109/ICBC67748.2026.11575534>.

Entriken, W., Shirley, D., Evans, J. & Sachs, N. 2018, *ERC-721: Non-fungible token standard*, Ethereum Improvement Proposals, no. 721, viewed 6 October 2026, <https://eips.ethereum.org/EIPS/eip-721>.

Ethereum Foundation 2026a, *Solidity documentation*, viewed 7 October 2026, <https://docs.soliditylang.org/>.

Ethereum Foundation 2026b, *Networks*, ethereum.org developer documentation, viewed 7 October 2026, <https://ethereum.org/en/developers/docs/networks/>.

Ethereum Foundation 2026c, *Remix IDE documentation*, viewed 7 October 2026, <https://remix-ide.readthedocs.io/>.

Ferreira, J.C., Correia, R., Rosário, L. & Vila, A. 2025, 'Blockchain integration for trust and consent management in MCP-enabled FHIR systems', *2025 IEEE International Conference on Distributed Ledger Technologies (ICDLT)*, pp. 1–10, <https://doi.org/10.1109/ICDLT66400.2025.11466653>.

Flamini, A., Sciarretta, G., Scuro, M., Sharif, A., Tomasi, A. & Ranise, S. 2024, 'On cryptographic mechanisms for the selective disclosure of verifiable credentials', *Journal of Information Security and Applications*, vol. 83, p. 103789, <https://doi.org/10.1016/j.jisa.2024.103789>.

Ghafoor, A., Symeonidis, I., Rydberg, A., Lindahl, C. & Abbasi, A.Q. 2025, 'Towards empowering stakeholders through decentralized trust and secure livestock data sharing', *Cryptography*, vol. 9, no. 3, p. 52, <https://doi.org/10.3390/cryptography9030052>.

Ghosh, P.K., Chakraborty, A., Hasan, M., Rashid, K. & Siddique, A.H. 2023, 'Blockchain application in healthcare systems: A review', *Systems*, vol. 11, no. 1, p. 38, <https://doi.org/10.3390/systems11010038>.

Grassi, L., Khovratovich, D., Rechberger, C., Roy, A. & Schofnegger, M. 2021, 'Poseidon: A new hash function for zero-knowledge proof systems', *Proceedings of the 30th USENIX Security Symposium*, pp. 519–535.

Groth, J. 2016, 'On the size of pairing-based non-interactive arguments', *Advances in Cryptology – EUROCRYPT 2016, LNCS*, vol. 9666, pp. 305–326, Springer, <https://doi.org/10.1007/978-3-662-49896-5_11>.

Hagström, J., Hägglund, M., Holmroos, M., Lähteenmäki, P. & Hörhammer, I. 2024, 'Minors' and guardian access to and use of a national patient portal: A retrospective comparative case study of Sweden and Finland', *International Journal of Medical Informatics*, vol. 187, p. 105465, <https://doi.org/10.1016/j.ijmedinf.2024.105465>.

Hellstern, R., Park, D.C., Lemieux, V. & Salimjan, G. 2022, 'Leveraging blockchain-based archival solutions for sensitive documentation: A Xinjiang case study', *Digital Society*, vol. 1, no. 1, p. 4, <https://doi.org/10.1007/s44206-022-00007-1>.

Hema, S., Reddy, G.B.S. & Shalini, R. 2026, 'Patient centric cryptographic protection of cloud electronic health records', *2026 6th International Conference on Expert Clouds and Applications (ICOECA)*, pp. 293–300, <https://doi.org/10.1109/ICOECA68095.2026.11485301>.

HL7 International 2019, *HL7 FHIR Release 4 (R4)*, viewed 7 October 2026, <https://hl7.org/fhir/R4/>.

Ibrahim, A.M., Abdel-Aziz, H.R., Mohamed, H.A.H., Zaghamir, D.E.F., Wahba, N.M.I., Hassan, G.A. et al. 2024, 'Balancing confidentiality and care coordination: Challenges in patient privacy', *BMC Nursing*, vol. 23, no. 1, p. 564, <https://doi.org/10.1186/s12912-024-02231-1>.

iden3 2026a, *snarkjs: zkSNARKs implementation in JavaScript*, version 0.7, npm package, viewed 7 October 2026, <https://www.npmjs.com/package/snarkjs>.

iden3 2026b, *circom: circuit compiler for zero-knowledge proofs*, viewed 7 October 2026, <https://docs.circom.io/>.

Jaiman, V. & Urovi, V. 2020, 'A consent model for blockchain-based health data sharing platforms', *IEEE Access*, vol. 8, pp. 143734–143745, <https://doi.org/10.1109/ACCESS.2020.3014565>.

Jesus, V. & Pandit, H.J. 2022, 'Consent receipts for a usable and auditable web of personal data', *IEEE Access*, vol. 10, pp. 28545–28563, <https://doi.org/10.1109/ACCESS.2022.3157850>.

Jiang, R., Chen, X., Yu, Y., Zhang, Y. & Ding, W. 2023, 'Risk and UCON-based access control model for healthcare big data', *Journal of Big Data*, vol. 10, no. 1, p. 104, <https://doi.org/10.1186/s40537-023-00783-8>.

Kaplow, K., Downey, M., Stewart, D., Massie, A.B., Motter, J.D., Taylor, L. et al. 2024, 'Data professionals' attitudes on data privacy, sharing, and consent in healthcare and research', *Digital Health*, vol. 10, p. 20552076241290964, <https://doi.org/10.1177/20552076241290964>.

Khalid, M.I., Ahmed, M., Helfert, M. & Kim, J. 2023, 'Privacy-first paradigm for dynamic consent management systems: Empowering data subjects through decentralized data controllers and privacy-preserving techniques', *Electronics*, vol. 12, no. 24, p. 4973, <https://doi.org/10.3390/electronics12244973>.

Kharlamov, A., Hohmann, R. & Parry, G. 2023, 'Data sharing decisions: Perceptions and intentions in healthcare', *Strategic Change*, vol. 32, no. 6, pp. 223–237, <https://doi.org/10.1002/jsc.2558>.

Khayer, B., Mirzaei, S., Alavizadeh, H. & Salehi Shahraki, A. 2025, 'Blockchain for secure IoT: A review of identity management, access control, and trust mechanisms', *IoT*, vol. 6, no. 4, p. 65, <https://doi.org/10.3390/iot6040065>.

Li, L., Liu, C.Z. & Shrestha, S. 2026, 'Analytical entropy approach for measuring blockchain immutability and tamper-resilient trust', *Entropy*, vol. 28, no. 6, p. 690, <https://doi.org/10.3390/e28060690>.

Li, H., Li, D., Lv, G., Crespi, N., Minerva, R., Shao, W. et al. 2026a, 'Privacy-preserving fine-grained EMR access control for IoMT: A hybrid RBAC-smart contract scheme with attribute-based authorization', *IEEE Internet of Things Journal*, vol. 13, no. 2, pp. 2970–2987, <https://doi.org/10.1109/JIOT.2025.3633504>.

Li, L., Liu, C.Z., Huang, K., Deng, R., Alrowaily, M.A., Alghamdi, M. et al. 2026b, 'Trust-aware environmental state consensus for smart agriculture with TEE-enabled sensing and Byzantine-resilient blockchain coordination', *Sensors*, vol. 26, no. 14, p. 4577, <https://doi.org/10.3390/s26144577>.

Lomotey, R.K., Kumi, S. & Deters, R. 2022, 'Data trusts as a service: Providing a platform for multi-party data sharing', *International Journal of Information Management Data Insights*, vol. 2, no. 1, p. 100075, <https://doi.org/10.1016/j.jjimei.2022.100075>.

Madine, M.M., Salah, K., Jayaraman, R., Yaqoob, I., Al-Hammadi, Y., Ellahham, S. et al. 2020, 'Fully decentralized multi-party consent management for secure sharing of patient health records', *IEEE Access*, vol. 8, pp. 225777–225791, <https://doi.org/10.1109/ACCESS.2020.3045048>.

Maruthi, V. & Singh, K. 2025, 'Enhancing security and privacy of IoMT data for unconscious patient with blockchain', *IEEE Transactions on Network and Service Management*, vol. 22, no. 6, pp. 5223–5238, <https://doi.org/10.1109/TNSM.2025.3602117>.

Mazzocca, C., Acar, A., Uluagac, A.S., Montanari, R., Bellavista, P. & Conti, M. 2025, 'A survey on decentralized identifiers and verifiable credentials', *IEEE Communications Surveys & Tutorials*, vol. 27, no. 6, pp. 3641–3671, <https://doi.org/10.1109/COMST.2025.3543197>.

McClelland, R. & Harper, C.M. 2023, 'Information privacy in healthcare — the vital role of informed consent', *European Journal of Health Law*, vol. 30, no. 4, pp. 469–480, <https://doi.org/10.1163/15718093-bja10097>.

Mei, L., Huang, K., Li, X., Wang, H. & Zhang, X. 2026, 'Efficient dual-revocation CP-ABE for secure and fine-grained data sharing in IoMT', *IEEE Internet of Things Journal*, vol. 13, no. 14, pp. 30933–30940, <https://doi.org/10.1109/JIOT.2026.3685269>.

Ménétrey, J., Göttel, C., Khurshid, A., Pasin, M., Felber, P., Schiavoni, V. et al. 2022, 'Attestation mechanisms for trusted execution environments demystified', *IFIP International Conference on Distributed Applications and Interoperable Systems (DAIS 2022), LNCS*, vol. 13272, pp. 95–113, Springer, <https://doi.org/10.1007/978-3-031-16092-9_7>.

Narkhede, M.R., Wankhede, N.I. & Kamble, A.M. 2025, 'Enhancing patient autonomy in data ownership: Privacy models and consent frameworks for healthcare', *Journal of Digital Health*, vol. 4, no. 1, pp. 1–23, <https://doi.org/10.55976/jdh.4202513361-23>.

Nassar Kyriakidou, C.D., Papathanasiou, A.M. & Polyzos, G.C. 2023, 'Decentralized identity with applications to security and privacy for the internet of things', *Computer Networks and Communications*, vol. 1, no. 2, pp. 244–271, <https://doi.org/10.37256/cnc.1220233048>.

Nazir, A., Rehmani, M.H., Butler, B. & O'Shea, D. 2026, 'Access control in healthcare IoT: A comprehensive survey', *Engineering Reports*, vol. 8, no. 4, p. e70766, <https://doi.org/10.1002/eng2.70766>.

Nguyen, T.L., Nguyen, L., Hoang, T., Bandara, D., Wang, Q., Lu, Q. et al. 2025, 'Blockchain-empowered trustworthy data sharing: Fundamentals, applications, and challenges', *ACM Computing Surveys*, vol. 57, no. 8, p. 195, <https://doi.org/10.1145/3718082>.

Page, M.J., McKenzie, J.E., Bossuyt, P.M., Boutron, I., Hoffmann, T.C., Mulrow, C.D. et al. 2021, 'The PRISMA 2020 statement: An updated guideline for reporting systematic reviews', *BMJ*, vol. 372, p. n71, <https://doi.org/10.1136/bmj.n71>.

Panagoulias, D.P., Damian, A.I., Stamate, C., Toderian, V., Butusina, P., De Franceschi, A. et al. 2026, 'Blockchain-enabled trust and compliance for clinical AI: Decentralized governance without decentralized data storage', *Electronics*, vol. 15, no. 14, p. 3046, <https://doi.org/10.3390/electronics15143046>.

Parameswarath, R.P., Gope, P. & Sikdar, B. 2022, 'User-empowered privacy-preserving authentication protocol for electric vehicle charging based on decentralized identity and verifiable credential', *ACM Transactions on Management Information Systems*, vol. 13, no. 4, p. 44, <https://doi.org/10.1145/3532869>.

Peffers, K., Tuunanen, T., Rothenberger, M.A. & Chatterjee, S. 2007, 'A design science research methodology for information systems research', *Journal of Management Information Systems*, vol. 24, no. 3, pp. 45–77, <https://doi.org/10.2753/MIS0742-1222240302>.

Phuyal, S., Bhandari, M., Bista, R. & Ferreira, J.C. 2026a, 'A blockchain-based architecture for dynamic and auditable patient consent in secondary use of health data', *Blockchain in Healthcare Today*, vol. 9, no. 1, p. 491, <https://doi.org/10.30953/bhty.v9.491>.

Phuyal, S., Bhandari, M., Bista, R. & Ferreira, J.C. 2026b, 'Enabling cross-institution health data sharing in Norway: EUDI wallets, on-chain consent, and openEHR ↔ FHIR translation', *IEEE Access*, vol. 14, pp. 20309–20327, <https://doi.org/10.1109/ACCESS.2026.3661642>.

Prashanth, M.S., Karnati, R., Velpuru, M.S. & Venkateshwara Reddy, H. 2024, 'Enhancing health record security and privacy with blockchain-based access management', *Pervasive Knowledge and Collective Intelligence on Web and Social Media (PerSOM 2023), LNICST*, vol. 517, pp. 182–202, Springer, <https://doi.org/10.1007/978-3-031-66044-3_13>.

Punia, A., Gulia, P., Gill, N.S., Kaushik, D., Alduaiji, N., Shukla, P.K. et al. 2025, 'An access control system for cloud-based healthcare systems driven by blockchain', *Journal of Cloud Computing*, vol. 14, no. 1, p. 78, <https://doi.org/10.1186/s13677-025-00831-z>.

Román-Martínez, I., Calvillo-Arbizu, J., Mayor-Gallego, V.J., Madinabeitia-Luque, G., Estepa-Alonso, A.J. & Estepa-Alonso, R.M. 2023, 'Blockchain-based service-oriented architecture for consent management, access control, and auditing', *IEEE Access*, vol. 11, pp. 12727–12741, <https://doi.org/10.1109/ACCESS.2023.3242605>.

Sawant, N.M. & Gomes, J. 2026, 'A decentralized solution for smarter and safer healthcare systems with FabricMedChain', *Iranian Journal of Science and Technology, Transactions of Electrical Engineering*, vol. 50, pp. 2843–2869, <https://doi.org/10.1007/s40998-025-00994-0>.

Shanmugham, M. & Senthilkumar, C. 2026, 'Blockchain enabled self-sovereign identity and consent framework for secure healthcare data access', *2026 3rd International Conference on Emerging Trends in Engineering and Medical Sciences (ICETEMS)*, pp. 1–6, <https://doi.org/10.1109/ICETEMS66917.2026.11469586>.

SooHoo, S.L., Keller, M.S., Chen, Y., Hu, D., Huang, S.-C., Kuo, T.-T. et al. 2026, 'Development of the authentication and authorization processes for the iAgree portal, a platform for patient-controlled data sharing across health systems', *JAMIA Open*, vol. 9, no. 3, p. ooag111, <https://doi.org/10.1093/jamiaopen/ooag111>.

Tan, K.-L., Chi, C.-H. & Lam, K.-Y. 2024, 'Secure and privacy-preserving sharing of personal health records with multi-party pre-authorization verification', *Wireless Networks*, vol. 30, no. 4, pp. 4773–4795, <https://doi.org/10.1007/s11276-022-03114-6>.

Tawfik, A.M., Al-Ahwal, A., Tag Eldien, A.S. & Zayed, H.H. 2025, 'Blockchain-based access control and privacy preservation in healthcare: A comprehensive survey', *Cluster Computing*, vol. 28, p. 529, <https://doi.org/10.1007/s10586-025-05308-x>.

Teeda, A. & Subba Rao, Y.V. 2026, 'A patient-centric blockchain based electronic health records for data privacy and confidentiality', *International Conference on Smart Computing and Informatics, LNNS*, vol. 1684, pp. 179–192, Springer, <https://doi.org/10.1007/978-3-032-08246-6_15>.

Theodorakopoulos, L., Theodoropoulou, A. & Halkiopoulos, C. 2024, 'Enhancing decentralized decision-making with big data and blockchain technology: A comprehensive review', *Applied Sciences*, vol. 14, no. 16, p. 7007, <https://doi.org/10.3390/app14167007>.

Tith, D., Lee, J.-S., Suzuki, H., Wijesundara, W.M.A.B., Taira, N., Obi, T. et al. 2020, 'Patient consent management by a purpose-based consent model for electronic health record based on blockchain technology', *Healthcare Informatics Research*, vol. 26, no. 4, pp. 265–273, <https://doi.org/10.4258/hir.2020.26.4.265>.

Tremper, G., Brenner, T., Ben Amor, M., Kussel, T. & Lablans, M. 2026, 'Mainzelliste: Ten years of pseudonymization, record linkage, and informed consent management', *Patterns*, vol. 7, no. 1, p. 101432, <https://doi.org/10.1016/j.patter.2025.101432>.

Tseng, C.-H., Hsieh, Y.-H., Lin, H.-Y. & Yuan, S.-M. 2025, 'EMR-Chain: Decentralized electronic medical record exchange system', *Technologies*, vol. 13, no. 10, p. 446, <https://doi.org/10.3390/technologies13100446>.

Turan, M.N., Hashimzai, I.A. & Qiam, M.Q. 2025, 'A blockchain-based framework for secure and transparent environmental data sharing in smart cities: Enhancing trust, integrity, and interoperability in urban sustainability systems', *Nata Palemahan: Journal of Environmental Engineering Innovations*, vol. 2, no. 2, pp. 70–79, <https://doi.org/10.38043/natapalemahan.v2i2.6996>.

Walonoski, J., Kramer, M., Nichols, J., Quina, A., Moesel, C., Hall, D. et al. 2018, 'Synthea: An approach, method, and software mechanism for generating synthetic patients and the synthetic electronic health care record', *Journal of the American Medical Informatics Association*, vol. 25, no. 3, pp. 230–238, <https://doi.org/10.1093/jamia/ocx079>.

Webber, E.C., Brick, D., Scibilia, J.P., Dehnel, P., Council on Clinical Information Technology et al. 2019, 'Electronic communication of the health record and information with pediatric patients and their guardians', *Pediatrics*, vol. 144, no. 1, p. e20191359, <https://doi.org/10.1542/peds.2019-1359>.

Welzel, C., Ostermann, M., Smith, H.L., Minssen, T., Kirsten, T. & Gilbert, S. 2025, 'Enabling secure and self determined health data sharing and consent management', *npj Digital Medicine*, vol. 8, no. 1, p. 560, <https://doi.org/10.1038/s41746-025-01945-z>.

Wood, G. 2014, *Ethereum: A secure decentralised generalised transaction ledger*, Ethereum Project Yellow Paper.

Wu, Y., Liu, C., Sebald, L., Nguyen, P. & Yesha, Y. 2022, 'Apply trust computing and privacy preserving smart contracts to manage, share, and analyze multi-site clinical trial data', *Proceedings of the International Conference on Deep Learning, Big Data and Blockchain (DBB 2022), LNNS*, vol. 541, pp. 3–14, Springer, <https://doi.org/10.1007/978-3-031-16035-6_1>.

Wu, Z. & Zhang, D. 2025, 'HealthDID: An efficient and authorizable multi-party privacy-preserving EMR sharing system based on DID', *Computer Standards & Interfaces*, vol. 93, p. 103967, <https://doi.org/10.1016/j.csi.2024.103967>.

Yin, H., Zhao, Y., Zhang, L., Qiao, B., Chen, W. & Wang, H. 2024, 'Attribute-based searchable encryption with decentralized key management for healthcare data sharing', *Journal of Systems Architecture*, vol. 148, p. 103081, <https://doi.org/10.1016/j.sysarc.2024.103081>.

Yin, J., Xiao, Y., Chen, Q., Lim, Y.Z., Liu, X., Pei, Q. et al. 2025, 'DP-DID: A dynamic and proactive decentralized identity system', *IEEE Transactions on Information Forensics and Security*, vol. 20, pp. 4999–5014, <https://doi.org/10.1109/TIFS.2025.3561662>.

Zhang, L., Kan, H. & Huang, H. 2022, 'Patient-centered cross-enterprise document sharing and dynamic consent framework using consortium blockchain and ciphertext-policy attribute-based encryption', *Proceedings of the 19th ACM International Conference on Computing Frontiers (CF '22)*, pp. 58–66, <https://doi.org/10.1145/3528416.3530228>.

Zhao, J. & Su, Q. 2024, 'A threshold traceable delegation authorization scheme for data sharing in healthcare', *Computers & Security*, vol. 139, p. 103686, <https://doi.org/10.1016/j.cose.2023.103686>.